Scan Report

Test-E2E-on-Rel-can/Test-GH-UI-SCM-...

Grouped By: Vulnerability Type
Scanned Branch Name: master
Project Created: 01 Apr, 2026 | 4:26 PM
Last Scanned: 01 Apr, 2026 | 4:26 PM
Timezone: Asia/Calcutta
Scanners: SAST, IaC Security, Container Security, SCA, SCS

C	111
H	94
M	197
L	41
I	11
	454

Table of Contents

Filtered By 4
Scan Information 4
Project & Scan Tags 4
Scan Results Overview 5
- By Scanner 5
- By Status 5
- By Severity 5
- By State 5
- By Language 5
- By Technology 5
- By Package 6
- By SAST Vulnerability 6
- Top 10 SAST Vulnerabilities 8
- Top 10 SAST Vulnerable Files 8
- 5 Oldest SAST Vulnerabilities 8

SAST Vulnerabilities 10
- By Severity 10

SAST Scan Results 10
- SQL_Injection 10
- Stored_XSS 27
- Second_Order_SQL_Injection 48
- Unsafe_Reflection 52
- SSRF 53
- Relative_Path_Traversal 55
- Reflected_XSS 60
- Improper_Restriction_of_XXE_Ref 66
- Connection_String_Injection 67
- Absolute_Path_Traversal 69
- Use_Of_Hardcoded_Password 70
- XPath_Injection 72
- Use_of_Broken_or_Risky_Cryptographic_Algorithm 74
- Unchecked_Input_for_Loop_Condition 75
- Parameter_Tampering 76
- CSRF 80
- Privacy_Violation 136
- Plaintext_Storage_of_a_Password 140
- Open_Redirect 141
- Missing_HSTS_Header 144
- Trust_Boundary_Violation_in_Session_Variables 145
- Heap_Inspection 146

IaC Security Vulnerabilities 149
- By Severity 149

IaC Security Scan Results 149

CICD 149
Terraform 149
Common 163
Dockerfile 163
SCA Vulnerabilities 166
By Severity 166
SCA Scan Results 166
Maven-org.json:json-20131018 166
Maven-org.apache.tomcat:tomcat-coyote-9.0.22 168
Maven-mysql:mysql-connector-java-5.1.26 176
Maven-commons-collections:commons-collections-3.2.1 180
Maven-dom4j:dom4j-1.6.1 182
Maven-org.hibernate:hibernate-core-4.0.1.Final 183
Npm-jquery-1.6.4 183
Maven-org.apache.tomcat:tomcat-util-9.0.22 185
Container Security Vulnerabilities 186
By Severity 186
Container Security Scan Results 186
node 186
SAST Resolved Vulnerabilities 200
Categories 201
ASA Mobile Premium 201
ASA Premium 201
ASD STIG 6.1 201
Base Preset 201
CWE top 25 202
FISMA 2014 202
MOIS(KISA) Secure Coding 2021 202
NIST SP 800-53 202
OWASP ASVS 203
OWASP Mobile Top 10 2016 203
OWASP Mobile Top 10 2024 203
OWASP Top 10 2013 204
OWASP Top 10 2017 204
OWASP Top 10 2021 204
OWASP Top 10 API 205
OWASP Top 10 API 2023 205
PCI DSS v3.2.1 206
PCI DSS v4.0 206
SANS top 25 206
Top Tier 206
Vulnerability Details 208
SQL_Injection 208
Stored_XSS 208
Second_Order_SQL_Injection 209
Unsafe_Reflection 209
SSRF 210
Relative_Path_Traversal 210
Reflected_XSS 210
Improper_Restriction_of_XXE_Ref 211
Connection_String_Injection 211
Use_Of_Hardcoded_Password 212

XPath_Injection 212
Use_of_Broken_or_Risky_Cryptographic_Algorithm 213
Unchecked_Input_for_Loop_Condition 213
Parameter_Tampering 213
CSRF 214
Privacy_Violation 214
Plaintext_Storage_of_a_Password 215
Open_Redirect 215
Missing_HSTS_Header 216
Trust_Boundary_Violation_in_Session_Variables 216
Heap_Inspection 217
Supply Chain Security Vulnerabilities 218

Filtered By

Severity: C H M L I

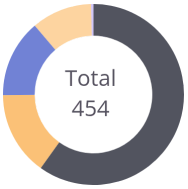
Excluded: None

Result State: To Verify, Not Exploitable, Proposed Not Exploitable, Confirmed, Urgent

Excluded: Roh2, del_check, system-tests, LicenseReview, , mariia-test, rg-rn-test, rg-sast-custom-states, Effective, Effective2026-01-20, MT, test-bb, urmi_custom1, e2e, E2E2, test-smr-cust-state, PROPOSED NOT EXPLOITABLE, test-custm-urm, Bor-CustomState, rn_customstates, rn_test_custom, rn_e2e, test_test_custom, a_b-cd, Propose Not Exploitable, pppppppppppppppppppppppppppppppppppppppppppppppppppppppppppppppppppppppppppppppaaa

Scan Results Overview

By Scanner

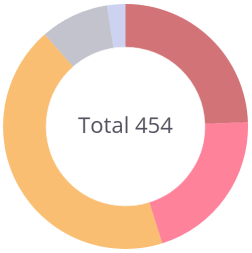


- SAST (272, 59.91%)
- IaC(68, 14.98%)
- SCA (63, 13.88%)
- CON (49, 10.79%)
- SCS (2, 0.44%)

By Status (SAST & IaC & SCA & SCS)

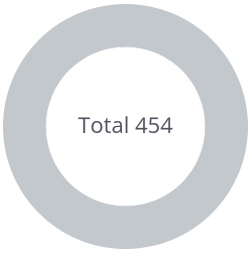
- New (405, 100%)
- Recurrent (0, 0%)

By Severity



Legend	Density (SAST & IaC)
Critical (111, 24.45%)	28.28
High (94, 20.70%)	11.14
Medium (197, 43.39%)	45.99
Low (41, 9.03%)	9.14
Information (11, 2.42%)	3.14

By State



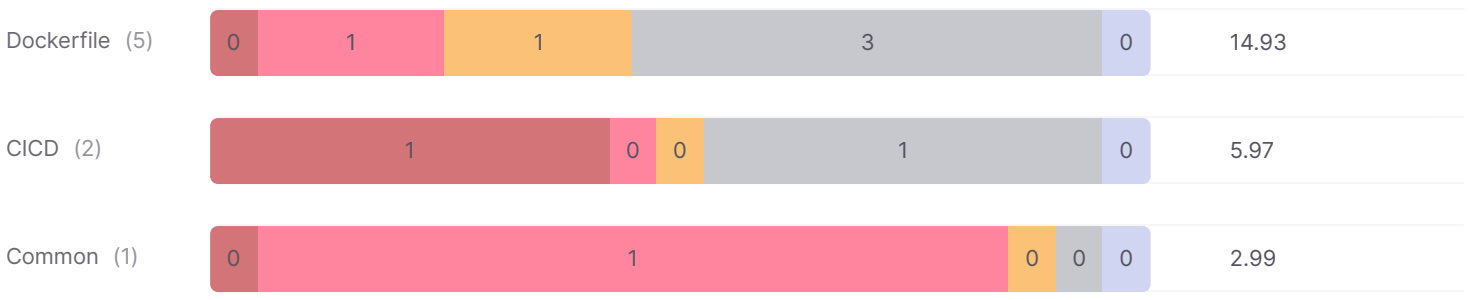
Legend	Density (SAST & IaC)
To Verify (454, 100.00%)	97.12
Not Exploitable (0, 0.00%)	0.00
Proposed Not Exploitable (0, 0.00%)	0.00
Confirmed (0, 0.00%)	0.00
Urgent (0, 0.00%)	0.00

By Language (SAST)

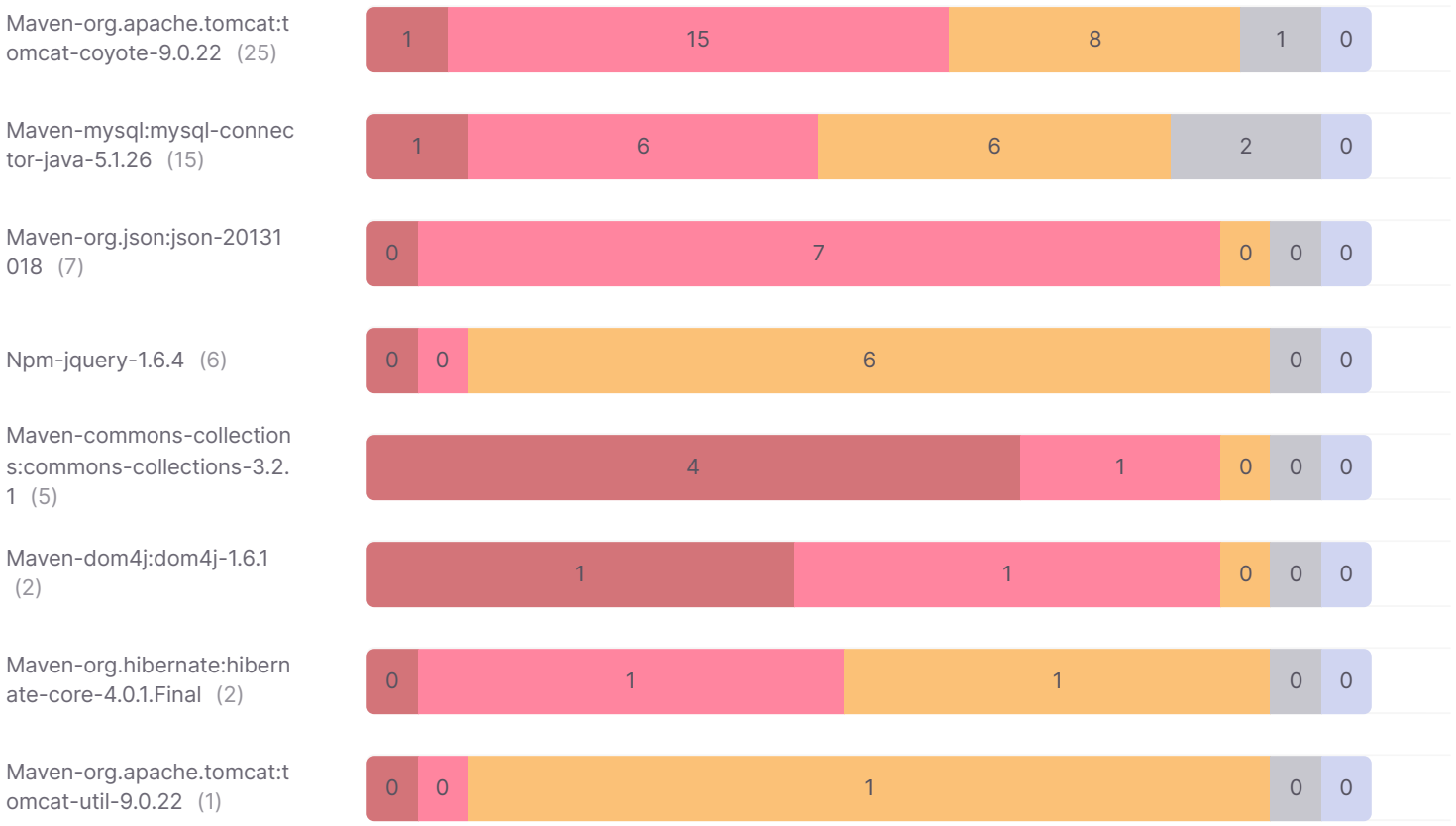
						Density (SAST)
java (272)	93	31	138	10	0	85.91

By Technology (IaC)

						Density (IaC)
Terraform (60)	5	4	22	18	11	179.1



By Package (SCA)



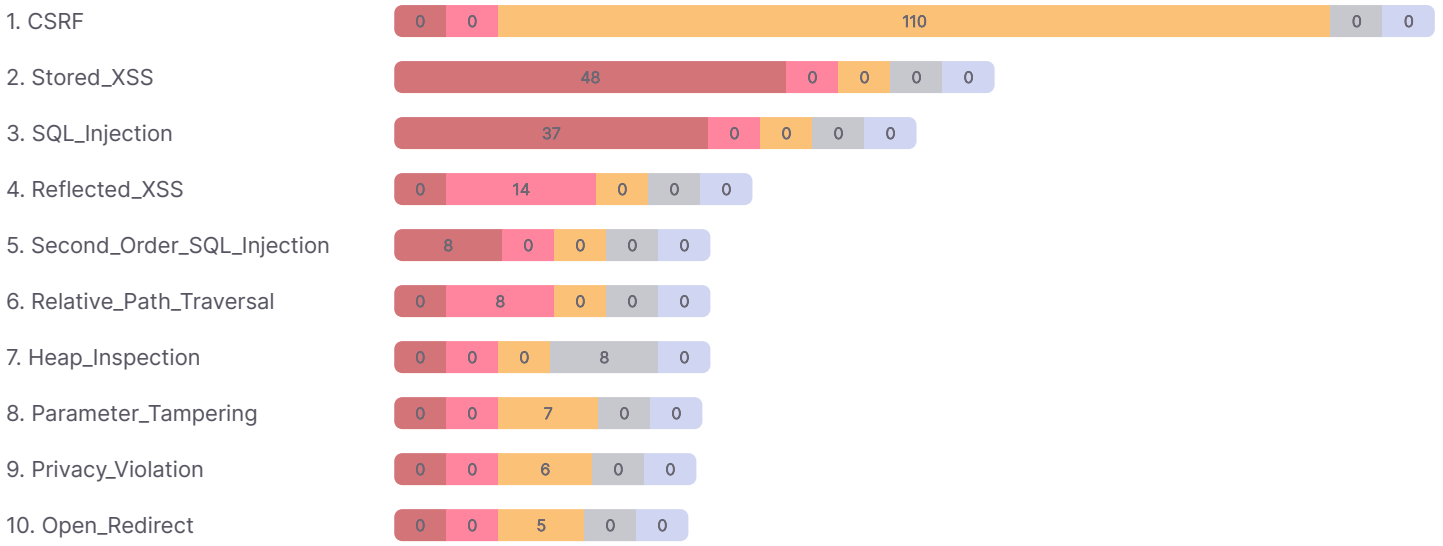
By SAST Vulnerability

	Vulnerability Type	C	H	M	L	I
C	Stored_XSS In 20 Files	48	0	0	0	0
C	SQL_Injection In 22 Files	37	0	0	0	0
C	Second_Order_SQL_Injection In 6 Files	8	0	0	0	0
H	Reflected_XSS In 10 Files	0	14	0	0	0

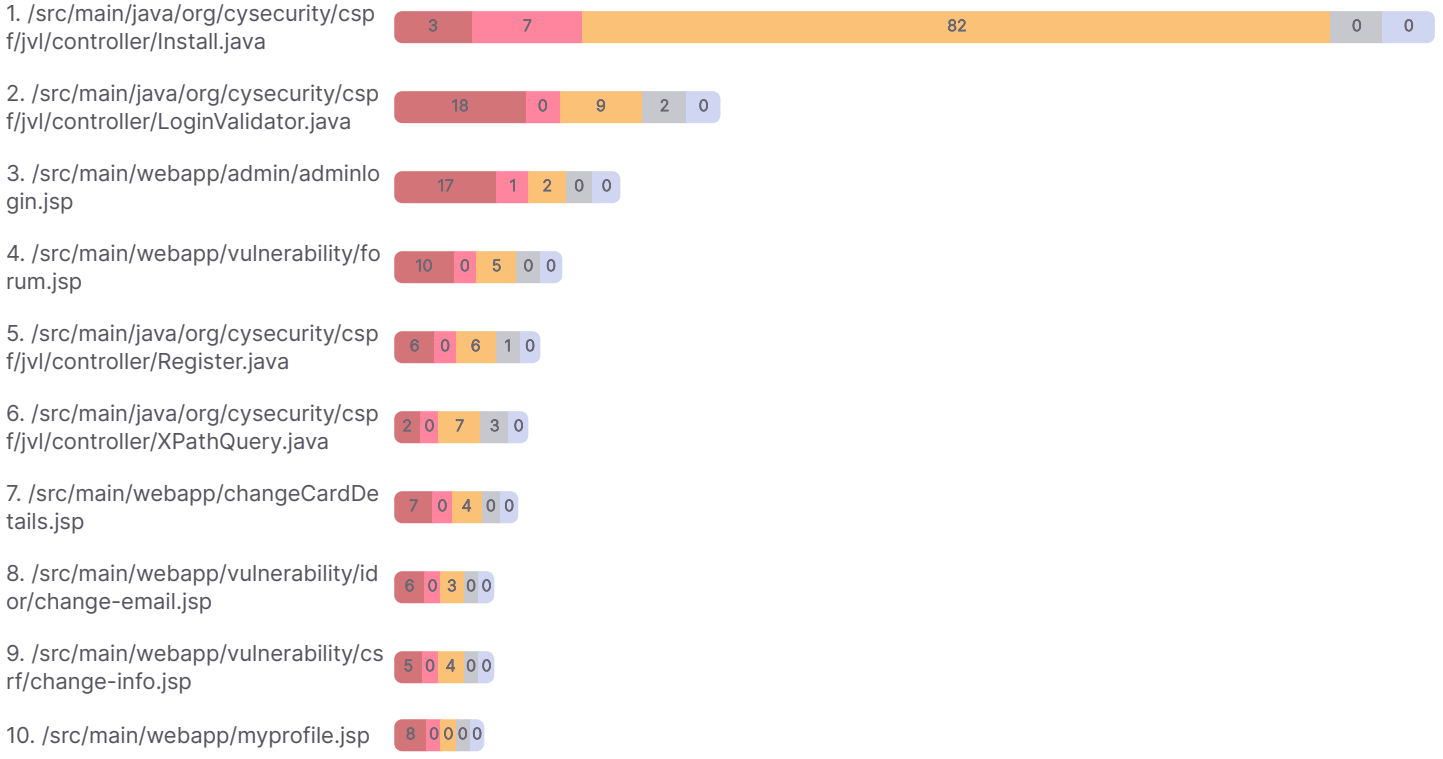
H	Relative_Path_Traversal In 6 Files	0	8	0	0	0
H	Connection_String_Injection In 1 Files	0	3	0	0	0
H	SSRF In 1 Files	0	3	0	0	0
H	Absolute_Path_Traversal In 1 Files	0	1	0	0	0
H	Improper_Restriction_of_XXE_Ref In 1 Files	0	1	0	0	0
H	Unsafe_Reflection In 1 Files	0	1	0	0	0
M	CSRF In 12 Files	0	0	110	0	0
M	Parameter_Tampering In 7 Files	0	0	7	0	0
M	Privacy_Violation In 5 Files	0	0	6	0	0
M	Open_Redirect In 2 Files	0	0	5	0	0
M	Use_Of_Hardcoded_Password In 3 Files	0	0	4	0	0
M	XPath_Injection In 1 Files	0	0	2	0	0
M	Missing_HSTS_Header In 1 Files	0	0	1	0	0
M	Plaintext_Storage_of_a_Password In 1 Files	0	0	1	0	0
M	Unchecked_Input_for_Loop_Conditio n In 1 Files	0	0	1	0	0
M	Use_of_Broken_or_Risky_Cryptograph ic_Algorithm In 1 Files	0	0	1	0	0
L	Heap_Inspection In 7 Files	0	0	0	8	0

	Trust_Boundary_Violation_in_Session_Variables In 1 Files	0	0	0	2	0
	Total In 45 Files	93	31	138	10	0

Top 10 SAST Vulnerabilities (251/45 Vulnerable files)



Top 10 SAST Vulnerable Files (45/133 Files)



5 Oldest SAST Vulnerabilities by severity

No data to show for Information severity

SAST Vulnerabilities

By Severity

93	31	138	10	0	272

SAST Scan Results (272)

SQL_Injection (Type)

Query Path: Java/Java_Critical_Risk/SQL_Injection

CWE Id: 89

Total results: 37

Description: The application's @DestinationMethod method executes an SQL query with @DestinationElement, at line @DestinationLine of @DestinationFile. The application constructs this SQL query by embedding an untrusted string into the query without proper sanitization. The concatenated string is submitted to the database, where it is parsed and executed accordingly. An attacker would be able to inject arbitrary syntax and data into the SQL query, by crafting a malicious payload and providing it via the input @SourceElement; this input is then read by the @SourceMethod method at line @SourceLine of @SourceFile. This input then flows through the code, into a query and to the database server - without sanitization. This may enable an SQL Injection attack.

Category:

- ASA Mobile Premium: ASA Mobile Premium
- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-002540 - CAT I The application must not be vulnerable to SQL Injection.
- Base Preset: Base Preset
- CWE top 25: CWE top 25
- FISMA 2014: System And Information Integrity
- MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data
- NIST SP 800-53: SI-10 Information Input Validation (P1)
- OWASP ASVS: V05 Validation, Sanitization and Encoding
- OWASP Mobile Top 10 2016: M7-Client Code Quality
- OWASP Mobile Top 10 2024: M4: Insufficient Input/Output Validation
- OWASP Top 10 2013: A1-Injection
- OWASP Top 10 2021: A3-Injection
- OWASP Top 10 API: API8-Injection
- PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.1 - Injection flaws - particularly SQL injection
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development
- SANS top 25: SANS top 25
- Top Tier: Top Tier

Result 1 of 37

Critical • Link • New • To Verify • Similarity Id: -989839381 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/XPathQuery.java	File Name: /src/main/webapp/vulnerability/Messages.jsp
Method:	Method:
Element: ""password""	Element: executeQuery

Code Snippets

```
36  String pass=request.getParameter("password");
```

```
14  rs=stmt.executeQuery("select * from UserMessages where recipient='"+session.getAttribute("user")+"'");
```

Result 2 of 37

Critical • Link • New • To Verify • Similarity Id: 1798167916 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/XPathQuery.java	File Name: /src/main/webapp/vulnerability/Messages.jsp
Method:	Method:
Element: ""username""	Element: executeQuery

Code Snippets

```
35  String user=request.getParameter("username");
```

```
14  rs=stmt.executeQuery("select * from UserMessages where recipient='"+session.getAttribute("user")+"'");
```

Result 3 of 37

Critical • Link • New • To Verify • Similarity Id: -1220666521 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/UsernameCheck.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/UsernameCheck.java
Method:	Method:
Element: ""username""	Element: executeQuery

Code Snippets

```
43  String user=request.getParameter("username").trim();
```

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"'");
```

Result 4 of 37

Critical • Link • New • To Verify • Similarity Id: 1252773181 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java
Method:	Method:
Element: ""password""	Element: executeQuery

Code Snippets

```
44  String pass=request.getParameter("password").trim();
```

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"'");
```

Result 5 of 37

Critical • Link • New • To Verify • Similarity Id: -1108102531 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/EmailCheck.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/EmailCheck.java
Method:	Method:
Element: ""email""	Element: executeQuery

Code Snippets

```
45  String email=request.getParameter("email").trim();
```

```
55  rs=stmt.executeQuery("select * from users where email='"+email+"'");
```

Result 6 of 37

Critical • Link • New • To Verify • Similarity Id: -1630064642 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java
Method:	Method:
Element: ""secret""	Element: executeUpdate

Code Snippets

```
47  String secret=request.getParameter("secret");
```

```
58  stmt.executeUpdate("INSERT into users(username, password, email, About,avatar,privilege,secretquestion,secret) values ('"+user+"','"+pass+"','"+email+"','"+about+"','default.jpg','user',1,'"+secret+"')");
```

Result 7 of 37

Critical • Link • New • To Verify • Similarity Id: -568636637 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
117  stmt.executeUpdate("DROP DATABASE IF EXISTS "+dbname);
```

Result 8 of 37

Critical • Link • New • To Verify • Similarity Id: -1570252881 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
119  stmt.executeUpdate("CREATE DATABASE "+dbname);
```

Result 9 of 37

Critical • Link • New • To Verify • Similarity Id: 622567378 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/sqs.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/sqs.java
Method:	Method:
Element: receiveMessage	Element: executeQuery

Code Snippets

```
25  List<Message> messages = sqs.receiveMessage("examplequeue").getMessages();
```

```
37  rs = stmt.executeQuery("SELECT id FROM t where data = '" + data + "'");
```

Result 10 of 37

Critical • Link • New • To Verify • Similarity Id: 1902381568 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""adminuser""	Element: executeUpdate

Code Snippets

```
60  adminuser= request.getParameter("adminuser");
```

```
127  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('"+adminuser+"','"+adminpass+"','admin@localhost','I am the admin of this application','default.jpg','admin',1,'rocky')");
```

Result 11 of 37

Critical • Link • New • To Verify • Similarity Id: -1698865400 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/vulnerability/csrf/changepassword.jsp	File Name: /src/main/webapp/vulnerability/csrf/changepassword.jsp
Method:	Method:
Element: ""password""	Element: executeUpdate

Code Snippets

```
33  String pass=request.getParameter("password");
```

```
40  stmt.executeUpdate("Update users set password='"+pass+"' where id="+id);
```

Result 12 of 37

Critical • Link • New • To Verify • Similarity Id: -1460055383 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/vulnerability/csrf/change-info.jsp	File Name: /src/main/webapp/vulnerability/csrf/change-info.jsp
Method:	Method:
Element: ""info""	Element: executeUpdate

Code Snippets

```
26  String info=request.getParameter("info");
```

```
31  stmt.executeUpdate("Update users set about='"+info+"' where id="+id);
```

Result 13 of 37

Critical • Link • New • To Verify • Similarity Id: -1171463241 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/vulnerability/idor/change-email.jsp	File Name: /src/main/webapp/vulnerability/idor/change-email.jsp
Method:	Method:
Element: ""email""	Element: executeUpdate

Code Snippets

```
27  String email=request.getParameter("email");
```

```
32  stmt.executeUpdate("Update users set email='"+email+"' where id="+id);
```

Result 14 of 37

Critical • Link • New • To Verify • Similarity Id: 1815908888 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/changeCardDetails.jsp	File Name: /src/main/webapp/changeCardDetails.jsp
Method:	Method:
Element: ""cardno""	Element: executeUpdate

Code Snippets

```
37  String cardno=request.getParameter("cardno");
```

```
43  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('"+id+"','"+cardno+"','"+cvv+"','"+expirydate
    +"')");
```

Result 15 of 37

Critical • Link • New • To Verify • Similarity Id: -1821802856 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/changeCardDetails.jsp	File Name: /src/main/webapp/changeCardDetails.jsp
Method:	Method:
Element: ""cvv""	Element: executeUpdate

Code Snippets

```
38  String cvv=request.getParameter("cvv");
```

```
43  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('"+id+"','"+cardno+"','"+cvv+"','"+expirydate
    +"')");
```

Result 16 of 37

Critical • Link • New • To Verify • Similarity Id: -1838076392 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/changeCardDetails.jsp	File Name: /src/main/webapp/changeCardDetails.jsp
Method:	Method:
Element: ""expirydate""	Element: executeUpdate

Code Snippets

```
39  String expirydate=request.getParameter("expirydate");
```

```
43  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('"+id+"','"+cardno+"','"+cvv+"','"+expirydate
    +"')");
```

Result 17 of 37

Critical • Link • New • To Verify • Similarity Id: 687083096 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java
Method:	Method:
Element: ""username""	Element: executeQuery

Code Snippets

```
43  String user=request.getParameter("username").trim();
```

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"'");
```

Result 18 of 37

Critical • Link • New • To Verify • Similarity Id: 1212367342 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/vulnerability/forum.jsp	File Name: /src/main/webapp/vulnerability/forum.jsp
Method:	Method:
Element: ""title""	Element: executeUpdate

Code Snippets

```
43  String title=request.getParameter("title");
```

```
48  stmt.executeUpdate("INSERT into posts(content,title,user) values ('"+content+"','"+title+"','"+user+"')");
```

Result 19 of 37

Critical • Link • New • To Verify • Similarity Id: -949802697 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/vulnerability/sqli/download_id.jsp	File Name: /src/main/webapp/vulnerability/sqli/download_id.jsp
Method:	Method:
Element: ""fileid""	Element: executeQuery

Code Snippets

```
18  String fileid=request.getParameter("fileid");
```

```
24  rs=stmt.executeQuery("select * from FilesList where fileid="+fileid);
```

Result 20 of 37

Critical • Link • New • To Verify • Similarity Id: 119781687 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/vulnerability/sqli/download_id_union.jsp	File Name: /src/main/webapp/vulnerability/sqli/download_id_union.jsp
Method:	Method:
Element: ""fileid""	Element: executeQuery

Code Snippets

```
18  String fileid=request.getParameter("fileid");
```

```
24  rs=stmt.executeQuery("select * from FilesList where fileid="+fileid);
```

Result 21 of 37

Critical • Link • New • To Verify • Similarity Id: 1264789815 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/myprofile.jsp	File Name: /src/main/webapp/myprofile.jsp
Method:	Method:
Element: ""id""	Element: executeQuery

Code Snippets

```
16  String id=request.getParameter("id");
```

```
29  ResultSet rs1=stmt.executeQuery("select * from cards where id="+id);
```

Result 22 of 37

Critical • Link • New • To Verify • Similarity Id: 1564773570 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/myprofile.jsp	File Name: /src/main/webapp/myprofile.jsp
Method:	Method:
Element: ""id""	Element: executeQuery

Code Snippets

```
16  String id=request.getParameter("id");
```

```
21  rs=stmt.executeQuery("select * from users where id="+id);
```

Result 23 of 37

Critical • Link • New • To Verify • Similarity Id: -1445077046 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/vulnerability/UserDetails.jsp	File Name: /src/main/webapp/vulnerability/UserDetails.jsp
Method:	Method:
Element: ""username""	Element: executeQuery

Code Snippets

```
8   String username=request.getParameter("username");
```

```
13  rs=stmt.executeQuery("select * from users where username='"+username+"'");
```

Result 24 of 37

Critical • Link • New • To Verify • Similarity Id: 2104399734 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java
Method:	Method:
Element: ""About""	Element: executeUpdate

Code Snippets

```
46  String about=request.getParameter("About");
```

```
58  stmt.executeUpdate("INSERT into users(username, password, email, About,avatar,privilege,secretquestion,secret) values ('"+user+"','"+pass+"','"+email+"','"+about+"','default.jpg','user',1,'"+secret+"')");
```

Result 25 of 37

Critical • Link • New • To Verify • Similarity Id: -840452232 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java
Method:	Method:
Element: ""email""	Element: executeUpdate

Code Snippets

```
45  String email=request.getParameter("email");
```

```
58  stmt.executeUpdate("INSERT into users(username, password, email, About,avatar,privilege,secretquestion,secret) values ('"+user+"','"+pass+"','"+email+"','"+about+"','default.jpg','user',1,'"+secret+"')");
```

Result 26 of 37

Critical • Link • New • To Verify • Similarity Id: 1958578452 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java
Method:	Method:
Element: ""password""	Element: executeUpdate

Code Snippets

```
44  String pass=request.getParameter("password");
```

```
58  stmt.executeUpdate("INSERT into users(username, password, email, About,avatar,privilege,secretquestion,secret) values ('"+user+"','"+pass+"','"+email+"','"+about+"','default.jpg','user',1,'"+secret+"')");
```

Result 27 of 37

Critical • Link • New • To Verify • Similarity Id: -487624491 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java
Method:	Method:
Element: ""username""	Element: executeUpdate

Code Snippets

```
43  String user=request.getParameter("username");
```

```
59  stmt.executeUpdate("INSERT into UserMessages(recipient, sender, subject, msg) values ('"+user+"','admin','Hi','Hi<br/> This is admin of this page. <br/> Welcome to Our Forum')");
```

Result 28 of 37

Critical • Link • New • To Verify • Similarity Id: -335970228 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java
Method:	Method:
Element: ""username""	Element: executeUpdate

Code Snippets

```
43  String user=request.getParameter("username");
```

```
58  stmt.executeUpdate("INSERT into users(username, password, email, About,avatar,privilege,secretquestion,secret) values ('"+user+"','"+pass+"','"+email+"','"+about+"','default.jpg','user',1,'"+secret+"')");
```

Result 29 of 37

Critical • Link • New • To Verify • Similarity Id: 783585966 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/vulnerability/forum.jsp	File Name: /src/main/webapp/vulnerability/forum.jsp
Method:	Method:
Element: ""content""	Element: executeUpdate

Code Snippets

```
42  String content=request.getParameter("content");
```

```
48  stmt.executeUpdate("INSERT into posts(content,title,user) values ('"+content+"','"+title+"','"+user+"')");
```

Result 30 of 37

Critical • Link • New • To Verify • Similarity Id: 1851128622 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/vulnerability/forum.jsp	File Name: /src/main/webapp/vulnerability/forum.jsp
Method:	Method:
Element: ""user""	Element: executeUpdate

Code Snippets

```
41  String user=request.getParameter("user");
```

```
48  stmt.executeUpdate("INSERT into posts(content,title,user) values ('"+content+"','"+title+"','"+user+"')");
```

Result 31 of 37

Critical • Link • New • To Verify • Similarity Id: -1170722709 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/vulnerability/idor/change-email.jsp	File Name: /src/main/webapp/vulnerability/idor/change-email.jsp
Method:	Method:
Element: ""id""	Element: executeUpdate

Code Snippets

```
28  String id=request.getParameter("id");
```

```
32  stmt.executeUpdate("Update users set email='"+email+"' where id="+id);
```

Result 32 of 37

Critical • Link • New • To Verify • Similarity Id: -1208818845 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/admin/manageusers.jsp	File Name: /src/main/webapp/admin/manageusers.jsp
Method:	Method:
Element: ""user""	Element: executeUpdate

Code Snippets

```
13  String user=request.getParameter("user");
```

```
14  stmt.executeUpdate("Delete from users where username='"+user+"'");
```

Result 33 of 37

Critical • Link • New • To Verify • Similarity Id: -143075178 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/vulnerability/forumposts.jsp	File Name: /src/main/webapp/vulnerability/forumposts.jsp
Method:	Method:
Element: ""postid""	Element: executeQuery

Code Snippets

```
9  String postid=request.getParameter("postid");
```

```
14  rs=stmt.executeQuery("select * from posts where postid="+postid);
```

Result 34 of 37

Critical • Link • New • To Verify • Similarity Id: 99870067 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/vulnerability/DisplayMessage.jsp	File Name: /src/main/webapp/vulnerability/DisplayMessage.jsp
Method:	Method:
Element: ""msgid""	Element: executeQuery

Code Snippets

```
16  rs=stmt.executeQuery("select * from UserMessages where msgid="+request.getParameter("msgid"));
```

Result 35 of 37

Critical • Link • New • To Verify • Similarity Id: -921477042 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/ForgotPassword.jsp	File Name: /src/main/webapp/ForgotPassword.jsp
Method:	Method:
Element: ""secret""	Element: executeQuery

Code Snippets

```
42  rs=stmt.executeQuery("select * from users where username='"+request.getParameter("username").trim()+"' and secret
    ='"+request.getParameter("secret")+"'");
```

Result 36 of 37

Critical • Link • New • To Verify • Similarity Id: -461260596 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/ForgotPassword.jsp	File Name: /src/main/webapp/ForgotPassword.jsp
Method:	Method:
Element: ""username""	Element: executeQuery

Code Snippets

```
42  rs=stmt.executeQuery("select * from users where username='"+request.getParameter("username").trim()+"' and secret
    ='"+request.getParameter("secret")+"'");
```

Result 37 of 37

Critical • Link • New • To Verify • Similarity Id: -501015144 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/admin/adminlogin.jsp
Method:	Method:
Element: ""username""	Element: executeQuery

Code Snippets

```
11  String user=request.getParameter("username");
```

```
19  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"' and privilege='admin'");
```

Stored_XSS (Type)

Query Path: Java/Java_Critical_Risk/Stored_XSS

CWE Id: 79

Total results: 48

Description: The method @DestinationMethod embeds untrusted data in generated output with @DestinationElement, at line @DestinationLine of @DestinationFile. This untrusted data is embedded into the output without proper sanitization or encoding, enabling an attacker to inject malicious code into the generated web-page. The attacker would be able to alter the returned web page by saving malicious data in a data-store ahead of time. The attacker's modified data is then read from the database by the @SourceMethod method with @SourceElement, at line @SourceLine of @SourceFile. This untrusted data then flows through the code straight to the output web page, without sanitization. This can enable a Stored Cross-Site Scripting (XSS) attack.

Category:

- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-002490 - CAT I The application must protect from Cross-Site Scripting (XSS) vulnerabilities.
- Base Preset: Base Preset
- CWE top 25: CWE top 25
- FISMA 2014: System And Information Integrity
- MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data
- NIST SP 800-53: SI-15 Information Output Filtering (P0)
- OWASP ASVS: V05 Validation, Sanitization and Encoding
- OWASP Mobile Top 10 2024: M4: Insufficient Input/Output Validation
- OWASP Top 10 2013: A3-Cross-Site Scripting (XSS)
- OWASP Top 10 2017: A7-Cross-Site Scripting (XSS)
- OWASP Top 10 2021: A3-Injection
- PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.7 - Cross-site scripting (XSS)
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development
- SANS top 25: SANS top 25
- Top Tier: Top Tier

Result 1 of 48

Critical • Link • New • To Verify • Similarity Id: -1325285888 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/vulnerability/forum.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"'");
```

```
24  out.print("Hello "+session.getAttribute("user")+", Welcome to Our Forum !");
```

Result 2 of 48

Critical • Link • New • To Verify • Similarity Id: 2130948318 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/vulnerability/forum.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"'");
```

```
32  <input type="hidden" name="user" value="<% if(session.getAttribute("user")!=null){out.print(session.getAttribute("use
    r"));} else { out.print("Anonymous"); } %>" size="50"/><br/>
```

Result 3 of 48

Critical • Link • New • To Verify • Similarity Id: 333247898 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/vulnerability/csrf/change-info.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"'");
```

```
35  out.print("<br/><br/><a href='"+path+"/myprofile.jsp?id="+id+"'>Return to Profile Page &gt;&gt;</a>");
```

Result 4 of 48

Critical • Link • New • To Verify • Similarity Id: 1808616641 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source

File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java

Method:

Element: rs

Destination

File Name: /src/main/webapp/index.jsp

Method:

Element: print

Code Snippets

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"'");
```

```
5  out.print("Hello "+session.getAttribute("user")+",");
```

Result 5 of 48

Critical • Link • New • To Verify • Similarity Id: 491614176 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source

File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java

Method:

Element: rs

Destination

File Name: /src/main/webapp/changeCardDetails.jsp

Method:

Element: print

Code Snippets

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"'");
```

```
52  out.print("<br/><br/><a href='"+path+"/myprofile.jsp?id="+id+"'>Return to Profile Page &gt;&gt;</a>");
```

Result 6 of 48

Critical • Link • New • To Verify • Similarity Id: 1039817635 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/header.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"'");
```

```
148  out.print("<li><a href='"+path+"/myprofile.jsp?id="+session.getAttribute("userid")+"'>My Profile</a></li>");
```

Result 7 of 48

Critical • Link • New • To Verify • Similarity Id: 545920191 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/vulnerability/DisplayMessage.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"'");
```

```
35  out.print("<br/><br/><a href='"+path+"/myprofile.jsp?id="+session.getAttribute("userid")+"'>Return to Profile Page &gt;&gt;</a>");
```

Result 8 of 48

Critical • Link • New • To Verify • Similarity Id: -1194821466 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/vulnerability/idor/change-email.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"'");
```

```
36  out.print("<br/><br/><a href='"+path+"/myprofile.jsp?id="+session.getAttribute("userid")+"'>Return to Profile Page &gt;&gt;</a>");
```

Result 9 of 48

Critical • Link • New • To Verify • Similarity Id: 702200398 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/vulnerability/SendMessage.jsp
Method:	Method:
Element: rs	Element: getAttribute

Code Snippets

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"'");
```

```
21  <tr> <td><input type="hidden" name="sender" value="<%=session.getAttribute("user")%>"/></td></tr>
```

Result 10 of 48

Critical • Link • New • To Verify • Similarity Id: 1060719453 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/header.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"'");
```

```
87  <li><a href="<%=path%>/myprofile.jsp?id=<% if(session.getAttribute("userid")!=null){ out.print(session.getAttribute("user
    id"));} %>" title="Make sure you have logged in ">Viewing Details</a>
```

Result 11 of 48

Critical • Link • New • To Verify • Similarity Id: -1404566706 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/vulnerability/Messages.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"'");
```

```
24  out.print("<br/><br/><a href='"+path+"/myprofile.jsp?id="+session.getAttribute("userid")+"'>Return to Profile Page &gt;&
    gt;</a>");
```

Result 12 of 48

Critical • Link • New • To Verify • Similarity Id: -1864242868 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/vulnerability/idor/change-email.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"'");
```

```
19  <input type="hidden" name="id" value="<% out.print(session.getAttribute("userid"));%>"/>
```

Result 13 of 48

Critical • Link • New • To Verify • Similarity Id: 1716236867 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/Injection/orm.jsp	File Name: /src/main/webapp/vulnerability/Injection/orm.jsp
Method:	Method:
Element: list	Element: print

Code Snippets

```
12  List <Users>list = query.list();
```

```
50  out.print(queryUsers(ormSession,request.getParameter("id")));
```

Result 14 of 48

Critical • Link • New • To Verify • Similarity Id: -1532110222 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/ForgotPassword.jsp	File Name: /src/main/webapp/ForgotPassword.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
42  rs=stmt.executeQuery("select * from users where username='"+request.getParameter("username").trim()+"' and secret
    ='"+request.getParameter("secret")+"'");
```

```
44  out.print("Hello "+rs.getString("username")+", <b class='success'> Your Password is: "+rs.getString("password"));
```

Result 15 of 48

Critical • Link • New • To Verify • Similarity Id: 350721249 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/vulnerability/forum.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
19  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"' and privilege='admin'");
```

```
32  <input type="hidden" name="user" value="<% if(session.getAttribute("user")!=null){out.print(session.getAttribute("use
    r"));} else { out.print("Anonymous"); } %>" size="50"/><br/>
```

Result 16 of 48

Critical • Link • New • To Verify • Similarity Id: 1389169271 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/vulnerability/csrf/change-info.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
19  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"' and privilege='admin'");
```

```
35  out.print("<br/><br/><a href='"+path+"/myprofile.jsp?id="+id+"'>Return to Profile Page &gt;&gt;</a>");
```

Result 17 of 48

Critical • Link • New • To Verify • Similarity Id: -1006807107 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/changeCardDetails.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
19  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"' and privilege='admin'");
```

```
52  out.print("<br/><br/><a href='"+path+"/myprofile.jsp?id="+id+"'>Return to Profile Page &gt;&gt;</a>");
```

Result 18 of 48

Critical • Link • New • To Verify • Similarity Id: -1679941717 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/vulnerability/SendMessage.jsp
Method:	Method:
Element: rs	Element: getAttribute

Code Snippets

```
19  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"' and privilege='admin'");
```

```
21  <tr> <td><input type="hidden" name="sender" value="<%=session.getAttribute("user")%>"/></td></tr>
```

Result 19 of 48

Critical • Link • New • To Verify • Similarity Id: -1438749693 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/vulnerability/forum.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
19 | rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"' and privilege='admin'");
```

```
24 | out.print("Hello "+session.getAttribute("user")+", Welcome to Our Forum !");
```

Result 20 of 48

Critical • Link • New • To Verify • Similarity Id: -84509218 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/index.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
19 | rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"' and privilege='admin'");
```

```
5 | out.print("Hello "+session.getAttribute("user")+",");
```

Result 21 of 48

Critical • Link • New • To Verify • Similarity Id: -1885000000 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/header.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
19 | rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"' and privilege='admin'");
```

```
148 | out.print("<li><a href='"+path+"/myprofile.jsp?id="+session.getAttribute("userid")+"'>My Profile</a></li>");
```

Result 22 of 48

Critical • Link • New • To Verify • Similarity Id: -606907910 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/header.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
19  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"' and privilege='admin'");
```

```
87  <li><a href="<%=path%>/myprofile.jsp?id=<% if(session.getAttribute("userid")!=null){ out.print(session.getAttribute("user
    id"));} %>" title="Make sure you have logged in ">Viewing Details</a>
```

Result 23 of 48

Critical • Link • New • To Verify • Similarity Id: 1123116956 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/vulnerability/DisplayMessage.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
19  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"' and privilege='admin'");
```

```
35  out.print("<br/><br/><a href='"+path+"/myprofile.jsp?id="+session.getAttribute("userid")+"'>Return to Profile Page &gt;&
    gt;</a>");
```

Result 24 of 48

Critical • Link • New • To Verify • Similarity Id: 374594153 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/vulnerability/idor/change-email.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
19  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"' and privilege='admin'");
```

```
36  out.print("<br/><br/><a href='"+path+"/myprofile.jsp?id="+session.getAttribute("userid")+"'>Return to Profile Page &gt;&gt;</a>");
```

Result 25 of 48

Critical • Link • New • To Verify • Similarity Id: -1447626287 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/vulnerability/Messages.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
19  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"' and privilege='admin'");
```

```
24  out.print("<br/><br/><a href='"+path+"/myprofile.jsp?id="+session.getAttribute("userid")+"'>Return to Profile Page &gt;&gt;</a>");
```

Result 26 of 48

Critical • Link • New • To Verify • Similarity Id: 808631661 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/UserDetails.jsp	File Name: /src/main/webapp/vulnerability/UserDetails.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
13  rs=stmt.executeQuery("select * from users where username='"+username+"'");
```

```
16  out.print("<br>About "+rs.getString("username")+": <br>"+rs.getString("about"));
```

Result 27 of 48

Critical • Link • New • To Verify • Similarity Id: 1134999916 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/forum.jsp	File Name: /src/main/webapp/vulnerability/forum.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
60  rs=stmt.executeQuery("select * from posts");
```

```
73  out.print(rs.getString("user"));
```

Result 28 of 48

Critical • Link • New • To Verify • Similarity Id: -1461717483 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/forum.jsp	File Name: /src/main/webapp/vulnerability/forum.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
60  rs=stmt.executeQuery("select * from posts");
```

```
69  out.print("<a href='UserDetails.jsp?username="+rs.getString("user")+"'>"+rs.getString("user")+"</a>");
```

Result 29 of 48

Critical • Link • New • To Verify • Similarity Id: 1716785359 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/vulnerability/idor/change-email.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
19 | rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"' and privilege='admin'");
```

```
19 | <input type="hidden" name="id" value="<% out.print(session.getAttribute("userid"));%>"/>
```

Result 30 of 48

Critical • Link • New • To Verify • Similarity Id: 341688953 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/forum.jsp	File Name: /src/main/webapp/vulnerability/forum.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
60 | rs=stmt.executeQuery("select * from posts");
```

```
65 | out.print("<td><a href='forumposts.jsp?postid="+rs.getString("postid")+"'>"+rs.getString("title")+"</a></td>");
```

Result 31 of 48

Critical • Link • New • To Verify • Similarity Id: -624838137 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/myprofile.jsp	File Name: /src/main/webapp/myprofile.jsp
Method:	Method:
Element: rs1	Element: print

Code Snippets

```
29 | ResultSet rs1=stmt.executeQuery("select * from cards where id="+id);
```

```
34 | out.print("CVV: "+rs1.getString("cvv")+"<br/>");
```

Result 32 of 48

Critical • Link • New • To Verify • Similarity Id: 697527347 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/myprofile.jsp	File Name: /src/main/webapp/myprofile.jsp
Method:	Method:
Element: rs1	Element: print

Code Snippets

```
29  ResultSet rs1=stmt.executeQuery("select * from cards where id="+id);
```

```
33  out.print("Card Number: "+rs1.getString("cardno")+"<br/>");
```

Result 33 of 48

Critical • Link • New • To Verify • Similarity Id: 1518499521 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/myprofile.jsp	File Name: /src/main/webapp/myprofile.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
21  rs=stmt.executeQuery("select * from users where id="+id);
```

```
26  out.print("About : "+rs.getString("about")+"<br>");
```

Result 34 of 48

Critical • Link • New • To Verify • Similarity Id: -1342681345 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/myprofile.jsp	File Name: /src/main/webapp/myprofile.jsp
Method:	Method:
Element: rs1	Element: print

Code Snippets

```
29  ResultSet rs1=stmt.executeQuery("select * from cards where id="+id);
```

```
35  out.print("Expiry Date: "+rs1.getString("expirydate")+"<br/>");
```

Result 35 of 48

Critical • Link • New • To Verify • Similarity Id: 700093701 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/myprofile.jsp	File Name: /src/main/webapp/myprofile.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
21  rs=stmt.executeQuery("select * from users where id="+id);
```

```
25  out.print("Email : "+rs.getString("email")+"<br>");
```

Result 36 of 48

Critical • Link • New • To Verify • Similarity Id: -877056248 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/securitymisconfig/pages.jsp	File Name: /src/main/webapp/vulnerability/securitymisconfig/pages.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
19  rs=stmt.executeQuery("select * from posts where postid="+idNumber);
```

```
24  out.print("<br/><br/>Content:<br/>"+rs.getString("content"));
```

Result 37 of 48

Critical • Link • New • To Verify • Similarity Id: -23631864 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/securitymisconfig/pages.jsp	File Name: /src/main/webapp/vulnerability/securitymisconfig/pages.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
19  rs=stmt.executeQuery("select * from posts where postid="+idNumber);
```

```
23  out.print("<br/>- Posted By "+rs.getString("user"));
```

Result 38 of 48

Critical • Link • New • To Verify • Similarity Id: -33591339 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/securitymisconfig/pages.jsp	File Name: /src/main/webapp/vulnerability/securitymisconfig/pages.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
19  rs=stmt.executeQuery("select * from posts where postid="+idNumber);
```

```
22  out.print("<b style='font-size:22px'>Title:"+rs.getString("title")+"</b>");
```

Result 39 of 48

Critical • Link • New • To Verify • Similarity Id: 851020905 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/myprofile.jsp	File Name: /src/main/webapp/myprofile.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
21  rs=stmt.executeQuery("select * from users where id="+id);
```

```
24  out.print("UserName : "+rs.getString("username")+"<br>");
```

Result 40 of 48

Critical • Link • New • To Verify • Similarity Id: 1333548595 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/Messages.jsp	File Name: /src/main/webapp/vulnerability/Messages.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
14  rs=stmt.executeQuery("select * from UserMessages where recipient='"+session.getAttribute("user")+"'");
```

```
19  out.print("<li><a href='DisplayMessage.jsp?msgid="+rs.getString("msgid")+" '>"+rs.getString("subject")+"</a></li>");
```

Result 41 of 48

Critical • Link • New • To Verify • Similarity Id: -1645058911 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/manageusers.jsp	File Name: /src/main/webapp/admin/manageusers.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
19  ResultSet rs=stmt.executeQuery("select * from users where privilege='user'");
```

```
22  out.print("<input type='radio' name='user' value='"+rs.getString("username")+"'/> "+rs.getString("username")+"<br/>");
```

Result 42 of 48

Critical • Link • New • To Verify • Similarity Id: -271510870 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/DisplayMessage.jsp	File Name: /src/main/webapp/vulnerability/DisplayMessage.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
16 | rs=stmt.executeQuery("select * from UserMessages where msgid="+request.getParameter("msgid"));
```

```
21 | out.print("<br/><b>Message:</b> <br/>"+rs.getString("msg"));
```

Result 43 of 48

Critical • Link • New • To Verify • Similarity Id: -2140926828 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/DisplayMessage.jsp	File Name: /src/main/webapp/vulnerability/DisplayMessage.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
16 | rs=stmt.executeQuery("select * from UserMessages where msgid="+request.getParameter("msgid"));
```

```
20 | out.print("<br/><b>Subject:</b>"+rs.getString("subject"));
```

Result 44 of 48

Critical • Link • New • To Verify • Similarity Id: -379911662 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/DisplayMessage.jsp	File Name: /src/main/webapp/vulnerability/DisplayMessage.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
16 | rs=stmt.executeQuery("select * from UserMessages where msgid="+request.getParameter("msgid"));
```

```
19 | out.print("<b>Sender:</b> "+rs.getString("sender"));
```

Result 45 of 48

Critical • Link • New • To Verify • Similarity Id: 225041451 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/forumposts.jsp	File Name: /src/main/webapp/vulnerability/forumposts.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
14  rs=stmt.executeQuery("select * from posts where postid="+postid);
```

```
19  out.print("<br/><br/>Content:<br/>"+rs.getString("content"));
```

Result 46 of 48

Critical • Link • New • To Verify • Similarity Id: 995389739 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/forumposts.jsp	File Name: /src/main/webapp/vulnerability/forumposts.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
14  rs=stmt.executeQuery("select * from posts where postid="+postid);
```

```
18  out.print("<br/>- Posted By "+rs.getString("user"));
```

Result 47 of 48

Critical • Link • New • To Verify • Similarity Id: -1698828100 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/forumposts.jsp	File Name: /src/main/webapp/vulnerability/forumposts.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
14  rs=stmt.executeQuery("select * from posts where postid="+postid);
```

```
17  out.print("<b style='font-size:22px'>Title:"+rs.getString("title")+"</b>");
```

Result 48 of 48

Critical • Link • New • To Verify • Similarity Id: -287554063 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/forumUsersList.jsp	File Name: /src/main/webapp/vulnerability/forumUsersList.jsp
Method:	Method:
Element: rs	Element: print

Code Snippets

```
12  rs=stmt.executeQuery("select * from users");
```

```
18  out.print("<a href='UserDetails.jsp?username="+rs.getString("username")+"'>"+rs.getString("username")+"</a>");
```

Second_Order_SQL_Injection (Type)

Query Path: Java/Java_Critical_Risk/Second_Order_SQL_Injection

CWE Id: 89

Total results: 8

Description: The application's @DestinationMethod method executes an SQL query with @DestinationElement, at line @DestinationLine of @DestinationFile. The application constructs this SQL query by embedding an untrusted string into the query without proper sanitization. The concatenated string is submitted to the database, where it is parsed and executed accordingly. The attacker may be able to write arbitrary data to the database, which is then retrieved by the application with @SourceElement in @SourceMethod method at line @SourceLine of @SourceFile. This data then flows through the code, until it is used directly in the SQL query without sanitization, and then submitted to the database server for execution. This may enable a Second-Order SQL Injection attack.

Category:

- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-002540 - CAT I The application must not be vulnerable to SQL Injection.
- Base Preset: Base Preset
- CWE top 25: CWE top 25
- FISMA 2014: System And Information Integrity
- MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data
- NIST SP 800-53: SI-10 Information Input Validation (P1)
- OWASP ASVS: V05 Validation, Sanitization and Encoding
- OWASP Mobile Top 10 2024: M4: Insufficient Input/Output Validation
- OWASP Top 10 2013: A1-Injection
- OWASP Top 10 2021: A3-Injection
- OWASP Top 10 API: API8-Injection
- PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.1 - Injection flaws - particularly SQL injection
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development
- SANS top 25: SANS top 25
- Top Tier: Top Tier

Result 1 of 8

Critical • Link • New • To Verify • Similarity Id: -1175804244 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/changeCardDetails.jsp
Method:	Method:
Element: rs	Element: BinaryExpr

Code Snippets

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"'");
```

```
43  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('"+id+"','"+cardno+"','"+cvv+"','"+expirydate
    +"')");
```

Result 2 of 8

Critical • Link • New • To Verify • Similarity Id: -1706551688 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/vulnerability/csrf/change-info.jsp
Method:	Method:
Element: rs	Element: BinaryExpr

Code Snippets

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"'");
```

```
31  stmt.executeUpdate("Update users set about='"+info+"' where id="+id);
```

Result 3 of 8

Critical • Link • New • To Verify • Similarity Id: -1380376776 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/vulnerability/csrf/changepassword.jsp
Method:	Method:
Element: rs	Element: BinaryExpr

Code Snippets

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"'");
```

```
40  stmt.executeUpdate("Update users set password='"+pass+"' where id="+id);
```

Result 4 of 8

Critical • Link • New • To Verify • Similarity Id: -898281520 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/vulnerability/Messages.jsp
Method:	Method:
Element: rs	Element: BinaryExpr

Code Snippets

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"'");
```

```
14  rs=stmt.executeQuery("select * from UserMessages where recipient='"+session.getAttribute("user")+"'");
```

Result 5 of 8

Critical • Link • New • To Verify • Similarity Id: -1729082871 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/changeCardDetails.jsp
Method:	Method:
Element: rs	Element: BinaryExpr

Code Snippets

```
19  rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"' and privilege='admin'");
```

```
43  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('"+id+"','"+cardno+"','"+cvv+"','"+expirydate
    +"')");
```

Result 6 of 8

Critical • Link • New • To Verify • Similarity Id: 1670393813 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/vulnerability/csrf/change-info.jsp
Method:	Method:
Element: rs	Element: BinaryExpr

Code Snippets

```
19 | rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"' and privilege='admin'");
```

```
31 | stmt.executeUpdate("Update users set about='"+info+"' where id="+id);
```

Result 7 of 8

Critical • Link • New • To Verify • Similarity Id: -273423109 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/vulnerability/csrf/changepassword.jsp
Method:	Method:
Element: rs	Element: BinaryExpr

Code Snippets

```
19 | rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"' and privilege='admin'");
```

```
40 | stmt.executeUpdate("Update users set password='"+pass+"' where id="+id);
```

Result 8 of 8

Critical • Link • New • To Verify • Similarity Id: -1581463021 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/vulnerability/Messages.jsp
Method:	Method:
Element: rs	Element: BinaryExpr

Code Snippets

```
19 | rs=stmt.executeQuery("select * from users where username='"+user+"' and password='"+pass+"' and privilege='admin'");
```

```
14 | rs=stmt.executeQuery("select * from UserMessages where recipient='"+session.getAttribute("user")+"'");
```

Unsafe_Reflection (Type)

Query Path: Java/Java_High_Risk/Unsafe_Reflection

CWE Id: 470

Total results: 1

Description: The input obtained by @SourceMethod in @SourceFile at line @SourceLine affects the invocation of a reflection in @DestinationMethod in @DestinationFile at line @DestinationLine. Input is derived from user input, allowing attackers to inject parameters containing potentially devastating values into reflection methods.

Category:

- ASA Premium: ASA Premium
- OWASP Top 10 2021: A3-Injection
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Result 1 of 1

High • Link • New • To Verify • Similarity Id: 45875249 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""jdbcdriver""	Element: jdbcdriver

Code Snippets

```
55  jdbcdriver = request.getParameter("jdbcdriver");
```

```
111  Class.forName(jdbcdriver);
```

SSRF (Type)

Query Path: Java/Java_High_Risk/SSRF

CWE Id: 918

Total results: 3

Description: The application sends a request to a remote server, for some resource, using @DestinationElement in @DestinationFile:@DestinationLine. However, an attacker can control the target of the request, by sending a URL or other data in @SourceElement at @SourceFile:@SourceLine.

Category:

- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-002500 - CAT II The application must protect from Cross-Site and Server-Side Request Forgery (CSRF|SSRF) vulnerabilities.
- CWE top 25: CWE top 25
- FISMA 2014: System And Information Integrity
- MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data
- NIST SP 800-53: SI-10 Information Input Validation (P1)
- OWASP ASVS: V05 Validation, Sanitization and Encoding
- OWASP Top 10 2017: A5-Broken Access Control
- OWASP Top 10 2021: A10-Server-Side Request Forgery
- OWASP Top 10 API 2023: API7-Server Side Request Forgery

Result 1 of 3

High • Link • New • To Verify • Similarity Id: 622978625 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: BinaryExpr

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
121  con= DriverManager.getConnection(dburl+dbname,dbuser,dbpass);
```

Result 2 of 3

High • Link • New • To Verify • Similarity Id: -460512571 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: BinaryExpr

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
121  con= DriverManager.getConnection(dburl+dbname,dbuser,dbpass);
```

Result 3 of 3

High • Link • New • To Verify • Similarity Id: 310245738 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: dburl

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
112  Connection con= DriverManager.getConnection(dburl,dbuser,dbpass);
```

Relative_Path_Traversal (Type)

Query Path: Java/Java_High_Risk/Relative_Path_Traversal

CWE Id: 23

Total results: 8

Description: Method @SourceMethod at line @SourceLine of @SourceFile gets dynamic data from the @SourceElement element. This element's value then flows through the code and is eventually used in a file path for local disk access in @DestinationMethod at line @DestinationLine of @DestinationFile. This may cause a Path Traversal vulnerability.

Category:

- ASA Premium: ASA Premium
- CWE top 25: CWE top 25
- MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data
- OWASP ASVS: V12 Files and Resources
- OWASP Mobile Top 10 2024: M4: Insufficient Input/Output Validation
- OWASP Top 10 2013: A4-Insecure Direct Object References
- OWASP Top 10 2017: A5-Broken Access Control
- OWASP Top 10 2021: A1-Broken Access Control
- PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.8 - Improper access control
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development
- SANS top 25: SANS top 25

Result 1 of 8

High • Link • New • To Verify • Similarity Id: 694938855 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/AddPageVru.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/AddPageVru.java
Method:	Method:
Element: ""filename""	Element: File

Code Snippets

```
40  String fileName=request.getParameter("filename");
```

```
46  File f=new File(filePath);
```

Result 2 of 8

High • Link • New • To Verify • Similarity Id: 1634598487 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/AddPage.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/AddPage.java
Method:	Method:
Element: ""filename""	Element: File

Code Snippets

```
40  String fileName=request.getParameter("filename");
```

```
46  File f=new File(filePath);
```

Result 3 of 8

High • Link • New • To Verify • Similarity Id: -341435167 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/sqli/download_id.jsp	File Name: /src/main/webapp/vulnerability/sqli/download_id.jsp
Method:	Method:
Element: ""fileid""	Element: File

Code Snippets

```
18  String fileid=request.getParameter("fileid");
```

```
37  String fileName = (new File(filePath)).getName();
```

Result 4 of 8

High • Link • New • To Verify • Similarity Id: 374676443 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/ForwardMe.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/ForwardMe.java
Method:	Method:
Element: ""location""	Element: forward

Code Snippets

```
39 | String location=request.getParameter("location");
```

```
42 | dispatcher.forward(request,response);
```

Result 5 of 8

High • Link • New • To Verify • Similarity Id: 10471828 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/sqli/download_id.jsp	File Name: /src/main/webapp/vulnerability/sqli/download_id.jsp
Method:	Method:
Element: ""fileid""	Element: File

Code Snippets

```
18 | String fileid=request.getParameter("fileid");
```

```
32 | file = new File(file.getParent()+filePath);
```

Result 6 of 8

High • Link • New • To Verify • Similarity Id: -2002495084 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/sqli/download_id_union.jsp	File Name: /src/main/webapp/vulnerability/sqli/download_id_union.jsp
Method:	Method:
Element: ""fileid""	Element: File

Code Snippets

```
18  String fileid=request.getParameter("fileid");
```

```
32  file = new File(file.getParent()+filePath);
```

Result 7 of 8

High • Link • New • To Verify • Similarity Id: -879842079 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/sqli/download_id_union.jsp	File Name: /src/main/webapp/vulnerability/sqli/download_id_union.jsp
Method:	Method:
Element: ""fileid""	Element: File

Code Snippets

```
18  String fileid=request.getParameter("fileid");
```

```
37  String fileName = (new File(filePath)).getName();
```

Result 8 of 8

High • Link • New • To Verify • Similarity Id: -1317415280 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026

First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/idor/download.jsp	File Name: /src/main/webapp/vulnerability/idor/download.jsp
Method:	Method:
Element: ""file""	Element: File

Code Snippets

```
11  filePath = request.getParameter("file");
```

```
13  file = new File(file.getParent()+"/docs/"+filePath);
```

Reflected_XSS (Type)

Query Path: Java/Java_High_Risk/Reflected_XSS

CWE Id: 79

Total results: 14

Description: The method @DestinationMethod embeds untrusted data in generated output with @DestinationElement, at line @DestinationLine of @DestinationFile. This untrusted data is embedded into the output without proper sanitization or encoding, enabling an attacker to inject malicious code into the generated web-page. The attacker would be able to alter the returned web page by simply providing modified data in the user input @SourceElement, which is read by the @SourceMethod method at line @SourceLine of @SourceFile. This input then flows through the code straight to the output web page, without sanitization. This can enable a Reflected Cross-Site Scripting (XSS) attack.

Category:

- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-002490 - CAT I The application must protect from Cross-Site Scripting (XSS) vulnerabilities.
- CWE top 25: CWE top 25
- FISMA 2014: System And Information Integrity
- MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data
- NIST SP 800-53: SI-15 Information Output Filtering (P0)
- OWASP ASVS: V05 Validation, Sanitization and Encoding
- OWASP Mobile Top 10 2024: M4: Insufficient Input/Output Validation
- OWASP Top 10 2013: A3-Cross-Site Scripting (XSS)
- OWASP Top 10 2017: A7-Cross-Site Scripting (XSS)
- OWASP Top 10 2021: A3-Injection
- PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.7 - Cross-site scripting (XSS)
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development
- SANS top 25: SANS top 25
- Top Tier: Top Tier

Result 1 of 14

High • Link • New • To Verify • Similarity Id: 1922143541 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/AddPageVru.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/AddPageVru.java
Method:	Method:
Element: ""filename""	Element: print

Code Snippets

```
40  String fileName=request.getParameter("filename");
```

```
56  out.print("Successfully created the file: <a href='../pages/"+fileName+"'>"+fileName+"</a>");
```

Result 2 of 14

High • Link • New • To Verify • Similarity Id: 756882085 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/AddPage.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/AddPage.java
Method:	Method:
Element: ""filename""	Element: print

Code Snippets

```
40  String fileName=request.getParameter("filename");
```

```
56  out.print("Successfully created the file: <a href='../pages/"+fileName+"'>"+fileName+"</a>");
```

Result 3 of 14

High • Link • New • To Verify • Similarity Id: -224797911 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/xxe.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/xxe.java
Method:	Method:
Element: getInputStream	Element: print

Code Snippets

```
44  InputStream xml=request.getInputStream();
```

```
54  out.print(nodes.item(i).getNodeName()+" : " + nodes.item(i).getFirstChild().getNodeValue().toString());
```

Result 4 of 14
High • Link • New • To Verify • Similarity Id: 1548541373 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/login.jsp	File Name: /src/main/webapp/login.jsp
Method:	Method:
Element: getCookies	Element: username

Code Snippets

```
7   Cookie[] cookies = request.getCookies();
```

```
22  <tr><td>UserName: </td><td><input type="text" name="username" value="<%=username%>" /></td></tr>
```

Result 5 of 14
High • Link • New • To Verify • Similarity Id: 1232999601 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/UserDetails.jsp	File Name: /src/main/webapp/vulnerability/UserDetails.jsp
Method:	Method:
Element: ""username""	Element: print

Code Snippets

```
8   String username=request.getParameter("username");
```

```
23  out.print("<a href='SendMessage.jsp?recipient="+username+"'>Send Message to "+username+"</a>");
```

Result 6 of 14
High • Link • New • To Verify • Similarity Id: -87498397 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/login.jsp	File Name: /src/main/webapp/login.jsp
Method:	Method:
Element: getCookies	Element: password

Code Snippets

```
7   Cookie[] cookies = request.getCookies();
```

```
23  <tr><td>Password :</td><td><input type="text" name="password" value="<%=password%>"/></td></tr>
```

Result 7 of 14

High • Link • New • To Verify • Similarity Id: -1032724180 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/xss/search.jsp	File Name: /src/main/webapp/vulnerability/xss/search.jsp
Method:	Method:
Element: ""keyword""	Element: searchedName

Code Snippets

```
16 | String searchedName = request.getParameter("keyword");
```

```
21 | Search Results for <%=searchedName%>
```

Result 8 of 14

High • Link • New • To Verify • Similarity Id: 998979648 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/admin/adminlogin.jsp
Method:	Method:
Element: ""err""	Element: print

Code Snippets

```
58 | <tr><td></td><td class="fail"><% if(request.getParameter("err")!=null){out.print(request.getParameter("err"));} %></td>
   | </tr>
```

Result 9 of 14

High • Link • New • To Verify • Similarity Id: -204518404 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/xss/xss4.jsp	File Name: /src/main/webapp/vulnerability/xss/xss4.jsp
Method:	Method:
Element: ""keyword""	Element: keyword

Code Snippets

```
2 | <% String keyword = request.getParameter("keyword"); %>
```

```
15 | Search Results for <%=keyword%>
```

Result 10 of 14

High • Link • New • To Verify • Similarity Id: 275766522 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/xss/xss4.jsp	File Name: /src/main/webapp/vulnerability/xss/xss4.jsp
Method:	Method:
Element: ""keyword""	Element: print

Code Snippets

```
2  <% String keyword = request.getParameter("keyword"); %>
```

```
6  <input type="text" name="keyword" value=<% if (keyword != null){ out.print(keyword);} %>>
```

Result 11 of 14

High • Link • New • To Verify • Similarity Id: -22735358 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/login.jsp	File Name: /src/main/webapp/login.jsp
Method:	Method:
Element: ""err""	Element: print

Code Snippets

```
26  <tr><td></td><td class="fail"><% if(request.getParameter("err")!=null){out.print(request.getParameter("err"));} %></td>
    </tr>
```

Result 12 of 14

High • Link • New • To Verify • Similarity Id: -192074734 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/SendMessage.jsp	File Name: /src/main/webapp/vulnerability/SendMessage.jsp
Method:	Method:
Element: ""recipient""	Element: print

Code Snippets

```
18  <tr><td>Recipient: </td><td><input type="text" name="recipient" value="<% if(request.getParameter("recipient")!=null){
    out.print(request.getParameter("recipient")); } %>"/></td></tr>
```

Result 13 of 14

High • Link • New • To Verify • Similarity Id: 851014818 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/SendMessage.jsp	File Name: /src/main/webapp/vulnerability/SendMessage.jsp
Method:	Method:
Element: ""status""	Element: print

Code Snippets

```
11  out.print(request.getParameter("status")); //Displaying any error message
```

Result 14 of 14

High • Link • New • To Verify • Similarity Id: -531486526 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/Injection/xpath_login.jsp	File Name: /src/main/webapp/vulnerability/Injection/xpath_login.jsp
Method:	Method:
Element: ""err""	Element: print

Code Snippets

```
9  <tr><td></td><td class="fail"><% if(request.getParameter("err")!=null){out.print(request.getParameter("err"));} %></td></tr>
```

Improper_Restriction_of_XXE_Ref (Type)

Query Path: Java/Java_High_Risk/Improper_Restriction_of_XXE_Ref

CWE Id: 611

Total results: 1

Description: The @DestinationMethod loads and parses XML using @DestinationElement, at line @DestinationLine of @DestinationFile. This XML was received earlier from user input, @SourceElement, at line @SourceLine of @SourceFile. Note that @DestinationElement is set to automatically load and replace any DTD entity references in the XML, including references to external files.

Category:

- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-002550 - CAT I The application must not be vulnerable to XML-oriented attacks.
- Base Preset: Base Preset
- FISMA 2014: System And Information Integrity
- MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data
- NIST SP 800-53: SI-10 Information Input Validation (P1)
- OWASP ASVS: V05 Validation, Sanitization and Encoding
- OWASP Top 10 2017: A4-XML External Entities (XXE)
- OWASP Top 10 2021: A5-Security Misconfiguration
- SANS top 25: SANS top 25

Result 1 of 1

High • Link • New • To Verify • Similarity Id: -1298238722 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/xxe.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/xxe.java
Method:	Method:
Element: getInputStream	Element: parse

Code Snippets

```
44  InputStream xml=request.getInputStream();
```

```
48  Document doc = builder.parse(is);
```

Connection_String_Injection (Type)

Query Path: Java/Java_High_Risk/Connection_String_Injection

CWE Id: 99

Total results: 3

Description: The application's @DestinationMethod method receives untrusted, user-controlled data, and uses this data to connect to a database using @DestinationElement, at line @DestinationLine of @DestinationFile. This may enable a Connection String Injection attack. The attacker can inject the connection string via user input, @SourceElement, which is retrieved by the application in the @SourceMethod method, at line @SourceLine of @SourceFile.

Category:

- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-002560 - CAT I The application must not be subject to input handling vulnerabilities.
- Base Preset: Base Preset
- FISMA 2014: System And Information Integrity
- MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data
- NIST SP 800-53: SI-10 Information Input Validation (P1)
- OWASP ASVS: V01 Architecture, Design and Threat Modeling
- OWASP Mobile Top 10 2024: M4: Insufficient Input/Output Validation
- OWASP Top 10 2013: A1-Injection
- OWASP Top 10 2021: A3-Injection
- PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.1 - Injection flaws - particularly SQL injection
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development
- Top Tier: Top Tier

Result 1 of 3

High • Link • New • To Verify • Similarity Id: 1251470665 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: BinaryExpr

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
121  con= DriverManager.getConnection(dburl+dbname,dbuser,dbpass);
```

Result 2 of 3

High • Link • New • To Verify • Similarity Id: -1960005435 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: BinaryExpr

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
121  con= DriverManager.getConnection(dburl+dbname,dbuser,dbpass);
```

Result 3 of 3

High • Link • New • To Verify • Similarity Id: 2022228974 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: dburl

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
112  Connection con= DriverManager.getConnection(dburl,dbuser,dbpass);
```

Absolute_Path_Traversal (Type)

Query Path: Java/Java_High_Risk/Absolute_Path_Traversal

CWE Id: 36

Total results: 1

Description: No query description available

Category:

- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-002560 - CAT I The application must not be subject to input handling vulnerabilities.
- Base Preset: Base Preset
- CWE top 25: CWE top 25
- MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data
- OWASP ASVS: V12 Files and Resources
- OWASP Mobile Top 10 2024: M4: Insufficient Input/Output Validation
- OWASP Top 10 2017: A5-Broken Access Control
- OWASP Top 10 2021: A1-Broken Access Control, A3-Injection
- PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.8 - Improper access control
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development
- SANS top 25: SANS top 25

Result 1 of 1

High • Link • New • To Verify • Similarity Id: 2070962620 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/idor/download.jsp	File Name: /src/main/webapp/vulnerability/idor/download.jsp
Method:	Method:
Element: ""file""	Element: File

Code Snippets

```
11  filePath = request.getParameter("file");
```

```
18  String fileName = (new File(filePath)).getName();
```

Use_Of_Hardcoded_Password (Type)

Query Path: Java/Java_Medium_Threat/Use_Of_Hardcoded_Password

CWE Id: 259

Total results: 4

Description: The application uses the hard-coded password @SourceElement for authentication purposes, either using it to verify users' identities, or to access another remote system. This password at line @SourceLine of @SourceFile appears in the code, implying it is accessible to anyone with source code access, and cannot be changed without rebuilding the application.

Category:

- ASA Mobile Premium: ASA Mobile Premium
- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-001740 - CAT I The application must only store cryptographic representations of passwords.
- CWE top 25: CWE top 25
- FISMA 2014: Identification And Authentication
- MOIS(KISA) Secure Coding 2021: MOIS(KISA) Security Functions
- NIST SP 800-53: SC-28 Protection of Information at Rest (P1)
- OWASP ASVS: V02 Authentication
- OWASP Mobile Top 10 2016: M9-Reverse Engineering
- OWASP Top 10 2021: A7-Identification and Authentication Failures
- OWASP Top 10 API: API2-Broken Authentication
- PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.10 - Broken authentication and session management
- PCI DSS v4.0: PCI DSS (4.0) - 8.6.2 Vulnerabilities related to passwords/passphrases usage
- SANS top 25: SANS top 25

Result 1 of 4

Medium • Link • New • To Verify • Similarity Id: -266683423 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/rds.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/rds.java
Method:	Method:
Element: password	Element: password

Code Snippets

```
8 | String password = "foobarbaz";
```

Result 2 of 4

Medium • Link • New • To Verify • Similarity Id: -1226851167 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/AddPageVru.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/AddPageVru.java
Method:	Method:
Element: password	Element: password

Code Snippets

```
24  public String password = "Vrushali";
```

Result 3 of 4

Medium • Link • New • To Verify • Similarity Id: 1559809761 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/NewFileVru.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/NewFileVru.java
Method:	Method:
Element: password	Element: password

Code Snippets

```
2  public String password = "Vrushali";
```

Result 4 of 4

Medium • Link • New • To Verify • Similarity Id: 66323903 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/AddPageVru.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/AddPageVru.java
Method:	Method:
Element: password2	Element: password2

Code Snippets

```
25  public String password2 = "Vrushali";
```

XPath_Injection (Type)

Query Path: Java/Java_Medium_Threat/XPath_Injection

CWE Id: 643

Total results: 2

Description: The application's @DestinationMethod method constructs an XPath query, for navigating an XML document. The XPath query is created with @DestinationElement, at line @DestinationLine of @DestinationFile, using an untrusted string embedded in the expression. This may enable an attacker to modify the XPath expression, leading to an XPath Injection attack. The attacker may be able to inject the modified XPath expression via user input, @SourceElement, which is retrieved by the application in the @SourceMethod method, at line @SourceLine of @SourceFile. This value then flows through the code to @DestinationElement, as noted.

Category:

- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-002560 - CAT I The application must not be subject to input handling vulnerabilities.
- FISMA 2014: System And Information Integrity
- MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data
- NIST SP 800-53: SI-10 Information Input Validation (P1)
- OWASP ASVS: V05 Validation, Sanitization and Encoding
- OWASP Mobile Top 10 2024: M4: Insufficient Input/Output Validation
- OWASP Top 10 2013: A1-Injection
- OWASP Top 10 2021: A3-Injection
- OWASP Top 10 API: API8-Injection
- PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.1 - Injection flaws - particularly SQL injection
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development
- Top Tier: Top Tier

Result 1 of 2

Medium • Link • New • To Verify • Similarity Id: -209770971 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/XPathQuery.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/XPathQuery.java
Method:	Method:
Element: ""password""	Element: compile

Code Snippets

```
36  String pass=request.getParameter("password");
```

```
53  String name=xPath.compile(xPression).evaluate(xDoc);
```

Result 2 of 2

Medium • Link • New • To Verify • Similarity Id: -463889532 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/XPathQuery.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/XPathQuery.java
Method:	Method:
Element: ""username""	Element: compile

Code Snippets

```
35  String user=request.getParameter("username");
```

```
53  String name=xPath.compile(xPression).evaluate(xDoc);
```

Use_of_Broken_or_Risky_Cryptographic_Algorithm (Type)

Query Path: Java/Java_Medium_Threat/Use_of_Broken_or_Risky_Cryptographic_Algorithm

CWE Id: 327

Total results: 1

Description: In @SourceMethod, the application protects sensitive data using a cryptographic algorithm, @SourceElement, that is considered weak or even trivially broken, in @SourceFile at line @SourceLine.

Category:

- ASA Mobile Premium: ASA Mobile Premium
- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-002010 - CAT II The application must implement NSA-approved cryptography to protect classified information in accordance with applicable federal laws, Executive Orders, directives, policies, regulations, and standards.
- Base Preset: Base Preset
- FISMA 2014: Configuration Management
- MOIS(KISA) Secure Coding 2021: MOIS(KISA) Security Functions
- NIST SP 800-53: SC-13 Cryptographic Protection (P1)
- OWASP ASVS: V06 Stored Cryptography
- OWASP Top 10 2013: A6-Sensitive Data Exposure
- OWASP Top 10 2017: A3-Sensitive Data Exposure
- OWASP Top 10 2021: A2-Cryptographic Failures
- OWASP Top 10 API: API2-Broken Authentication
- PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.4 - Insecure communications
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Result 1 of 1

Medium • Link • New • To Verify • Similarity Id: -1120810660 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/model/HashMe.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/model/HashMe.java
Method:	Method:
Element: getInstance	Element: getInstance

Code Snippets

```
16 | MessageDigest md = MessageDigest.getInstance("MD5");
```

Unchecked_Input_for_Loop_Condition (Type)

Query Path: Java/Java_Medium_Threat/Unchecked_Input_for_Loop_Condition

CWE Id: 606

Total results: 1

Description: Method @SourceMethod at line @SourceLine of @SourceFile obtains user input from @SourceElement - the range of this value is not validated, and is eventually used in a loop condition in @DestinationMethod at line @DestinationLine of @DestinationFile, allowing attackers to provide a very high number of iterations.

Category:

- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-002560 - CAT I The application must not be subject to input handling vulnerabilities.
- OWASP Top 10 2021: A3-Injection, A4-Insecure Design
- OWASP Top 10 API: API4-Lack of Resources and Rate Limiting
- OWASP Top 10 API 2023: API4-Unrestricted Resource Consumption
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Result 1 of 1

Medium • Link • New • To Verify • Similarity Id: -1254153666 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/xxe.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/xxe.java
Method:	Method:
Element: getInputStream	Element: nodes

Code Snippets

```
44  InputStream xml=request.getInputStream();
```

```
53  for (int i = 0; i < nodes.getLength(); i++) {
```

Parameter_Tampering (Type)

Query Path: Java/Java_Medium_Threat/Parameter_Tampering

CWE Id: 472

Total results: 7

Description: Method @SourceMethod at line @SourceLine of @SourceFile gets user input from element @SourceElement. This input is later concatenated by the application directly into a string variable containing SQL commands, without being validated. This string is then used in method @DestinationMethod to query the database @DestinationElement, at line @DestinationLine of @DestinationFile, without any additional filtering by the database. This could allow the user to tamper with the filter parameter.

Category:

- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-002560 - CAT I The application must not be subject to input handling vulnerabilities.
- MOIS(KISA) Secure Coding 2021: MOIS(KISA) Security Functions
- OWASP ASVS: V01 Architecture, Design and Threat Modeling
- OWASP Top 10 2017: A5-Broken Access Control
- OWASP Top 10 2021: A4-Insecure Design
- OWASP Top 10 API: API1-Broken Object Level Authorization
- PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.1 - Injection flaws - particularly SQL injection
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Result 1 of 7

Medium • Link • New • To Verify • Similarity Id: 546931494 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/EmailCheck.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/EmailCheck.java
Method:	Method:
Element: ""email""	Element: executeQuery

Code Snippets

```
45  String email=request.getParameter("email").trim();
```

```
55  rs=stmt.executeQuery("select * from users where email='"+email+"'");
```

Result 2 of 7

Medium • Link • New • To Verify • Similarity Id: -1119267588 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/UserrnameCheck.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/UserrnameCheck.java
Method:	Method:
Element: ""username""	Element: executeQuery

Code Snippets

```
43  String user=request.getParameter("username").trim();
```

```
52  rs=stmt.executeQuery("select * from users where username='"+user+"'");
```

Result 3 of 7

Medium • Link • New • To Verify • Similarity Id: 791202700 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/Injection/orm.jsp	File Name: /src/main/webapp/vulnerability/Injection/orm.jsp
Method:	Method:
Element: ""id""	Element: list

Code Snippets

```
50  out.print(queryUsers(ormSession,request.getParameter("id")));
```

```
12  List <Users>list = query.list();
```

Result 4 of 7
Medium • Link • New • To Verify • Similarity Id: 267816824 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/idor/change-email.jsp	File Name: /src/main/webapp/vulnerability/idor/change-email.jsp
Method:	Method:
Element: ""id""	Element: executeUpdate

Code Snippets

```
28 | String id=request.getParameter("id");
```

```
32 | stmt.executeUpdate("Update users set email='"+email+"' where id="+id);
```

Result 5 of 7
Medium • Link • New • To Verify • Similarity Id: -149054080 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/manageusers.jsp	File Name: /src/main/webapp/admin/manageusers.jsp
Method:	Method:
Element: ""user""	Element: executeUpdate

Code Snippets

```
13 | String user=request.getParameter("user");
```

```
14 | stmt.executeUpdate("Delete from users where username='"+user+"'");
```

Result 6 of 7
Medium • Link • New • To Verify • Similarity Id: 993703405 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/forumposts.jsp	File Name: /src/main/webapp/vulnerability/forumposts.jsp
Method:	Method:
Element: ""postid""	Element: executeQuery

Code Snippets

```
9 | String postid=request.getParameter("postid");
```

```
14 | rs=stmt.executeQuery("select * from posts where postid="+postid);
```

Result 7 of 7

Medium • Link • New • To Verify • Similarity Id: 585898352 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026

First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/DisplayMessage.jsp	File Name: /src/main/webapp/vulnerability/DisplayMessage.jsp
Method:	Method:
Element: ""msgid""	Element: executeQuery

Code Snippets

```
16 | rs=stmt.executeQuery("select * from UserMessages where msgid="+request.getParameter("msgid"));
```

CSRF (Type)

Query Path: Java/Java_Medium_Threat/CSRF

CWE Id: 352

Total results: 110

Description: Method @SourceMethod at line @SourceLine of @SourceFile gets a parameter from a user request from @SourceElement. This parameter value flows through the code and is eventually used to access application state altering functionality. This may enable Cross-Site Request Forgery (CSRF).

Category:

- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-002500 - CAT II The application must protect from Cross-Site and Server-Side Request Forgery (CSRF|SSRF) vulnerabilities.
- CWE top 25: CWE top 25
- MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data
- NIST SP 800-53: SC-23 Session Authenticity (P1)
- OWASP ASVS: V13 API and Web Service
- OWASP Top 10 2013: A8-Cross-Site Request Forgery (CSRF)
- OWASP Top 10 2021: A1-Broken Access Control
- PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.9 - Cross-site request forgery
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development
- SANS top 25: SANS top 25

Result 1 of 110

Medium • Link • New • To Verify • Similarity Id: -2117789250 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/vulnerability/csrf/changepassword.jsp
Method:	Method:
Element: ""password""	Element: executeUpdate

Code Snippets

```
44  String pass=request.getParameter("password").trim();
```

```
40  stmt.executeUpdate("Update users set password='"+pass+"' where id="+id);
```

Result 2 of 110

Medium • Link • New • To Verify • Similarity Id: 1750174665 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/vulnerability/csrf/change-info.jsp
Method:	Method:
Element: ""username""	Element: executeUpdate

Code Snippets

```
43  String user=request.getParameter("username").trim();
```

```
31  stmt.executeUpdate("Update users set about='"+info+"' where id="+id);
```

Result 3 of 110

Medium • Link • New • To Verify • Similarity Id: 1313351577 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/vulnerability/csrf/changepassword.jsp
Method:	Method:
Element: ""username""	Element: executeUpdate

Code Snippets

```
43  String user=request.getParameter("username").trim();
```

```
40  stmt.executeUpdate("Update users set password='"+pass+"' where id="+id);
```

Result 4 of 110

Medium • Link • New • To Verify • Similarity Id: 1404933367 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/changeCardDetails.jsp
Method:	Method:
Element: ""password""	Element: executeUpdate

Code Snippets

```
44  String pass=request.getParameter("password").trim();
```

```
43  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('"+id+"','"+cardno+"','"+cvv+"','"+expirydate
    +"')");
```

Result 5 of 110

Medium • Link • New • To Verify • Similarity Id: 148701572 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 9fb2e726-512d-44ae-b194-f394f9a03be1

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/webapp/vulnerability/csrf/change-info.jsp
Method:	Method:
Element: ""password""	Element: executeUpdate

Code Snippets

```
44  String pass=request.getParameter("password").trim();
```

```
31  stmt.executeUpdate("Update users set about='"+info+"' where id="+id);
```

Result 6 of 110

Medium • Link • New • To Verify • Similarity Id: 20895113 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""adminpass""	Element: executeUpdate

Code Snippets

```
61  adminpass= HashMe.hashMe(request.getParameter("adminpass"));
```

```
127  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('"+adminuser+"','"+adminpass+"','admin@localhost','I am the admin of this application','default.jpg','admin',1,'rocky')");
```

Result 7 of 110

Medium • Link • New • To Verify • Similarity Id: 816425934 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/vulnerability/csrf/change-info.jsp
Method:	Method:
Element: ""username""	Element: executeUpdate

Code Snippets

```
11  String user=request.getParameter("username");
```

```
31  stmt.executeUpdate("Update users set about='"+info+"' where id="+id);
```

Result 8 of 110

Medium • Link • New • To Verify • Similarity Id: -1754120153 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
160  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('3','5111111111111118','111','1/2017')");
```

Result 9 of 110

Medium • Link • New • To Verify • Similarity Id: -1298210273 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
159  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('2','4111111111111111 ','321','7/2015')");
```

Result 10 of 110

Medium • Link • New • To Verify • Similarity Id: -143067212 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/adminlogin.jsp	File Name: /src/main/webapp/vulnerability/csrf/changepassword.jsp
Method:	Method:
Element: ""username""	Element: executeUpdate

Code Snippets

```
11 | String user=request.getParameter("username");
```

```
40 | stmt.executeUpdate("Update users set password='"+pass+"' where id="+id);
```

Result 11 of 110

Medium • Link • New • To Verify • Similarity Id: -1618378615 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58 | dbname = request.getParameter("dbname");
```

```
165 | stmt.executeUpdate("INSERT into FilesList(path) values ('/docs/exampledoc.pdf')");
```

Result 12 of 110

Medium • Link • New • To Verify • Similarity Id: 280507103 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
164  stmt.executeUpdate("INSERT into FilesList(path) values ('/docs/doc1.pdf')");
```

Result 13 of 110

Medium • Link • New • To Verify • Similarity Id: -1761999384 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
148  stmt.executeUpdate("INSERT into Messages(name,email, msg) values ('TestUser','Test@localhost', 'Hi admin, how are you')");
```

Result 14 of 110

Medium • Link • New • To Verify • Similarity Id: 1697824206 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
144  stmt.executeUpdate("Insert into tdata values(2,'ext2.html')");
```

Result 15 of 110

Medium • Link • New • To Verify • Similarity Id: 123780327 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
143  stmt.executeUpdate("Insert into tdata values(1,'ext1.html')");
```

Result 16 of 110

Medium • Link • New • To Verify • Similarity Id: -1299913828 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
152  stmt.executeUpdate("INSERT into UserMessages(recipient, sender, subject, msg) values ('attacker','admin','Hi','Hi<br/> This is admin of this page. <br/> Welcome to Our Forum')");
```

Result 17 of 110

Medium • Link • New • To Verify • Similarity Id: 399227177 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
153  stmt.executeUpdate("INSERT into UserMessages(recipient, sender, subject, msg) values ('victim','admin','Hi','Hi<br/> This is admin of this page. <br/> Welcome to Our Forum')");
```

Result 18 of 110

Medium • Link • New • To Verify • Similarity Id: -661985302 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
158  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('1','4000123456789010','123','12/2014')");
```

Result 19 of 110

Medium • Link • New • To Verify • Similarity Id: -868418112 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
136  stmt.executeUpdate("INSERT into posts(content,title, user) values ('Feel free to ask any questions about Java Vulnerable Lab','First Post', 'admin')");
```

Result 20 of 110

Medium • Link • New • To Verify • Similarity Id: -1135938696 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
132  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('Anderson','java','anderson@1999','I am computer programmer','default.jpg','user',1,'C++')");
```

Result 21 of 110

Medium • Link • New • To Verify • Similarity Id: -561953710 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
139  stmt.executeUpdate("INSERT into posts(content,title, user) values ('Trinity! Help!','Help','neo')");
```

Result 22 of 110

Medium • Link • New • To Verify • Similarity Id: -377309900 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
138  stmt.executeUpdate("INSERT into posts(content,title, user) values ('Hello This is attacker','Third Post', 'attacker')");
```

Result 23 of 110

Medium • Link • New • To Verify • Similarity Id: -2113433439 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
137  stmt.executeUpdate("INSERT into posts(content,title, user) values ('Hello Guys, this is victim','Second Post', 'victim')");
```

Result 24 of 110

Medium • Link • New • To Verify • Similarity Id: -1266190439 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
131  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('trinity','NEO','trinity@matrix','it is Trinity','default.jpg','user',1,'sentinel')");
```

Result 25 of 110

Medium • Link • New • To Verify • Similarity Id: -69531872 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
130  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('NEO','trinity','neo@matrix','I am the NEO','default.jpg','user',1,'sentinel')");
```

Result 26 of 110

Medium • Link • New • To Verify • Similarity Id: -1259159842 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
129  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('attacker','attacker','attacker@localhost','I am the attacker of this application','default.jpg','user',1,'bella')");
```

Result 27 of 110

Medium • Link • New • To Verify • Similarity Id: 1344730878 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
128  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('victim','victim','victim@localhost','I am the victim of this application','default.jpg','user',1,'max')");
```

Result 28 of 110

Medium • Link • New • To Verify • Similarity Id: -1553972878 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbname""	Element: executeUpdate

Code Snippets

```
58  dbname = request.getParameter("dbname");
```

```
127  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('"+adminuser+"','"+adminpass+"','admin@localhost','I am the admin of this application','default.jpg','admin',1,'rocky')");
```

Result 29 of 110

Medium • Link • New • To Verify • Similarity Id: -120100535 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
165  stmt.executeUpdate("INSERT into FilesList(path) values ('/docs/exampledoc.pdf')");
```

Result 30 of 110

Medium • Link • New • To Verify • Similarity Id: -460486551 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
153  stmt.executeUpdate("INSERT into UserMessages(recipient, sender, subject, msg) values ('victim','admin','Hi','Hi<br/> This is admin of this page. <br/> Welcome to Our Forum')");
```

Result 31 of 110

Medium • Link • New • To Verify • Similarity Id: 1978311199 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
164  stmt.executeUpdate("INSERT into FilesList(path) values ('/docs/doc1.pdf')");
```

Result 32 of 110

Medium • Link • New • To Verify • Similarity Id: 848772967 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
160  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('3','5111111111111118','111','1/2017')");
```

Result 33 of 110

Medium • Link • New • To Verify • Similarity Id: 2082065119 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
159  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('2','4111111111111111 ','321','7/2015')");
```

Result 34 of 110

Medium • Link • New • To Verify • Similarity Id: -1576677206 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
158  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('1','4000123456789010','123','12/2014')");
```

Result 35 of 110

Medium • Link • New • To Verify • Similarity Id: -1087578866 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
144  stmt.executeUpdate("Insert into tdata values(2,'ext2.html')");
```

Result 36 of 110

Medium • Link • New • To Verify • Similarity Id: 164349224 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
148  stmt.executeUpdate("INSERT into Messages(name,email, msg) values ('TestUser','Test@localhost', 'Hi admin, how are you')");
```

Result 37 of 110

Medium • Link • New • To Verify • Similarity Id: 1443881692 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
152  stmt.executeUpdate("INSERT into UserMessages(recipient, sender, subject, msg) values ('attacker','admin','Hi','Hi<br/> This is admin of this page. <br/> Welcome to Our Forum')");
```

Result 38 of 110

Medium • Link • New • To Verify • Similarity Id: 1852157202 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
139  stmt.executeUpdate("INSERT into posts(content,title, user) values ('Trinity! Help!','Help','neo')");
```

Result 39 of 110

Medium • Link • New • To Verify • Similarity Id: 33928615 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
143  stmt.executeUpdate("Insert into tdata values(1,'ext1.html')");
```

Result 40 of 110

Medium • Link • New • To Verify • Similarity Id: 903560692 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
138  stmt.executeUpdate("INSERT into posts(content,title, user) values ('Hello This is attacker','Third Post', 'attacker')");
```

Result 41 of 110

Medium • Link • New • To Verify • Similarity Id: -1283070247 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
131  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('trinity','NEO','trinity@matrix','it is Trinity','default.jpg','user',1,'sentinel')");
```

Result 42 of 110

Medium • Link • New • To Verify • Similarity Id: -187084831 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
137  stmt.executeUpdate("INSERT into posts(content,title, user) values ('Hello Guys, this is victim','Second Post', 'victim')");
```

Result 43 of 110

Medium • Link • New • To Verify • Similarity Id: -1702485320 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
132  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('Anderson','java','anderson@1999','I am computer programmer','default.jpg','user',1,'C++')");
```

Result 44 of 110

Medium • Link • New • To Verify • Similarity Id: 1200469632 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
136  stmt.executeUpdate("INSERT into posts(content,title, user) values ('Feel free to ask any questions about Java Vulnerable Lab','First Post', 'admin')");
```

Result 45 of 110

Medium • Link • New • To Verify • Similarity Id: -1461448736 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
130  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('NEO','trinity','neo@matrix','I am the NEO','default.jpg','user',1,'sentinel')");
```

Result 46 of 110

Medium • Link • New • To Verify • Similarity Id: 464467870 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
129  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('attacker','attacker','attacker@localhost','I am the attacker of this application','default.jpg','user',1,'bella')");
```

Result 47 of 110

Medium • Link • New • To Verify • Similarity Id: 12541886 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
128  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('victim','victim','victim@localhost','I am the victim of this application','default.jpg','user',1,'max')");
```

Result 48 of 110

Medium • Link • New • To Verify • Similarity Id: 525418674 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbpass""	Element: executeUpdate

Code Snippets

```
57  dbpass = request.getParameter("dbpass");
```

```
127  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('"+adminuser+"','"+adminpass+"','admin@localhost','I am the admin of this application','default.jpg','admin',1,'rocky')");
```

Result 49 of 110

Medium • Link • New • To Verify • Similarity Id: -734655777 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
164  stmt.executeUpdate("INSERT into FilesList(path) values ('/docs/doc1.pdf')");
```

Result 50 of 110

Medium • Link • New • To Verify • Similarity Id: 1665706121 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
165  stmt.executeUpdate("INSERT into FilesList(path) values ('/docs/exampledoc.pdf')");
```

Result 51 of 110

Medium • Link • New • To Verify • Similarity Id: -1513220057 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
160  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('3','5111111111111118','111','1/2017')");
```

Result 52 of 110

Medium • Link • New • To Verify • Similarity Id: 1874725407 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
159  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('2','411111111111111 ','321','7/2015')");
```

Result 53 of 110

Medium • Link • New • To Verify • Similarity Id: -1784016918 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
158  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('1','4000123456789010','123','12/2014')");
```

Result 54 of 110

Medium • Link • New • To Verify • Similarity Id: -823104430 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
139  stmt.executeUpdate("INSERT into posts(content,title, user) values ('Trinity! Help!','Help','neo')");
```

Result 55 of 110

Medium • Link • New • To Verify • Similarity Id: -1065512663 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
153  stmt.executeUpdate("INSERT into UserMessages(recipient, sender, subject, msg) values ('victim','admin','Hi','Hi<br/> This is admin of this page. <br/> Welcome to Our Forum')");
```

Result 56 of 110

Medium • Link • New • To Verify • Similarity Id: -165626980 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
152  stmt.executeUpdate("INSERT into UserMessages(recipient, sender, subject, msg) values ('attacker','admin','Hi','Hi<br/> This is admin of this page. <br/> Welcome to Our Forum')");
```

Result 57 of 110

Medium • Link • New • To Verify • Similarity Id: -671228440 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
148  stmt.executeUpdate("INSERT into Messages(name,email, msg) values ('TestUser','Test@localhost', 'Hi admin, how are you')");
```

Result 58 of 110

Medium • Link • New • To Verify • Similarity Id: -78998066 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
144  stmt.executeUpdate("Insert into tdata values(2,'ext2.html')");
```

Result 59 of 110

Medium • Link • New • To Verify • Similarity Id: -487725849 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
143  stmt.executeUpdate("Insert into tdata values(1,'ext1.html')");
```

Result 60 of 110

Medium • Link • New • To Verify • Similarity Id: 852352308 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
138  stmt.executeUpdate("INSERT into posts(content,title, user) values ('Hello This is attacker','Third Post', 'attacker')");
```

Result 61 of 110

Medium • Link • New • To Verify • Similarity Id: -1022662495 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
137  stmt.executeUpdate("INSERT into posts(content,title, user) values ('Hello Guys, this is victim','Second Post', 'victim')");
```

Result 62 of 110

Medium • Link • New • To Verify • Similarity Id: 1603413440 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
136  stmt.executeUpdate("INSERT into posts(content,title, user) values ('Feel free to ask any questions about Java Vulnerable Lab','First Post', 'admin')");
```

Result 63 of 110

Medium • Link • New • To Verify • Similarity Id: 988859256 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
132  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('Anderson','java','anderson@1999','I am computer programmer','default.jpg','user',1,'C++')");
```

Result 64 of 110

Medium • Link • New • To Verify • Similarity Id: 1821781792 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
130  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('NEO','trinity','neo@matrix','I am the NEO','default.jpg','user',1,'sentinel')");
```

Result 65 of 110

Medium • Link • New • To Verify • Similarity Id: -401611042 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
129  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('attacker','attacker','attacker@localhost','I am the attacker of this application','default.jpg','user',1,'bella')");
```

Result 66 of 110

Medium • Link • New • To Verify • Similarity Id: -1031450727 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
131  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('trinity','NEO','trinity@matrix','it is Trinity','default.jpg','user',1,'sentinel')");
```

Result 67 of 110

Medium • Link • New • To Verify • Similarity Id: -433662365 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
164  stmt.executeUpdate("INSERT into FilesList(path) values ('/docs/doc1.pdf')");
```

Result 68 of 110

Medium • Link • New • To Verify • Similarity Id: 638983934 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
128  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('victim','victim','victim@localhost','I am the victim of this application','default.jpg','user',1,'max')");
```

Result 69 of 110

Medium • Link • New • To Verify • Similarity Id: 473700722 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dbuser""	Element: executeUpdate

Code Snippets

```
56  dbuser = request.getParameter("dbuser");
```

```
127  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('"+adminuser+"','"+adminpass+"','admin@localhost','I am the admin of this application','default.jpg','admin',1,'rocky')");
```

Result 70 of 110

Medium • Link • New • To Verify • Similarity Id: 1644732549 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
165  stmt.executeUpdate("INSERT into FilesList(path) values ('/docs/exampledoc.pdf')");
```

Result 71 of 110

Medium • Link • New • To Verify • Similarity Id: -115357011 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
153  stmt.executeUpdate("INSERT into UserMessages(recipient, sender, subject, msg) values ('victim','admin','Hi','Hi<br/> This is admin of this page. <br/> Welcome to Our Forum')");
```

Result 72 of 110

Medium • Link • New • To Verify • Similarity Id: 743317675 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
160  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('3','5111111111111118','111','1/2017')");
```

Result 73 of 110

Medium • Link • New • To Verify • Similarity Id: -1187048933 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
159  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('2','4111111111111111 ','321','7/2015')");
```

Result 74 of 110

Medium • Link • New • To Verify • Similarity Id: -550823962 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
158  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('1','4000123456789010','123','12/2014')");
```

Result 75 of 110

Medium • Link • New • To Verify • Similarity Id: -1894079456 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
152  stmt.executeUpdate("INSERT into UserMessages(recipient, sender, subject, msg) values ('attacker','admin','Hi','Hi<br/> This is admin of this page. <br/> Welcome to Our Forum')");
```

Result 76 of 110

Medium • Link • New • To Verify • Similarity Id: 1967071852 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
148  stmt.executeUpdate("INSERT into Messages(name,email, msg) values ('TestUser','Test@localhost', 'Hi admin, how are you')");
```

Result 77 of 110

Medium • Link • New • To Verify • Similarity Id: -874244014 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
144  stmt.executeUpdate("Insert into tdata values(2,'ext2.html')");
```

Result 78 of 110

Medium • Link • New • To Verify • Similarity Id: -1483210269 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
143  stmt.executeUpdate("Insert into tdata values(1,'ext1.html')");
```

Result 79 of 110

Medium • Link • New • To Verify • Similarity Id: -1139217330 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
139  stmt.executeUpdate("INSERT into posts(content,title, user) values ('Trinity! Help!','Help','neo')");
```

Result 80 of 110

Medium • Link • New • To Verify • Similarity Id: 1146259248 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
138  stmt.executeUpdate("INSERT into posts(content,title, user) values ('Hello This is attacker','Third Post', 'attacker')");
```

Result 81 of 110

Medium • Link • New • To Verify • Similarity Id: -885812484 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
132  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('Anderson','java','anderson@1999','I am computer programmer','default.jpg','user',1,'C++')");
```

Result 82 of 110

Medium • Link • New • To Verify • Similarity Id: -1422271715 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
131  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('trinity','NEO','trinity@matrix','it is Trinity','default.jpg','user',1,'sentinel')");
```

Result 83 of 110

Medium • Link • New • To Verify • Similarity Id: -414088932 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
130  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('NEO','trinity','neo@matrix','I am the NEO','default.jpg','user',1,'sentinel')");
```

Result 84 of 110

Medium • Link • New • To Verify • Similarity Id: 1615637797 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
137  stmt.executeUpdate("INSERT into posts(content,title, user) values ('Hello Guys, this is victim','Second Post', 'victim')");
```

Result 85 of 110

Medium • Link • New • To Verify • Similarity Id: 862858940 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
136  stmt.executeUpdate("INSERT into posts(content,title, user) values ('Feel free to ask any questions about Java Vulnerable Lab','First Post', 'admin')");
```

Result 86 of 110

Medium • Link • New • To Verify • Similarity Id: 145744374 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
127  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('"+adminuser+"','"+adminpass+"','admin@localhost','I am the admin of this application','default.jpg','admin',1,'rocky')");
```

Result 87 of 110

Medium • Link • New • To Verify • Similarity Id: 2084757242 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
128  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('victim','victim','victim@localhost','I am the victim of this application','default.jpg','user',1,'max')");
```

Result 88 of 110

Medium • Link • New • To Verify • Similarity Id: -1447437350 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""dburl""	Element: executeUpdate

Code Snippets

```
54  dburl = request.getParameter("dburl");
```

```
129  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('attacker','attacker','attacker@localhost','I am the attacker of this application','default.jpg','user',1,'bella')");
```

Result 89 of 110

Medium • Link • New • To Verify • Similarity Id: -1440596731 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/SendMessage.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/SendMessage.java
Method:	Method:
Element: ""sender""	Element: executeUpdate

Code Snippets

```
45  String sender=request.getParameter("sender");
```

```
54  pstmt.executeUpdate();
```

Result 90 of 110

Medium • Link • New • To Verify • Similarity Id: -1486656345 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/SendMessage.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/SendMessage.java
Method:	Method:
Element: ""recipient""	Element: executeUpdate

Code Snippets

```
42  String recipient=request.getParameter("recipient");
```

```
54  pstmt.executeUpdate();
```

Result 91 of 110

Medium • Link • New • To Verify • Similarity Id: 1120173205 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/SendMessage.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/SendMessage.java
Method:	Method:
Element: ""subject""	Element: executeUpdate

Code Snippets

```
43  String subject=request.getParameter("subject");
```

```
54  pstmt.executeUpdate();
```

Result 92 of 110

Medium • Link • New • To Verify • Similarity Id: -1306484054 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/csrf/changepassword.jsp	File Name: /src/main/webapp/vulnerability/csrf/changepassword.jsp
Method:	Method:
Element: ""password""	Element: executeUpdate

Code Snippets

```
33  String pass=request.getParameter("password");
```

```
40  stmt.executeUpdate("Update users set password='"+pass+"' where id="+id);
```

Result 93 of 110

Medium • Link • New • To Verify • Similarity Id: 1996273842 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Install.java
Method:	Method:
Element: ""adminuser""	Element: executeUpdate

Code Snippets

```
60  adminuser= request.getParameter("adminuser");
```

```
127  stmt.executeUpdate("INSERT into users(username, password, email,About,avatar, privilege,secretquestion,secret) values ('"+adminuser+"','"+adminpass+"','admin@localhost','I am the admin of this application','default.jpg','admin',1,'rocky')");
```

Result 94 of 110

Medium • Link • New • To Verify • Similarity Id: -1071012619 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/SendMessage.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/SendMessage.java
Method:	Method:
Element: ""msg""	Element: executeUpdate

Code Snippets

```
44  String msg=request.getParameter("msg");
```

```
54  pstmt.executeUpdate();
```

Result 95 of 110

Medium • Link • New • To Verify • Similarity Id: 1605229300 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java
Method:	Method:
Element: ""secret""	Element: executeUpdate

Code Snippets

```
47  String secret=request.getParameter("secret");
```

```
58  stmt.executeUpdate("INSERT into users(username, password, email, About,avatar,privilege,secretquestion,secret) values ('"+user+"','"+pass+"','"+email+"','"+about+"','default.jpg','user',1,'"+secret+"')");
```

Result 96 of 110

Medium • Link • New • To Verify • Similarity Id: -1150923749 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/idor/change-email.jsp	File Name: /src/main/webapp/vulnerability/idor/change-email.jsp
Method:	Method:
Element: ""email""	Element: executeUpdate

Code Snippets

```
27  String email=request.getParameter("email");
```

```
32  stmt.executeUpdate("Update users set email='"+email+"' where id="+id);
```

Result 97 of 110

Medium • Link • New • To Verify • Similarity Id: -64048742 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/changeCardDetails.jsp	File Name: /src/main/webapp/changeCardDetails.jsp
Method:	Method:
Element: ""expirydate""	Element: executeUpdate

Code Snippets

```
39  String expirydate=request.getParameter("expirydate");
```

```
43  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('"+id+"','"+cardno+"','"+cvv+"','"+expirydate
    +"')");
```

Result 98 of 110

Medium • Link • New • To Verify • Similarity Id: -894807782 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/changeCardDetails.jsp	File Name: /src/main/webapp/changeCardDetails.jsp
Method:	Method:
Element: ""cvv""	Element: executeUpdate

Code Snippets

```
38  String cvv=request.getParameter("cvv");
```

```
43  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('"+id+"','"+cardno+"','"+cvv+"','"+expirydate
    +"')");
```

Result 99 of 110

Medium • Link • New • To Verify • Similarity Id: -916009574 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/changeCardDetails.jsp	File Name: /src/main/webapp/changeCardDetails.jsp
Method:	Method:
Element: ""cardno""	Element: executeUpdate

Code Snippets

```
37  String cardno=request.getParameter("cardno");
```

```
43  stmt.executeUpdate("INSERT into cards(id,cardno, cvv,expirydate) values ('"+id+"','"+cardno+"','"+cvv+"','"+expirydate
    +"')");
```

Result 100 of 110

Medium • Link • New • To Verify • Similarity Id: 917976809 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/csrf/change-info.jsp	File Name: /src/main/webapp/vulnerability/csrf/change-info.jsp
Method:	Method:
Element: ""info""	Element: executeUpdate

Code Snippets

```
26  String info=request.getParameter("info");
```

```
31  stmt.executeUpdate("Update users set about='"+info+"' where id="+id);
```

Result 101 of 110

Medium • Link • New • To Verify • Similarity Id: -911407330 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java
Method:	Method:
Element: ""password""	Element: executeUpdate

Code Snippets

```
44  String pass=request.getParameter("password");
```

```
58  stmt.executeUpdate("INSERT into users(username, password, email, About,avatar,privilege,secretquestion,secret) values ('"+user+"','"+pass+"','"+email+"','"+about+"','default.jpg','user',1,'"+secret+"')");
```

Result 102 of 110

Medium • Link • New • To Verify • Similarity Id: -586056646 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java
Method:	Method:
Element: ""email""	Element: executeUpdate

Code Snippets

```
45  String email=request.getParameter("email");
```

```
58  stmt.executeUpdate("INSERT into users(username, password, email, About,avatar,privilege,secretquestion,secret) values ('"+user+"','"+pass+"','"+email+"','"+about+"','default.jpg','user',1,'"+secret+"')");
```

Result 103 of 110

Medium • Link • New • To Verify • Similarity Id: 894411900 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java
Method:	Method:
Element: ""About""	Element: executeUpdate

Code Snippets

```
46  String about=request.getParameter("About");
```

```
58  stmt.executeUpdate("INSERT into users(username, password, email, About,avatar,privilege,secretquestion,secret) values ('"+user+"','"+pass+"','"+email+"','"+about+"','default.jpg','user',1,'"+secret+"')");
```

Result 104 of 110

Medium • Link • New • To Verify • Similarity Id: -1678161690 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java
Method:	Method:
Element: ""username""	Element: executeUpdate

Code Snippets

```
43  String user=request.getParameter("username");
```

```
58  stmt.executeUpdate("INSERT into users(username, password, email, About,avatar,privilege,secretquestion,secret) values ('"+user+"','"+pass+"','"+email+"','"+about+"','default.jpg','user',1,'"+secret+"')");
```

Result 105 of 110

Medium • Link • New • To Verify • Similarity Id: -796931324 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/forum.jsp	File Name: /src/main/webapp/vulnerability/forum.jsp
Method:	Method:
Element: ""title""	Element: executeUpdate

Code Snippets

```
43  String title=request.getParameter("title");
```

```
48  stmt.executeUpdate("INSERT into posts(content,title,user) values ('"+content+"','"+title+"','"+user+"')");
```

Result 106 of 110

Medium • Link • New • To Verify • Similarity Id: -1683053763 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java
Method:	Method:
Element: ""username""	Element: executeUpdate

Code Snippets

```
43  String user=request.getParameter("username");
```

```
59  stmt.executeUpdate("INSERT into UserMessages(recipient, sender, subject, msg) values ('"+user+"','admin','Hi','Hi<br/> This is admin of this page. <br/> Welcome to Our Forum')");
```

Result 107 of 110

Medium • Link • New • To Verify • Similarity Id: 574710340 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/forum.jsp	File Name: /src/main/webapp/vulnerability/forum.jsp
Method:	Method:
Element: ""content""	Element: executeUpdate

Code Snippets

```
42  String content=request.getParameter("content");
```

```
48  stmt.executeUpdate("INSERT into posts(content,title,user) values ('"+content+"','"+title+"','"+user+"')");
```

Result 108 of 110

Medium • Link • New • To Verify • Similarity Id: 747694532 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/forum.jsp	File Name: /src/main/webapp/vulnerability/forum.jsp
Method:	Method:
Element: ""user""	Element: executeUpdate

Code Snippets

```
41  String user=request.getParameter("user");
```

```
48  stmt.executeUpdate("INSERT into posts(content,title,user) values ('"+content+"','"+title+"','"+user+"')");
```

Result 109 of 110

Medium • Link • New • To Verify • Similarity Id: -1706318097 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/manageusers.jsp	File Name: /src/main/webapp/admin/manageusers.jsp
Method:	Method:
Element: ""user""	Element: executeUpdate

Code Snippets

```
13  String user=request.getParameter("user");
```

```
14  stmt.executeUpdate("Delete from users where username='"+user+"'");
```

Result 110 of 110

Medium • Link • New • To Verify • Similarity Id: -1289447193 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/idor/change-email.jsp	File Name: /src/main/webapp/vulnerability/idor/change-email.jsp
Method:	Method:
Element: ""id""	Element: executeUpdate

Code Snippets

```
28  String id=request.getParameter("id");
```

```
32  stmt.executeUpdate("Update users set email='"+email+"' where id="+id);
```

Privacy_Violation (Type)

Query Path: Java/Java_Medium_Threat/Privacy_Violation

CWE Id: 359

Total results: 6

Description: Method @SourceMethod at line @SourceLine of @SourceFile sends user information outside the application. This may constitute a Privacy Violation.

Category:

- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-002330 - CAT II The application must protect the confidentiality and integrity of stored information when required by DoD policy or the information owner.
- Base Preset: Base Preset
- FISMA 2014: Identification And Authentication
- MOIS(KISA) Secure Coding 2021: MOIS(KISA) Security Functions
- NIST SP 800-53: SC-4 Information in Shared Resources (P1)
- OWASP ASVS: V10 Malicious Code
- OWASP Mobile Top 10 2024: M6: Inadequate Privacy Controls
- OWASP Top 10 2013: A6-Sensitive Data Exposure
- OWASP Top 10 2017: A3-Sensitive Data Exposure
- OWASP Top 10 2021: A1-Broken Access Control
- PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.1 - Injection flaws - particularly SQL injection
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development
- SANS top 25: SANS top 25

Result 1 of 6

Medium • Link • New • To Verify • Similarity Id: 342689183 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source

File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/XPathQuery.java

Method:

Element: pass

Destination

File Name: /src/main/webapp/vulnerability/forum.jsp

Method:

Element: print

Code Snippets

```
50  String xPression="/users/user[username='"+user+"' and password='"+pass+"']/name";
```

```
32  <input type="hidden" name="user" value="<% if(session.getAttribute("user")!=null){out.print(session.getAttribute("use
    r"));} else { out.print("Anonymous"); } %>" size="50"/><br/>
```

Result 2 of 6

Medium • Link • New • To Verify • Similarity Id: 308496577 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source

File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/XPathQuery.java

Method:

Element: pass

Destination

File Name: /src/main/webapp/vulnerability/forum.jsp

Method:

Element: print

Code Snippets

```
50 | String xPression="/users/user[username='"+user+"' and password='"+pass+"']/name";
```

```
24 | out.print("Hello "+session.getAttribute("user")+", Welcome to Our Forum !");
```

Result 3 of 6

Medium • Link • New • To Verify • Similarity Id: 629003880 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source

File Name: /src/main/webapp/login.jsp

Method:

Element: password

Destination

File Name: /src/main/webapp/login.jsp

Method:

Element: password

Code Snippets

```
15 | password= c.getValue();
```

```
23 | <tr><td>Password :</td><td><input type="text" name="password" value="<%=password%>"/></td></tr>
```

Result 4 of 6

Medium • Link • New • To Verify • Similarity Id: 624679258 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/XPathQuery.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/XPathQuery.java
Method:	Method:
Element: pass	Element: println

Code Snippets

```
50  String xPression="/users/user[username='"+user+"' and password='"+pass+"']/name";
```

```
54  out.println(name);
```

Result 5 of 6

Medium • Link • New • To Verify • Similarity Id: 294323893 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/XPathQuery.java	File Name: /src/main/webapp/vulnerability/SendMessage.jsp
Method:	Method:
Element: pass	Element: getAttribute

Code Snippets

```
50  String xPression="/users/user[username='"+user+"' and password='"+pass+"']/name";
```

```
21  <tr> <td><input type="hidden" name="sender" value="<%=session.getAttribute("user")%>"/></td></tr>
```

Result 6 of 6

Medium • Link • New • To Verify • Similarity Id: 1901473128 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/XPathQuery.java	File Name: /src/main/webapp/index.jsp
Method:	Method:
Element: pass	Element: print

Code Snippets

```
50 | String xPression="/users/user[username='"+user+"' and password='"+pass+"']/name";
```

```
5 | out.print("Hello "+session.getAttribute("user")+",");
```

Plaintext_Storage_of_a_Password (Type)

Query Path: Java/Java_Medium_Threat/Plaintext_Storage_of_a_Password

CWE Id: 256

Total results: 1

Description: The password @SourceLine did not used a secure scheme to store the password - this may allow attackers to retrieve it, and use it to access authenticated resources.

Category:

- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-001740 - CAT I The application must only store cryptographic representations of passwords.
- FISMA 2014: Identification And Authentication
- NIST SP 800-53: SC-28 Protection of Information at Rest (P1)
- OWASP ASVS: V02 Authentication
- OWASP Mobile Top 10 2024: M1: Improper Credential Usage
- OWASP Top 10 2013: A6-Sensitive Data Exposure
- OWASP Top 10 2017: A3-Sensitive Data Exposure
- OWASP Top 10 2021: A4-Insecure Design
- OWASP Top 10 API: API2-Broken Authentication
- PCI DSS v4.0: PCI DSS (4.0) - 8.6.2 Vulnerabilities related to passwords/passphrases usage

Result 1 of 1

Medium • Link • New • To Verify • Similarity Id: 959897640 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/model/DBConnect.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/model/DBConnect.java
Method:	Method:
Element: properties	Element: dbpass

Code Snippets

```
26  properties.load(new FileInputStream(path));
```

```
35  con= DriverManager.getConnection(dbfullurl,dbuser,dbpass);
```

Open_Redirect (Type)

Query Path: Java/Java_Medium_Threat/Open_Redirect

CWE Id: 601

Total results: 5

Description: The potentially tainted value provided by @SourceElement in @SourceFile at line @SourceLine is used as a destination URL by @DestinationElement in @DestinationFile at line @DestinationLine, potentially allowing attackers to perform an open redirection.

Category:

- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-002560 - CAT I The application must not be subject to input handling vulnerabilities.
- FISMA 2014: System And Information Integrity
- MOIS(KISA) Secure Coding 2021: MOIS(KISA) Verification and representation of input data
- NIST SP 800-53: SI-10 Information Input Validation (P1)
- OWASP ASVS: V05 Validation, Sanitization and Encoding
- OWASP Top 10 2017: A10-Unvalidated Redirects and Forwards
- OWASP Top 10 2021: A1-Broken Access Control
- OWASP Top 10 API 2023: API10-Unsafe Consumption of APIs
- PCI DSS v3.2.1: PCI DSS (3.2.1) - 6.5.8 - Improper access control
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Result 1 of 5

Medium • Link • New • To Verify • Similarity Id: -1220741251 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java
Method:	Method:
Element: ""username""	Element: sendRedirect

Code Snippets

```
43  String user=request.getParameter("username").trim();
```

```
79  response.sendRedirect("login.jsp?err=something went wrong");
```

Result 2 of 5

Medium • Link • New • To Verify • Similarity Id: -1070120520 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java
Method:	Method:
Element: ""password""	Element: sendRedirect

Code Snippets

```
44  String pass=request.getParameter("password").trim();
```

```
79  response.sendRedirect("login.jsp?err=something went wrong");
```

Result 3 of 5

Medium • Link • New • To Verify • Similarity Id: 967638729 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java
Method:	Method:
Element: ""username""	Element: sendRedirect

Code Snippets

```
43  String user=request.getParameter("username").trim();
```

```
68  response.sendRedirect(response.encodeURL("ForwardMe?location=/index.jsp"));
```

Result 4 of 5

Medium • Link • New • To Verify • Similarity Id: 1058759214 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java
Method:	Method:
Element: ""password""	Element: sendRedirect

Code Snippets

```
44  String pass=request.getParameter("password").trim();
```

```
68  response.sendRedirect(response.encodeURL("ForwardMe?location=/index.jsp"));
```

Result 5 of 5

Medium • Link • New • To Verify • Similarity Id: -141160893 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Open.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Open.java
Method:	Method:
Element: ""url""	Element: sendRedirect

Code Snippets

```
36  String url=request.getParameter("url");
```

```
39  response.sendRedirect(url);
```

Missing_HSTS_Header (Type)

Query Path: Java/Java_Medium_Threat/Missing_HSTS_Header

CWE Id: 346

Total results: 1

Description: The web-application does not define an HSTS header, leaving it vulnerable to attack.

Category:

- ASA Premium: ASA Premium
- Base Preset: Base Preset
- OWASP ASVS: V14 Configuration
- OWASP Top 10 2021: A7-Identification and Authentication Failures
- OWASP Top 10 API 2023: API8-Security Misconfiguration
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Result 1 of 1

Medium • Link • New • To Verify • Similarity Id: -10409763 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/admin/AddPage.jsp	File Name: /src/main/webapp/admin/AddPage.jsp
Method:	Method:
Element: jsp_AddPage	Element: jsp_AddPage

Code Snippets

```
1 | <%@ include file="/header.jsp" %>
```

Trust_Boundary_Violation_in_Session_Variables (Type)

Query Path: Java/Java_Low_Visibility/Trust_Boundary_Violation_in_Session_Variables

CWE Id: 501

Total results: 2

Description: Method @SourceMethod at line @SourceLine of @SourceFile gets user input from element @SourceElement. This element's value flows through the code without being properly sanitized or validated and is eventually stored in the server-side Session object, in @DestinationMethod at line @DestinationLine of @DestinationFile. This constitutes a Trust Boundary Violation.

Category:

- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-002360 - CAT II The application must isolate security functions from non-security functions.
- OWASP Top 10 2021: A4-Insecure Design
- PCI DSS v4.0: PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development

Result 1 of 2

Low • Link • New • To Verify • Similarity Id: 1605096282 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/XPathQuery.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/XPathQuery.java
Method:	Method:
Element: ""password""	Element: name

Code Snippets

```
36  String pass=request.getParameter("password");
```

```
63  session.setAttribute("user", name);
```

Result 2 of 2

Low • Link • New • To Verify • Similarity Id: -1746599077 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/XPathQuery.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/XPathQuery.java
Method:	Method:
Element: ""username""	Element: name

Code Snippets

```
35  String user=request.getParameter("username");
```

```
63  session.setAttribute("user", name);
```

Heap_Inspection (Type)

Query Path: Java/Java_Low_Visibility/Heap_Inspection

CWE Id: 244

Total results: 8

Description: Method @SourceMethod at line @SourceLine of @SourceFile defines @SourceElement, which is designated to contain user passwords. However, while plaintext passwords are later assigned to @SourceElement, this variable is never cleared from memory.

Category:

- ASA Premium: ASA Premium
- ASD STIG 6.1: APSC-DV-002330 - CAT II The application must protect the confidentiality and integrity of stored information when required by DoD policy or the information owner.
- OWASP ASVS: V08 Data Protection
- OWASP Top 10 2013: A6-Sensitive Data Exposure
- OWASP Top 10 2021: A2-Cryptographic Failures

Result 1 of 8

Low • Link • New • To Verify • Similarity Id: -435280958 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/rds.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/rds.java
Method:	Method:
Element: password	Element: password

Code Snippets

```
8   String password = "foobarbaz";
```

Result 2 of 8

Low • Link • New • To Verify • Similarity Id: 1996111558 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java
Method:	Method:
Element: password	Element: password

Code Snippets

```
64   Cookie password=new Cookie("password",pass);
```

Result 3 of 8

Low • Link • New • To Verify • Similarity Id: -1640357384 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/csrf/changepassword.jsp	File Name: /src/main/webapp/vulnerability/csrf/changepassword.jsp
Method:	Method:
Element: pass	Element: pass

Code Snippets

```
33 | String pass=request.getParameter("password");
```

Result 4 of 8

Low • Link • New • To Verify • Similarity Id: -1137887934 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/Register.java
Method:	Method:
Element: pass	Element: pass

Code Snippets

```
44 | String pass=request.getParameter("password");
```

Result 5 of 8

Low • Link • New • To Verify • Similarity Id: 1683128866 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/webapp/vulnerability/Injection/orm.jsp	File Name: /src/main/webapp/vulnerability/Injection/orm.jsp
Method:	Method:
Element: dbpass	Element: dbpass

Code Snippets

```
31 | String dbpass = properties.getProperty("dbpass");
```

Result 6 of 8

Low • Link • New • To Verify • Similarity Id: 438351106 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/LoginValidator.java
Method:	Method:
Element: pass	Element: pass

Code Snippets

```
44  String pass=request.getParameter("password").trim();
```

Result 7 of 8

Low • Link • New • To Verify • Similarity Id: 1252836846 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/XPathQuery.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/controller/XPathQuery.java
Method:	Method:
Element: pass	Element: pass

Code Snippets

```
36  String pass=request.getParameter("password");
```

Result 8 of 8

Low • Link • New • To Verify • Similarity Id: 157522674 • Found First: 01 Apr, 2026 • Found Last: 01 Apr, 2026
First Scan ID: 66798420-8c09-4e9e-a766-9bf4aff317a3

Source	Destination
File Name: /src/main/java/org/cysecurity/cspf/jvl/model/DBConnect.java	File Name: /src/main/java/org/cysecurity/cspf/jvl/model/DBConnect.java
Method:	Method:
Element: dbpass	Element: dbpass

Code Snippets

```
28  String dbpass = properties.getProperty("dbpass");
```

IaC Security Vulnerabilities

By Severity

6	6	23	22	11	68

IaC Security Scan Results (68)

CICD (2 Results)

Query Name: nr-cusotm

Total Results: 1

Description: custom query

Category: Resource Management

Result 1 of 1
Critical • Link • New • To Verify • Found First: 12 Feb, 2026
Found Last: 01 Apr, 2026 • Scan ID: 375a7c2c-cd48-4b3c-9540-bb4d07b5428e

> File: /.github/workflows/cx.yml
> Expected Value: Action pinned to a full length commit SHA.
> Actual Value: Action is not pinned to a full length commit SHA.
> Issue Type: IncorrectValue

Query Name: Unpinned Actions Full Length Commit SHA

Total Results: 1

Description: Pinning an action to a full length commit SHA is currently the only way to use an action as an immutable release. Pinning to a particular SHA helps mitigate the risk of a bad actor adding a backdoor to the action's repository, as they would need to generate a SHA-1 collision for a valid Git object payload. When selecting a SHA, you should verify it is from the action's repository and not a repository fork.

Category: Supply-Chain

Result 1 of 1
Low • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /.github/workflows/cx.yml
> Expected Value: Action pinned to a full length commit SHA.
> Actual Value: Action is not pinned to a full length commit SHA.
> Issue Type: IncorrectValue

Terraform (60 Results)

Query Name: S3 Bucket With All Permissions

Total Results: 1

Description: S3 Buckets should not have all permissions, as to prevent leaking private information to the entire internet or allow unauthorized data tampering / deletion. This means the 'Effect' must not be 'Allow' when the 'Action' is '*', for all Principals.

Category: Access Control

Result 1 of 1
Critical • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /s3_with_all_permissions.tf
> Expected Value: 'policy.Statement' should not allow all actions to all principal
> Actual Value: 'policy.Statement' allows all actions to all principal
> Issue Type: IncorrectValue

Query Name: S3 Bucket Allows Delete Action From All Principals

Total Results: 1

Description: S3 Buckets must not allow Delete Action From All Principals, as to prevent leaking private information to the entire internet or allow unauthorized data tampering / deletion. This means the 'Effect' must not be 'Allow' when the 'Action' is Delete, for all Principals.

Category: Access Control

Result 1 of 1
Critical • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /s3_with_all_permissions.tf
> Expected Value: aws_s3_bucket[s3Bucket].policy.Action should not be a 'Delete' action
> Actual Value: aws_s3_bucket[s3Bucket].policy.Action is a 'Delete' action
> Issue Type: IncorrectValue

Query Name: S3 Bucket Access to Any Principal

Total Results: 1

Description: S3 Buckets must not allow Actions From All Principals, as to prevent leaking private information to the entire internet or allow unauthorized data tampering / deletion. This means the 'Effect' must not be 'Allow' when there are All Principals

Category: Access Control

Result 1 of 1
Critical • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /s3_with_all_permissions.tf
> Expected Value: aws_s3_bucket[s3Bucket].policy.Principal should not equal to, nor contain '*'
> Actual Value: aws_s3_bucket[s3Bucket].policy.Principal is equal to or contains '*'
> Issue Type: IncorrectValue

Query Name: S3 Bucket ACL Allows Read Or Write to All Users

Total Results: 2

Description: S3 Buckets should not be readable and writable to all users

Category: Access Control

Result 1 of 2
Critical • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /Unsecure_Storage_of_Encryption_Key.tf
> Expected Value: 'acl' should equal to 'private'
> Actual Value: 'acl' is equal 'public-read'
> Issue Type: IncorrectValue

Result 2 of 2
Critical • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /s3.tf
> Expected Value: 'acl' should equal to 'private'
> Actual Value: 'acl' is equal 'public-read'
> Issue Type: IncorrectValue

Query Name: SQS Policy Allows All Actions

Total Results: 2

Description: SQS policy allows ALL (*) actions

Category: Access Control

Result 1 of 2
High • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /sqs.tf
> Expected Value: 'policy.Statement.Action' should not equal '*'
> Actual Value: 'policy.Statement.Action' is equal '*'
> Issue Type: IncorrectValue

Result 2 of 2
High • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /Unsecure_Sensitive_data.tf
> Expected Value: 'policy.Statement.Action' should not equal '*'
> Actual Value: 'policy.Statement.Action' is equal '*'
> Issue Type: IncorrectValue

Query Name: Hardcoded AWS Access Key

Total Results: 1

Description: AWS Access Key should not be hardcoded

Category: Secret Management

Result 1 of 1
High • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /infrostructure.tf
> Expected Value: 'user_data' shouldn't contain hardcoded access key
> Actual Value: 'user_data' contains hardcoded access key
> Issue Type: IncorrectValue

Query Name: DB Instance Storage Not Encrypted

Total Results: 1

Description: AWS DB Instance should have its storage encrypted by setting the parameter to 'true'. The storage_encrypted default value is 'false'.

Category: Encryption

Result 1 of 1
High • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /rds.tf
> Expected Value: 'storage_encrypted' should be set to true
> Actual Value: 'storage_encrypted' is undefined or null
> Issue Type: MissingAttribute

Query Name: SQS With SSE Disabled

Total Results: 2

Description: Amazon Simple Queue Service (SQS) queue should protect the contents of their messages using Server-Side Encryption (SSE)

Category: Encryption

Result 1 of 2
Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /Unsecure_Sensitive_data.tf
> Expected Value: aws_sqs_queue[q].kms_master_key_id or aws_sqs_queue[q].sqs_managed_sse_enabled should be defined and not null
> Actual Value: aws_sqs_queue[q].kms_master_key_id and aws_sqs_queue[q].sqs_managed_sse_enabled are undefined or null
> Issue Type: MissingAttribute

Result 2 of 2
Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /sqs.tf
> Expected Value: aws_sqs_queue[q].kms_master_key_id or aws_sqs_queue[q].sqs_managed_sse_enabled should be defined and not null
> Actual Value: aws_sqs_queue[q].kms_master_key_id and aws_sqs_queue[q].sqs_managed_sse_enabled are undefined or null
> Issue Type: MissingAttribute

Query Name: SQS Policy With Public Access

Total Results: 2

Description: Checks for dangerous permissions in Action statements in an SQS Queue Policy. This is deemed a potential security risk as it would allow various attacks to the queue

Category: Access Control

Result 1 of 2
Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /sqs.tf
> Expected Value: 'policy.Statement.Principal.AWS' should not equal '*'
> Actual Value: 'policy.Statement.Principal.AWS' is equal '*'
> Issue Type: IncorrectValue

Result 2 of 2
Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /Unsecure_Sensitive_data.tf
> Expected Value: 'policy.Statement.Principal.AWS' should not equal '*'
> Actual Value: 'policy.Statement.Principal.AWS' is equal '*'
> Issue Type: IncorrectValue

Query Name: S3 Bucket Without Versioning

Total Results: 3

Description: S3 bucket should have versioning enabled

Category: Backup

Result 1 of 3
Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /s3_with_all_permissions.tf
> Expected Value: 'versioning' should be true
> Actual Value: 'versioning' is undefined or null
> Issue Type: MissingAttribute

Result 2 of 3
Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /Unsecure_Storage_of_Encryption_Key.tf
> Expected Value: 'versioning' should be true
> Actual Value: 'versioning' is undefined or null
> Issue Type: MissingAttribute

Result 3 of 3
Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /s3.tf
> Expected Value: 'versioning' should be true
> Actual Value: 'versioning' is undefined or null
> Issue Type: MissingAttribute

Query Name: S3 Bucket Policy Accepts HTTP Requests

Total Results: 1

Description: S3 Bucket policy should not accept HTTP Requests

Category: Encryption

Result 1 of 1
Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /s3_with_all_permissions.tf
> Expected Value: aws_s3_bucket[s3Bucket].policy should not accept HTTP Requests
> Actual Value: aws_s3_bucket[s3Bucket].policy accepts HTTP Requests
> Issue Type: IncorrectValue

Query Name: S3 Bucket Logging Disabled

Total Results: 3

Description: Server Access Logging should be enabled on S3 Buckets so that all changes are logged and trackable

Category: Observability

Result 1 of 3

Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /Unsecure_Storage_of_Encryption_Key.tf
> Expected Value: 'logging' should be defined and not null
> Actual Value: 'logging' is undefined or null
> Issue Type: MissingAttribute

Result 2 of 3

Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /s3_with_all_permissions.tf
> Expected Value: 'logging' should be defined and not null
> Actual Value: 'logging' is undefined or null
> Issue Type: MissingAttribute

Result 3 of 3

Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /s3.tf
> Expected Value: 'logging' should be defined and not null
> Actual Value: 'logging' is undefined or null
> Issue Type: MissingAttribute

Query Name: RDS Without Logging

Total Results: 1

Description: RDS does not have any kind of logger

Category: Observability

Result 1 of 1

Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /rds.tf
> Expected Value: 'enabled_cloudwatch_logs_exports' should be defined
> Actual Value: 'enabled_cloudwatch_logs_exports' is undefined
> Issue Type: MissingAttribute

Query Name: RDS With Backup Disabled

Total Results: 1

Description: Make sure the AWS RDS configuration has automatic backup configured. If the retention period is equal to 0 there is no backup

Category: Backup

Result 1 of 1
Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /rds.tf
> Expected Value: 'backup_retention_period' should be defined, and bigger than '0'
> Actual Value: 'backup_retention_period' is not defined
> Issue Type: MissingAttribute

Query Name: Public Lambda via API Gateway

Total Results: 1

Description: Allowing to run lambda function using public API Gateway

Category: Access Control

Result 1 of 1
Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /lambda.tf
> Expected Value: 'source_arn' should not equal '/*/*'
> Actual Value: 'source_arn' is equal '/*/*'
> Issue Type: IncorrectValue

Query Name: IAM Database Auth Not Enabled

Total Results: 1

Description: IAM Database Auth Enabled should be configured to true when using compatible engine and version

Category: Encryption

Result 1 of 1
Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /rds.tf
> Expected Value: 'iam_database_authentication_enabled' should be set to true
> Actual Value: 'iam_database_authentication_enabled' is undefined or null
> Issue Type: MissingAttribute

Query Name: ELBv2 LB Access Log Disabled

Total Results: 1

Description: ELBv2 LBs should have access log enabled to capture detailed information about requests sent to your load balancer.

Category: Observability

Result 1 of 1
Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /infrostructure.tf
> Expected Value: 'access_logs.enabled' should be defined and set to true
> Actual Value: 'access_logs' is undefined
> Issue Type: MissingAttribute

Query Name: EC2 Instance Monitoring Disabled

Total Results: 1

Description: EC2 Instance should have detailed monitoring enabled. With detailed monitoring enabled data is available in 1-minute periods

Category: Observability

Result 1 of 1

Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /infrostructure.tf
> Expected Value: 'monitoring' should be defined and not null
> Actual Value: 'monitoring' is undefined or null
> Issue Type: MissingAttribute

Query Name: EC2 Instance Has Public IP

Total Results: 1

Description: EC2 Instance should not have a public IP address.

Category: Networking and Firewall

Result 1 of 1

Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /infrostructure.tf
> Expected Value: 'associate_public_ip_address' should be defined and not null
> Actual Value: 'associate_public_ip_address' is undefined or null
> Issue Type: MissingAttribute

Query Name: ALB Not Dropping Invalid Headers

Total Results: 1

Description: It's considered a best practice when using Application Load Balancers to drop invalid header fields

Category: Best Practices

Result 1 of 1

Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /infrostructure.tf
> Expected Value: aws_lb[{{front_end}}].drop_invalid_header_fields should be set to true
> Actual Value: aws_lb[{{front_end}}].drop_invalid_header_fields is missing
> Issue Type: MissingAttribute

Query Name: ALB Listening on HTTP

Total Results: 1

Description: AWS Application Load Balancer (alb) should not listen on HTTP

Category: Networking and Firewall

Result 1 of 1

Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /infrostructure.tf
> Expected Value: 'default_action.redirect.protocol' should be equal to 'HTTPS'
> Actual Value: 'default_action.redirect.protocol' is equal 'HTTP'
> Issue Type: IncorrectValue

Query Name: ALB Is Not Integrated With WAF

Total Results: 1

Description: All Application Load Balancers (ALB) must be protected with Web Application Firewall (WAF) service

Category: Networking and Firewall

Result 1 of 1
Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /infrostructure.tf
> Expected Value: 'aws_lb[front_end]' should not be 'internal' and has a 'aws_wafregional_web_acl_association' associated
> Actual Value: 'aws_lb[front_end]' is not 'internal' and does not have a 'aws_wafregional_web_acl_association' associated
> Issue Type: MissingAttribute

Query Name: ALB Deletion Protection Disabled

Total Results: 1

Description: Application Load Balancer should have deletion protection enabled

Category: Insecure Configurations

Result 1 of 1
Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /infrostructure.tf
> Expected Value: 'enable_deletion_protection' should be defined and set to true
> Actual Value: 'enable_deletion_protection' is undefined or null
> Issue Type: MissingAttribute

Query Name: Tags Not Copied to RDS Cluster Snapshot

Total Results: 1

Description: Tags of the RDS Cluster should be copied to the respective snapshots to ensure that snapshots retain important metadata for identification, cost allocation, and resource management

Category: Backup

Result 1 of 1
Low • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /rds.tf
> Expected Value: 'aws_db_instance[default].copy_tags_to_snapshot' should be defined to true
> Actual Value: 'aws_db_instance[default].copy_tags_to_snapshot' is not defined
> Issue Type: MissingAttribute

Query Name: Shield Advanced Not In Use

Total Results: 2

Description: AWS Shield Advanced should be used for Amazon Route 53 hosted zone, AWS Global Accelerator accelerator, Elastic IP Address, Elastic Load Balancing, and Amazon CloudFront Distribution to protect these resources against robust DDoS attacks

Category: Networking and Firewall

Result 1 of 2
Low • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /infrostructure.tf
> Expected Value: aws_lb has shield advanced associated
> Actual Value: aws_lb does not have shield advanced associated
> Issue Type: MissingAttribute

Result 2 of 2
Low • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /infrostructure.tf
> Expected Value: aws_eip has shield advanced associated
> Actual Value: aws_eip does not have shield advanced associated
> Issue Type: MissingAttribute

Query Name: S3 bucket notifications disabled

Total Results: 3

Description: S3 bucket notifications provide alerts triggered when certain operations are performed, which might be a helpful indicator for detecting unintended operations that might compromise your infrastructure or even malicious activity.

Category: Observability

Result 1 of 3
Low • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /Unsecure_Sensitive_data.tf
> Expected Value: 'aws_s3_bucket_notification' should be defined and not null
> Actual Value: 'aws_s3_bucket_notification' is undefined or null
> Issue Type: MissingAttribute

Result 2 of 3
Low • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /sqs.tf
> Expected Value: 'aws_s3_bucket_notification' should be defined and not null
> Actual Value: 'aws_s3_bucket_notification' is undefined or null
> Issue Type: MissingAttribute

Result 3 of 3
Low • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /lambda.tf
> Expected Value: 'aws_s3_bucket_notification' should be defined and not null
> Actual Value: 'aws_s3_bucket_notification' is undefined or null
> Issue Type: MissingAttribute

Query Name: Lambda Functions Without X-Ray Tracing

Total Results: 1

Description: AWS Lambda functions should have TracingConfig enabled. For this, property 'tracing_Config.mode' should have the value 'Active'

Category: Observability

Result 1 of 1
Low • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /lambda.tf
> Expected Value: aws_lambda_function[example].tracing_config should be defined and not null
> Actual Value: aws_lambda_function[example].tracing_config is undefined or null
> Issue Type: MissingAttribute

Query Name: Lambda Function Without Dead Letter Queue

Total Results: 1

Description: AWS Lambda Function should be configured for a Dead Letter Queue(DLQ)

Category: Insecure Configurations

Result 1 of 1
Low • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /lambda.tf
> Expected Value: 'aws_lambda_function[example].dead_letter_config' should be defined and not null
> Actual Value: 'aws_lambda_function[example].dead_letter_config' is undefined or null
> Issue Type: MissingAttribute

Query Name: Instance Uses Metadata Service IMDSv1

Total Results: 1

Description: Instance metadata can be accessed with both IMDSv1 or IMDSv2. Although, IMDSv2 service is a session-oriented service, granting additional protection against exposure of metadata information. That version should be used instead of IMDSv1 in order to mitigate those situations.

Category: Insecure Configurations

Result 1 of 1
Low • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /infrostructure.tf
> Expected Value: 'aws_instance[http].metadata_options' should be defined with 'http_tokens' field set to 'required'
> Actual Value: 'aws_instance[http].metadata_options' is not defined
> Issue Type: MissingAttribute

Query Name: IAM Access Analyzer Not Enabled

Total Results: 8

Description: IAM Access Analyzer should be enabled and configured to continuously monitor resource permissions

Category: Best Practices

Result 1 of 8
Low • Link • New • To Verify • Found First: 14 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: aa69c31e-ee5d-4295-9ecc-a61a1b2e987d

> File: /sqs.tf
> Expected Value: 'aws_accessanalyzer_analyzer' should be set
> Actual Value: 'aws_accessanalyzer_analyzer' is undefined
> Issue Type: MissingAttribute

Result 2 of 8

Low • Link • New • To Verify • Found First: 14 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: aa69c31e-ee5d-4295-9ecc-a61a1b2e987d

> File: /lambda.tf
> Expected Value: 'aws_accessanalyzer_analyzer' should be set
> Actual Value: 'aws_accessanalyzer_analyzer' is undefined
> Issue Type: MissingAttribute

Result 3 of 8

Low • Link • New • To Verify • Found First: 14 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: aa69c31e-ee5d-4295-9ecc-a61a1b2e987d

> File: /Unsecure_Sensitive_data.tf
> Expected Value: 'aws_accessanalyzer_analyzer' should be set
> Actual Value: 'aws_accessanalyzer_analyzer' is undefined
> Issue Type: MissingAttribute

Result 4 of 8

Low • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /rds.tf
> Expected Value: 'aws_accessanalyzer_analyzer' should be set
> Actual Value: 'aws_accessanalyzer_analyzer' is undefined
> Issue Type: MissingAttribute

Result 5 of 8

Low • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /Unsecure_Storage_of_Encryption_Key.tf
> Expected Value: 'aws_accessanalyzer_analyzer' should be set
> Actual Value: 'aws_accessanalyzer_analyzer' is undefined
> Issue Type: MissingAttribute

Result 6 of 8

Low • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /s3_with_all_permissions.tf
> Expected Value: 'aws_accessanalyzer_analyzer' should be set
> Actual Value: 'aws_accessanalyzer_analyzer' is undefined
> Issue Type: MissingAttribute

Result 7 of 8

Low • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /s3.tf
> Expected Value: 'aws_accessanalyzer_analyzer' should be set
> Actual Value: 'aws_accessanalyzer_analyzer' is undefined
> Issue Type: MissingAttribute

Result 8 of 8
Low • Link • New • To Verify • Found First: 14 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: aa69c31e-ee5d-4295-9ecc-a61a1b2e987d

> File: /infrostructure.tf
> Expected Value: 'aws_accessanalyzer_analyzer' should be set
> Actual Value: 'aws_accessanalyzer_analyzer' is undefined
> Issue Type: MissingAttribute

Query Name: AWS EIP not attached to any instance

Total Results: 1

Description: Unattached EIPs from EC2 instances should be disabled to allow us to maintain better control, efficiency, and visibility over the network traffic and implement security measures more effectively

Category: Resource Management

Result 1 of 1
Low • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /infrostructure.tf
> Expected Value: All EIPs should be attached
> Actual Value: EIP is not attached
> Issue Type: MissingAttribute

Query Name: Resource Not Using Tags

Total Results: 9

Description: AWS services resource tags are an essential part of managing components. As a best practice, the field 'tags' should have additional tags defined other than 'Name'

Category: Best Practices

Result 1 of 9
Information • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /s3_with_all_permissions.tf
> Expected Value: aws_s3_bucket[{{s3Bucket}}].tags should be defined and not null
> Actual Value: aws_s3_bucket[{{s3Bucket}}].tags is undefined or null
> Issue Type: MissingAttribute

Result 2 of 9
Information • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /rds.tf
> Expected Value: aws_db_instance[{{default}}].tags should be defined and not null
> Actual Value: aws_db_instance[{{default}}].tags is undefined or null
> Issue Type: MissingAttribute

Result 3 of 9
Information • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /Unsecure_Sensitive_data.tf
> Expected Value: aws_sqs_queue[{{q}}].tags should be defined and not null
> Actual Value: aws_sqs_queue[{{q}}].tags is undefined or null
> Issue Type: MissingAttribute

Result 4 of 9

Information • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /lambda.tf
> Expected Value: aws_lambda_function[{{example}}].tags should be defined and not null
> Actual Value: aws_lambda_function[{{example}}].tags is undefined or null
> Issue Type: MissingAttribute

Result 5 of 9

Information • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /sqs.tf
> Expected Value: aws_sqs_queue[{{q}}].tags should be defined and not null
> Actual Value: aws_sqs_queue[{{q}}].tags is undefined or null
> Issue Type: MissingAttribute

Result 6 of 9

Information • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /infrostructure.tf
> Expected Value: aws_eip[{{public_http}}].tags has additional tags defined other than 'Name'
> Actual Value: aws_eip[{{public_http}}].tags does not have additional tags defined other than 'Name'
> Issue Type: MissingAttribute

Result 7 of 9

Information • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /infrostructure.tf
> Expected Value: aws_lb_target_group[{{front_end}}].tags should be defined and not null
> Actual Value: aws_lb_target_group[{{front_end}}].tags is undefined or null
> Issue Type: MissingAttribute

Result 8 of 9

Information • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /infrostructure.tf
> Expected Value: aws_lb[{{front_end}}].tags should be defined and not null
> Actual Value: aws_lb[{{front_end}}].tags is undefined or null
> Issue Type: MissingAttribute

Result 9 of 9

Information • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /infrostructure.tf
> Expected Value: aws_instance[{{http}}].tags has additional tags defined other than 'Name'
> Actual Value: aws_instance[{{http}}].tags does not have additional tags defined other than 'Name'
> Issue Type: MissingAttribute

Query Name: Name Is Not Snake Case

Total Results: 1

Description: All names should follow snake case pattern.

Category: Best Practices

Result 1 of 1
Information • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /s3_with_all_permissions.tf
> Expected Value: All names should be on snake case pattern
> Actual Value: 's3Bucket' is not in snake case
> Issue Type: IncorrectValue

Query Name: EC2 Not EBS Optimized

Total Results: 1

Description: It's considered a best practice for an EC2 instance to use an EBS optimized instance. This provides the best performance for your EBS volumes by minimizing contention between Amazon EBS I/O and other traffic from your instance

Category: Best Practices

Result 1 of 1
Information • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /infrostructure.tf
> Expected Value: 'ebs_optimized' should be set to true
> Actual Value: 'ebs_optimized' is undefined or null
> Issue Type: MissingAttribute

Common (1 Result)

Query Name: Passwords And Secrets - Generic Password

Total Results: 1

Description: Query to find passwords and secrets in infrastructure code.

Category: Secret Management

Result 1 of 1
High • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /rds.tf
> Expected Value: Hardcoded secret key should not appear in source
> Actual Value: Hardcoded secret key appears in source
> Issue Type: RedundantAttribute

Dockerfile (5 Results)

Query Name: Missing User Instruction

Total Results: 1

Description: Always set a user in the runtime stage of your Dockerfile. Without it, the container defaults to root, even if earlier build stages define a user.

Category: Build Process

Result 1 of 1
High • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /Dockerfile
> Expected Value: The 'Dockerfile' should contain the 'USER' instruction
> Actual Value: The 'Dockerfile' does not contain any 'USER' instruction
> Issue Type: MissingAttribute

Query Name: Add Instead of Copy

Total Results: 1

Description: Using ADD to load external installation scripts could lead to an evil web server leveraging this and loading a malicious script.

Category: Supply-Chain

Result 1 of 1
Medium • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /Dockerfile
> Expected Value: 'COPY' /usr/src/app/node_modules
> Actual Value: 'ADD' /usr/src/app/node_modules
> Issue Type: IncorrectValue

Query Name: Healthcheck Instruction Missing

Total Results: 1

Description: Ensure that HEALTHCHECK is being used. The HEALTHCHECK instruction tells Docker how to test a container to check that it is still working

Category: Insecure Configurations

Result 1 of 1
Low • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /Dockerfile
> Expected Value: Dockerfile should contain instruction 'HEALTHCHECK'
> Actual Value: Dockerfile doesn't contain instruction 'HEALTHCHECK'
> Issue Type: MissingAttribute

Query Name: Exposing Port 22 (SSH)

Total Results: 1

Description: Expose only the ports that your application needs and avoid exposing ports like SSH (22)

Category: Best Practices

Result 1 of 1
Low • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /Dockerfile
> Expected Value: 'EXPOSE' shouldn't contain the port 22
> Actual Value: 'EXPOSE' contains the port 22
> Issue Type: IncorrectValue

Query Name: Chown Flag Exists

Total Results: 1

Description: It is considered a best practice for every executable in a container to be owned by the root user even if it is executed by a non-root user, only execution permissions are required on the file, not ownership

Category: Best Practices

Result 1 of 1

Low • Link • New • To Verify • Found First: 07 Nov, 2025
Found Last: 01 Apr, 2026 • Scan ID: f00bdb1e-1e09-49a2-918f-93ebff4c2d37

> File: /Dockerfile
> Expected Value: The 'Dockerfile' shouldn´t contain the 'chown' flag
> Actual Value: The 'Dockerfile' contains the 'chown' flag
> Issue Type: IncorrectValue

SCA Vulnerabilities

By Severity

7	31	22	3	0	63

SCA Scan Results (63 Results)

Maven-org.json:json-20131018 (7 Results)

Package Name: org.json:json

Version: 20131018

Total Results: 3

Category: CWE-787
Total Results: 3

Result 1 of 3 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: rLIzLpyk3hYBQ1a6wcwg5kj41nToUlIlWdwXdMcwi3w= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2022-45689
> Description: hutool-json was discovered to contain an Out-of-Memory error. This vulnerability affects "cn.hutool:hutool-json" package versions prior to 5.8.11, and "org.json:json" package versions prior to 20211205.
> References: Advisory • Issue • Issue • Commit • Commit • Pull request

Result 2 of 3 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: KpI7StwI19YyfzUMvWnsILAIVy0bBhSRb5jC5oprN4A= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2022-45688
> Description: A stack overflow in the "XML.toJSONObject" component of hutool-json allows attackers to cause a Denial of Service (DoS) via crafted JSON or XML data. This vulnerability affects "org.json:json" package versions prior to 20230227, and "cn.hutool:hutool-json" package versions prior to 5.8.25.
> References: Advisory • Issue • Issue • Pull request • Commit • Release Note • Release Note • Commit

Result 3 of 3 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: oux/IDRG62+9Y31jMmJnirHSsF+I9hF4SIIn2hoEii0= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2022-45690
> Description: A stack overflow in the "org.json.JSONTokener.nextValue::JSONTokener.java" component of hutool-json allows attackers to cause a Denial of Service (DoS) via crafted JSON or XML data. This vulnerability affects "cn.hutool:hutool-json" package versions prior to 5.8.11, and "org.json:json" package versions prior to 20220320.
> References: Advisory • Issue • Commit • Issue • Commit • Pull request

Package Name: org.json:json

Version: 20131018

Total Results: 1

Category: CWE-74
Total Results: 1

Result 1 of 1 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: bex6vr0BUXBxOL6ymGF4BY5Uoc5ALw498F/zxu1mz1Q= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: Cx2906ba70-607a
> Description: The package `JSON-java` before 20171018 is vulnerable to Denial Of Service attack. The function `unescape()` used in multiple java files, unescapes a given XML string twice, causing the application to crash, due to `StringIndexOutOfBoundsException`.
> References: Issue • Pull request • Commit

Package Name: org.json:json

Version: 20131018

Total Results: 1

Category: CWE-248
Total Results: 1

Result 1 of 1 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: wYtXLEC0RdZ9WabP2vFsYdXHYwTttpWII3jTf4PJ6FA= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: Cx08fcacc9-cb99
> Description: The package `JSON-java` before 20180130 is vulnerable to Denial of service. The method `JSONArray()` in class `JSONArray()` of file `JSONArray.java`, doesn't check for unclosed array while parsing, causing the application to crash, due to an StackOverflowException. This affects the Availability of the application.
> References: Issue • Pull request • Commit

Package Name: org.json:json

Version: 20131018

Total Results: 1

Category: CWE-770
Total Results: 1

Result 1 of 1 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: TDOlayukCermZmUqwxgzI8HM1LLMN8ODpf49dLbOfP0= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2023-5072
> Description: Denial of Service (DoS) in JSON-Java in versions prior to 20231013. A bug in the parser means that an input string of modest size can lead to indefinite amounts of memory being used.
> References: Advisory • Advisory • Issue • Pull request • Commit • Release Note • Issue • Pull request • Commit

Package Name: org.json:json

Version: 20131018

Total Results: 1

Category: CWE-835
Total Results: 1

Result 1 of 1 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: Wc5UFSjABNggddiUA4Aj89iq9eZ1fqKWgS3SIPWL8bQ= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: Cxdb5a1032-eda2
> Description: The package `JSON-java` before 20200518 is vulnerable to Denial Of Service. The function `nextMeta` in the file `XMLTokener.java` runs into an infinite loop as the `JSONTokener.nextMeta()` function returns the same character repeatedly and never advances the Tokener index. Due to this flaw, the availability of the application is affected.
> References: Issue • Pull request • Commit

Maven-org.apache.tomcat:tomcat-coyote-9.0.22 (25 Results)

Package Name: org.apache.tomcat:tomcat-coyote

Version: 9.0.22

Total Results: 1

Category: CWE-835
Total Results: 1

Result 1 of 1 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: v1YyRUqgp+D90pnKHItDaiAQ6HZ6qk0wr/jhfCk2BRw= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2021-41079
> Description: Apache Tomcat 8.5.0 through 8.5.63, 9.0.0-M1 through 9.0.43, and 10.0.0-M1 through 10.0.2 did not properly validate incoming TLS packets. When Tomcat was configured to use NIO+OpenSSL or NIO2+OpenSSL for TLS, a specially crafted packet could be used to trigger an infinite loop resulting in a denial of service.
> References: Advisory • Mail Thread • Issue • Commit

Package Name: org.apache.tomcat:tomcat-coyote

Version: 9.0.22

Total Results: 4

Category: CWE-400
Total Results: 4

Result 1 of 4 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: YflOKkmtYzsActpao4EylCWrbJ55Ofr/lm1Np0ud1tg= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2025-53506
> Description: Uncontrolled Resource Consumption vulnerability in Apache Tomcat if an HTTP/2 client did not acknowledge the initial settings frame that reduces the maximum permitted concurrent streams. This issue affects Apache Tomcat versions from 11.0.0-M1 through 11.0.8, from 10.1.0-M1 through 10.1.42, from 9.0.0.M1 through 9.0.106. Users are recommended to upgrade to version 11.0.9, 10.1.43 or 9.0.107, which fix the issue.
> References: Advisory • Mail Thread • Commit

Result 2 of 4 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: d0zq5UNsNj/s9vqoAhi7CGO8Y13jnb5/GkYJPM9uMcc= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2023-44487
> Description: The HTTP/2 protocol allows a denial of service (server resource consumption) because r equest cancellation can reset many streams quickly, as exploited in the wild in August through Octob er 2023.
> References: Advisory • Advisory • Advisory • Advisory • Advisory • Commit • Commit • Commit • Commit • Commit • Commit • Pull request • Commit • Pull request • Commit • Pull request • Commit • Release Note • Issue • Release Note • Issue • Pull request • Commit • Pull request • Pull request • Pull request • Commit • Pull request • Commit • Advisory • Pull request • Commit • Pull request • Commit

Result 3 of 4 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: gQ1NoUiLchEdEOCUDPDNYNj/3TLGZAxFncPHziBDFsU= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2024-34750
> Description: Improper Handling of Exceptional Conditions, Uncontrolled Resource Consumption vulner ability in Apache Tomcat. When processing an HTTP/2 stream, Tomcat did not handle some cases of excessive HTTP headers correctly. This led to a miscounting of active HTTP/2 streams which in turn l ed to the use of an incorrect infinite timeout which allowed connections to remain open which should have been closed. This issue affects Apache Tomcat: from 9.0.0-M1 through 9.0.89, from 10.1.0-M1 thr ough 10.1.24, from 11.0.0-M1 through 11.0.0-M20.
> References: Advisory • Mail Thread • Commit • Advisory • Release Note

Result 4 of 4 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: X9hF92nkxh2hzsWO07pjdJEr/NOAuwWJV1×70pSZcP8= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2020-11996
> Description: A specially crafted sequence of HTTP/2 requests sent to Apache Tomcat 10.0.0-M1 to 10. 0.0-M5, 9.0.0.M1 to 9.0.35 and 8.5.0 to 8.5.55 could trigger high CPU usage for several seconds. If a s ufficient number of such requests were made on concurrent HTTP/2 connections, the server could be come unresponsive.
> References: Advisory • Issue • Commit

Package Name: org.apache.tomcat:tomcat-coyote

Version: 9.0.22

Total Results: 4

Category: CWE-444
Total Results: 4

Result 1 of 4 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: Q2Yecc75TByAsspPWG35agQK27Gl6UHD8neOqu8GqCc= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2022-42252
> Description: If Apache Tomcat 8.5.0 through 8.5.82, 9.0.0-M1 through 9.0.67, 10.0.0-M1 through 10.0.2 6 and 10.1.0-M1 through 10.1.0 was configured to ignore invalid HTTP headers via setting "rejectIllegal Header" to false (the default for 8.5.x only), Tomcat did not reject a request containing an invalid Cont ent-Length header making a request smuggling attack possible if Tomcat was located behind a revers e proxy that also failed to reject the request with the invalid header.
> References: Advisory • Mail Thread • Commit • Release Note

Result 2 of 4 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: kEIz1FBn6mmt5MrM+Ksa4p6k7FaWNJJG6fc575mXzfE= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2019-17569
> Description: The refactoring present in Apache Tomcat before 8.5.51 and 9.x before 9.0.31 introduced a regression. The result of the regression was that invalid Transfer-Encoding headers were incorrectly processed leading to a possibility of HTTP Request Smuggling if Tomcat was located behind a reverse proxy that incorrectly handled the invalid Transfer-Encoding header in a particular manner. Such a reverse proxy is considered unlikely.
> References: Release Note • Commit • Advisory

Result 3 of 4 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 28 Mar, 2026 •
Result ID: 9lXtnQ9agzbu/1ghqOpt4VdBSU5G4ltuHFKukOlitq4= •
First Scan ID: c75b1160-3d70-4c6d-90cf-19828fc45c5c

> CVE: CVE-2020-1935
> Description: In Apache Tomcat 9.0.0.M1 to 9.0.30, 8.5.0 to 8.5.50 and 7.0.0 to 7.0.99 the HTTP header parsing code used an approach to end-of-line parsing that allowed some invalid HTTP headers to be parsed as valid. This led to a possibility of HTTP Request Smuggling if Tomcat was located behind a reverse proxy that incorrectly handled the invalid Transfer-Encoding header in a particular manner. Such a reverse proxy is considered unlikely.
> References: Advisory • Commit • Commit • Commit

Result 4 of 4 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: ik1QFSpm7Mu7qegbHdjLkDeITCGzrbU8wXe4k/HCo7o= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2021-33037
> Description: Apache Tomcat 7.0.X, 8.0.X, 8.5.0 to 8.5.66, 9.0.0.M1 to 9.0.46, and 10.0.0-M1 to 10.0.6, did not correctly parse the HTTP transfer-encoding request header in some circumstances leading to the possibility to request smuggling when used with a reverse proxy. Specifically: - Tomcat incorrectly ignored the transfer encoding header if the client declared it would only accept an HTTP/1.0 response; - Tomcat honoured the identify encoding; and - Tomcat did not ensure that, if present, the chunked encoding was the final encoding.
> References: Advisory • Issue • Commit • Commit • Commit • Mail Thread

Package Name: org.apache.tomcat:tomcat-coyote

Version: 9.0.22

Total Results: 2

Category: CWE-770
Total Results: 2

Result 1 of 2 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: Me/zNbPp231WQ44Uuzb43+Gcscpft+dIqgjSiJA31ZQ= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2023-24998
> Description: Apache Commons FileUpload prior to 1.5 does not limit the number of request parts to be processed, resulting in the possibility of an attacker triggering a Denial of Service (DoS) with a malicious upload or series of uploads. Note that, like all the file upload limits, the new configuration option (FileUploadBase#setFileCountMax) is not enabled by default and must be explicitly configured.
> References: Advisory • Commit • Mail Thread • Pull request • Release Note

Result 2 of 2 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: L4uDt67A3ANOPCD54LeeRC3twcblGaGFu8fh4+/ISN8= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2024-38286
> Description: Allocation of Resources Without Limits or Throttling vulnerability in Apache Tomcat. This issue affects Apache Tomcat versions 9.0.13 through 9.0.89, 10.1.0-M1 through 10.1.24, and 11.0.0-M1 through 11.0.0-M20. Apache Tomcat, under certain configurations on any platform, allows an attacker to cause an "OutOfMemoryError" by abusing the TLS handshake process.
> References: Advisory • Commit • Mail Thread • Release Note

Package Name: org.apache.tomcat:tomcat-coyote

Version: 9.0.22

Total Results: 3

Category: CWE-20
Total Results: 3

Result 1 of 3 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: YG+MHTOmKM+k6hfQhCnGQNl1faxLfdLr62QkoFFeHTI= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2024-24549
> Description: According to the class of vulnerabilities "HTTP/2 CONTINUATION Flood," implementation of the HTTP/2 protocol without proper input validation or limits, leads to Denial of Service. This was found to affect Apache Tomcat. When processing an HTTP/2 request, if the request exceeded any of the configured limits for headers, the associated HTTP/2 stream was not reset until after all of the headers had been processed. This issue affects Apache Tomcat versions 8.5.0 through 8.5.98, 9.0.0-M1 through 9.0.85, 10.1.0-M1 through 10.1.18, and 11.0.0-M1 through 11.0.0-M16.
> References: Advisory • Mail Thread • Commit • Advisory • Blog Post • Blog Post

Result 2 of 3 - Vulnerability
Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: yXFnvNpPA5mLUxY1NlsI8wM5ILxCYsqTI7YI75OU/mk= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2023-45648
> Description: Improper Input Validation vulnerability in Apache Tomcat. A specially crafted, invalid trailer header could cause Tomcat to treat a single request as multiple requests leading to the possibility of request smuggling when behind a reverse proxy. This issue affects Apache Tomcat versions 8.5.0 through 8.5.93, 9.0.0.M1 through 9.0.80, 10.1.0-M1 through 10.1.13, and 11.0.0-M1 through 11.0.0-M11.
> References: Advisory • Commit • Mail Thread • Advisory

Result 3 of 3 - Vulnerability
Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: IAU4Ap/QIT/fGPnfoA7LGviUDw2Nir/cnHVirmV+MNU= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2025-66614
> Description: Improper Input Validation vulnerability. This issue affects Apache Tomcat: from 11.0.0-M1 through 11.0.14, 10.0.0-M1 through 10.1.49, and 8.5.0 through 9.0.112. Older EOL versions are not affected. Tomcat did not validate that the host name provided via the SNI extension was the same as the host name provided in the HTTP host header field. If Tomcat was configured with more than one virtual host and the TLS configuration for one of those hosts did not require client certificate authentication but another one did, it was possible for a client to bypass the client certificate authentication by sending different host names in the SNI extension and the HTTP host header field. The vulnerability only applies if client certificate authentication is only enforced at the Connector. It does not apply if client certificate authentication is enforced at the web application. Users are recommended to upgrade to version 11.0.15 or later, 10.1.50 or later or 9.0.113 or later, which fix the issue.
> References: Advisory • Mail Thread • Release Note • Release Note • Release Note • Commit • Commit

Package Name: org.apache.tomcat:tomcat-coyote

Version: 9.0.22

Total Results: 1

Category: CWE-404
Total Results: 1

Result 1 of 1 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: ICdc0OsrN+/bnEhp1hLTYfFSf0dd8J4T5youVsaN4fc= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2025-48989
> Description: Improper Resource Shutdown or Release vulnerability in Apache Tomcat made Tomcat vulnerable to the made you reset attack. This issue affects Apache Tomcat versions 8.5.0 through 9.0.107, 10.0.0-M1 through 10.1.43, and 11.0.0-M1 through 11.0.9. Older, EOL versions may also be affected.
> References: Advisory • Advisory • Commit

Package Name: org.apache.tomcat:tomcat-coyote

Version: 9.0.22

Total Results: 2

Category: CWE-362
Total Results: 2

Result 1 of 2 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: 2BRu44zyZb1bXd2rmuRYzg+JemWDi1sKoasF5iJTV6Q= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2025-52434
> Description: Concurrent Execution using Shared Resource with Improper Synchronization ('Race Condition') vulnerability in Apache Tomcat when using the APR/Native connector. This was particularly noticeable with client-initiated closes of HTTP/2 connections. This issue affects Apache Tomcat versions 9.0.x prior to 9.0.107.
> References: Advisory • Commit • Pull request • Mail Thread • Release Note

Result 2 of 2 - Vulnerability
Low • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: vbTFpxWvH0OqwJTWdBHrHidL3I6NlhA3A9rv7I8qHvg= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2021-43980
> Description: The simplified implementation of blocking reads and writes introduced in Tomcat 10 and back-ported to Tomcat 9.0.47 onwards exposed a long standing (but extremely hard to trigger) concurrency bug in Apache Tomcat 8.5.0 through 8.5.77, 9.0.0-M1 through 9.0.60, 10.0.0-M1 through 10.0.18 and 10.1.0-M1 through 10.1.0-M12 and that could cause client connections to share an "Http11Processor" instance resulting in responses, or part responses, to be received by the wrong client.
> References: Advisory • Mail Thread • Release Note • Commit

Package Name: org.apache.tomcat:tomcat-coyote

Version: 9.0.22

Total Results: 1

Category: CWE-401
Total Results: 1

Result 1 of 1 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: 49BfYMm7w8MFVw/hAuLS50×4TKSxxCDlpCqpf44sT28= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2020-13934
> Description: An h2c direct connection to Apache Tomcat 10.0.0-M1 to 10.0.0-M6, 9.0.0.M1 to 9.0.36, 8.0.x to 8.5.56 and 7.x did not release the HTTP/1.1 processor after the upgrade to HTTP/2. If a sufficient number of such requests were made, an OutOfMemoryException could occur leading to a denial of service.
> References: Advisory • Mail Thread • Commit

Package Name: org.apache.tomcat:tomcat-coyote

Version: 9.0.22

Total Results: 3

Category: CWE-200
Total Results: 3

Result 1 of 3 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: abPnBgZ05ObxYXmqzhrG4/Sn4djc095HMywJO6CN43g= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2020-17527
> Description: While investigating bug 64830 it was discovered that Apache Tomcat 10.0.0-M1 to 10.0.0-M9, 9.0.0-M1 to 9.0.39 and 8.5.0 to 8.5.59 could re-use an HTTP request header value from the previous stream received on an HTTP/2 connection for the request associated with the subsequent stream. While this would most likely lead to an error and the closure of the HTTP/2 connection, it is possible that information could leak between requests.
> References: Advisory • Mail Thread • Commit • Issue • Release Note • Release Note • Release Note

Result 2 of 3 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: /OHuyZtTRF3QYTBJkBrcD4HH7KiPz9pdQ5gJbxI3nlc= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2021-25122
> Description: When responding to new h2c connection requests, Apache Tomcat versions 10.0.0-M1 to 10.0.0, 9.0.0.M1 to 9.0.41 and through 8.5.61 could duplicate request headers and a limited amount of request body from one request to another meaning user A and user B could both see the results of us er A's request.
> References: Mail Thread • Advisory • Commit • Commit • Commit • Issue • Advisory

Result 3 of 3 - Vulnerability
Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: avpu+WAS9OShol0gik9v3A2H3RkyEC3mfuq5R9XgzZg= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2020-13943
> Description: If an HTTP/2 client connecting to Apache Tomcat affected versions exceeded the agreed maximum number of concurrent streams for a connection (in violation of the HTTP/2 protocol), it was possible that a subsequent request made on that connection could contain HTTP headers - including HTTP/2 pseudo headers - from a previous request rather than the intended headers. This could lead t o users seeing responses for unexpected resources. This issue affects org.apache.tomcat:tomcat-coy ote & org.apache.tomcat.embed:tomcat-embed-core versions 8.5.0 through 8.5.57, 9.0.0.M1 through 9.0.37, and 10.0.0-M1 through 10.0.0-M7 and org.apache.tomcat.experimental:tomcat-embed-progra mmatic version 9.0.38-dev.
> References: Advisory • Mail Thread • Advisory • Commit

Package Name: org.apache.tomcat:tomcat-coyote

Version: 9.0.22

Total Results: 1

Category: CWE-755
Total Results: 1

Result 1 of 1 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 28 Mar, 2026 •
Result ID: 1ugLIfqrKRRAhm8oB1wyJng8×4DUXjgw0vm0XLOVoc0= •
First Scan ID: c75b1160-3d70-4c6d-90cf-19828fc45c5c

> CVE: CVE-2021-30639
> Description: A vulnerability in Apache Tomcat allows an attacker to remotely trigger a denial of servic e. An error introduced as part of a change to improve error handling during non-blocking I/O meant th at the error flag associated with the Request object was not reset between requests. This meant that once a non-blocking I/O error occurred, all future requests handled by that request object would fail. Users were able to trigger non-blocking I/O errors, e.g. by dropping a connection, thereby creating th e possibility of triggering a DoS. Applications that do not use non-blocking I/O are not exposed to this vulnerability. This issue affects Apache Tomcat 7.0.X, 8.0.X, 8.5.X before 8.5.65, 9.0.X before 9.0.45 an d 10.0.X before 10.0.5.
> References: Advisory • Issue • Issue • Mail Thread • Commit

Package Name: org.apache.tomcat:tomcat-coyote

Version: 9.0.22

Total Results: 1

Category: CWE-459
Total Results: 1

Result 1 of 1 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: zcCITfHnPHW65SxbHIg6unywpKhL1rSda0HjFlutQrs= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2023-42795
> Description: Incomplete Cleanup vulnerability in Apache Tomcat. When recycling various internal objects in Apache Tomcat in versions prior to 8.5.94, 9.0.x prior to 9.0.81, 10.0.x prior to 10.1.14, 11.0.x prior to 11.0.0-M12 an error could cause Tomcat to skip some parts of the recycling process leading to information leaking from the current request/response to the next.
> References: Advisory • Advisory • Commit

Package Name: org.apache.tomcat:tomcat-coyote

Version: 9.0.22

Total Results: 1

Category: CWE-209
Total Results: 1

Result 1 of 1 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: YuJXBPayq8iybq7qIuwgYu1Zy/nRCiPWgWPz5PO3o8s= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2024-21733
> Description: Generation of Error Message Containing Sensitive Information vulnerability in Apache Tomcat. This issue affects the Apache Tomcat versions 8.5.7 through 8.5.63, 9.0.0-M11 through 9.0.43, and 10.0.0-M1 through 10.0.2.
> References: Advisory • Mail Thread • Commit • Release Note

Package Name: org.apache.tomcat:tomcat-coyote

Version: 9.0.22

Total Results: 1

Category: CWE-269
Total Results: 1

Result 1 of 1 - Vulnerability

Critical • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: Tzd2mx/lfb0h4vLA/QHJQ1KZKJ0ZUkE1gfhW0sfnGDI= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2020-1938
> Description: When using the Apache JServ Protocol (AJP), care must be taken when trusting incoming connections to Apache Tomcat. Tomcat treats AJP connections as having higher trust than, for example, a similar HTTP connection. If such connections are available to an attacker, they can be exploited in ways that may be surprising. In Apache Tomcat 9.0.0.M1 to 9.0.0.30, 8.5.0 to 8.5.50 and 7.0.0 to 7.0.99, Tomcat shipped with an AJP Connector enabled by default that listened on all configured IP addresses. It was expected (and recommended in the security guide) that this Connector would be disabled if not required. This vulnerability report identified a mechanism that allowed: - returning arbitrary files from anywhere in the web application - processing any file in the web application as a JSP Further, if the web application allowed file upload and stored those files within the web application (or the attacker was able to control the content of the web application by some other means) then this, along with the ability to process a file as a JSP, made remote code execution possible. It is important to note that mitigation is only required if an AJP port is accessible to untrusted users. Users wishing to take a defence-in-depth approach and block the vector that permits returning arbitrary files and execution as JSP may upgrade to Apache Tomcat 9.0.31, 8.5.51 or 7.0.100 or later. A number of changes were made to the default AJP Connector configuration in 9.0.31 to harden the default configuration. It is likely that users upgrading to 9.0.31, 8.5.51 or 7.0.100 or later will need to make small changes to their configurations.
> References: Advisory • Mail Thread • Commit • Commit • Commit • Commit • Commit • Commit • Commit • Commit • Commit • Commit

Maven-mysql:mysql-connector-java-5.1.26 (15 Results)

Package Name: mysql:mysql-connector-java

Version: 5.1.26

Total Results: 3

Category: CWE-20
Total Results: 3

Result 1 of 3 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: opzZipAKAAhzY9XPd5YiXsPu8ZXkf9ArVijdUmm0GXo= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: CVE-2018-3258
> Description: Vulnerability in the MySQL Connectors component of Oracle MySQL (subcomponent: Connector/J). Supported versions that are affected are 8.0.12 and prior. Easily exploitable vulnerability allows low privileged attacker with network access via multiple protocols to compromise MySQL Connectors. Successful attacks of this vulnerability can result in takeover of MySQL Connectors. CVSS 3.0 Base Score 8.8 (Confidentiality, Integrity and Availability impacts). CVSS Vector: (CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H).
> References: Advisory • Advisory • Disclosure • Commit

Result 2 of 3 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: +AHq6eOMkMh/TuFcY+D3KWSYJa9NjdnRdCpxQHxnKKM= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: CVE-2019-2692
> Description: Vulnerability in the MySQL Connectors component of Oracle MySQL (subcomponent: Connector/J). Supported versions that are affected are 8.0.15 and prior. Difficult to exploit vulnerability allows high privileged attacker with logon to the infrastructure where MySQL Connectors executes to compromise MySQL Connectors. Successful attacks require human interaction from a person other than the attacker. Successful attacks of this vulnerability can result in takeover of MySQL Connectors. CVSS 3.0 Base Score 6.3 (Confidentiality, Integrity and Availability impacts). CVSS Vector: (CVSS:3.0/AV:L/AC:H/PR:H/UI:R/S:U/C:H/I:H/A:H).
> References: Advisory • Release Note • Advisory

Result 3 of 3 - Vulnerability
Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: iZ3EeeN211gzZdbxq+ksKS9VPuuBYgq61fllmhx48UA= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: CVE-2022-21363
> Description: Vulnerability in the MySQL Connectors product of Oracle MySQL (component: Connector/J). Supported versions that are affected are 8.0.27 and prior. Difficult to exploit vulnerability allows high privileged attacker with network access via multiple protocols to compromise MySQL Connectors. Successful attacks of this vulnerability can result in takeover of MySQL Connectors. CVSS 3.1 Base Score 6.6 (Confidentiality, Integrity and Availability impacts). CVSS Vector: (CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:H).
> References: Advisory • Issue

Package Name: mysql:mysql-connector-java

Version: 5.1.26

Total Results: 1

Category: CWE-287
Total Results: 1

Result 1 of 1 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 06 Mar, 2026 •
Result ID: qdpreFGrIJXIvfUqYV5m3tM0qrUs+JkgRqrrodwn5AM= •
First Scan ID: 1e32c6c0-6455-4319-8078-a3a47c3e518c

> CVE: CVE-2023-22102
> Description: Vulnerability in the MySQL Connectors product of Oracle MySQL (component: Connector/J). The affected versions are through 8.1.0. The difficult-to-exploit vulnerability allows unauthenticated attackers with network access via multiple protocols to compromise MySQL Connectors. Successful attacks require human interaction from a person other than the attacker and while the vulnerability is in MySQL Connectors, attacks may significantly impact additional products (scope change). Successful attacks of this vulnerability can result in takeover of MySQL Connectors.
> References: Advisory • Advisory

Package Name: mysql:mysql-connector-java

Version: 5.1.26

Total Results: 2

Category: CWE-401
Total Results: 2

Result 1 of 2 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: 9toA8ipTgxBHZA12mI22cuX6DeDFZU+0Od5LjzW0Yxo= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: Cx039cb67c-ead3
> Description: MySQL Connector/J before 5.1.37 is vulnerable to Memory Leak. The method methodCompressedInputStream.getNextPacketFromServer() of src/com/mysq/jdbc/CompressedInputStream.java has high memory and garbage collection usage caused by the consecutive instantiation of a new inflater.
> References: Issue • Commit • Release Note

Result 2 of 2 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: +8rJtI5A91HbgtBCQBbjh5Y/bvT1SAwfUI05pIbJrwI= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: Cx6f651376-312a
> Description: MySQL Connector/J before version 5.1.44 and 6.x is vulnerable to memory leak. When using cached server-side prepared statements, a memory leak occurred as references to opened statements were being kept while the statements were being decached; it happened when either the close() method has been called twice on a statement, or when there were conflicting cache entries for a statement and the older entry had not been closed and removed from the opened statement list.
> References: Issue • Pull request • Commit • Release Note

Package Name: mysql:mysql-connector-java

Version: 5.1.26

Total Results: 1

Category: CWE-772
Total Results: 1

Result 1 of 1 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: 4h5Alp4JMym/LSAy9z0aAC/QZo5uBcQAH4wBTH3C8Vs= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: Cx7ef609d2-efb5
> Description: MySQL Connector/J before 5.1.31 is vulnerable to Memory Leak. Upon continuous interruption between the server and the database, the dead connections are accumulated in a map in `ProfilerEventHandlerFactory` factory and aren't removed from the memory. When the number of database connections reaches a certain number, it causes the application to throw an OutOfMemoryException as the garbage collector fails to collect the dead connections.
> References: Issue • Commit • Release Note

Package Name: mysql:mysql-connector-java

Version: 5.1.26

Total Results: 5

Category: CWE-284
Total Results: 5

Result 1 of 5 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: 3/Bp3r++X0MBBQ0L7BaSzX10hAdKZndVsOOUwA/1pT8= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: CVE-2017-3523
> Description: Vulnerability in the MySQL Connectors component of Oracle MySQL (subcomponent: Connector/J). Supported versions that are affected are 5.1.40 and earlier. Difficult to exploit vulnerability allows low privileged attacker with network access via multiple protocols to compromise MySQL Connectors. While the vulnerability is in MySQL Connectors, attacks may significantly impact additional products. Successful attacks of this vulnerability can result in takeover of MySQL Connectors. CVSS 3.0 Base Score 8.5 (Confidentiality, Integrity and Availability impacts). CVSS Vector: (CVSS:3.0/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:H/A:H).
> References: Advisory • Advisory • Commit

Result 2 of 5 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: UngSRpVd2fPJFeXw1Mf08owqvqt35yDLRbPN/HOTVko= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: CVE-2017-3586
> Description: Vulnerability in the MySQL Connectors component of Oracle MySQL (subcomponent: Connector/J). Supported versions that are affected are 5.1.41 and earlier. Easily "exploitable" vulnerability allows low privileged attacker with network access via multiple protocols to compromise MySQL Connectors. While the vulnerability is in MySQL Connectors, attacks may significantly impact additional products. Successful attacks of this vulnerability can result in unauthorized update, insert or delete access to some of MySQL Connectors accessible data as well as unauthorized read access to a subset of MySQL Connectors accessible data. CVSS 3.0 Base Score 6.4 (Confidentiality and Integrity impacts). CVSS Vector: (CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:L/A:N).
> References: Advisory • Release Note • Commit • Release Note

Result 3 of 5 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: 4gEzKRmqprEeEVDbRpOCDPGaoK/ZTo0fIQ+jLGgK98U= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: CVE-2020-2875
> Description: Vulnerability in the MySQL Connectors product of Oracle MySQL (component: Connector/J). Supported versions that are affected are 8.0.14 and prior and 5.1.48 and prior. Difficult to exploit vulnerability allows unauthenticated attacker with network access via multiple protocols to compromise MySQL Connectors. Successful attacks require human interaction from a person other than the attacker and while the vulnerability is in MySQL Connectors, attacks may significantly impact additional products. Successful attacks of this vulnerability can result in unauthorized update, insert or delete access to some of MySQL Connectors accessible data as well as unauthorized read access to a subset of MySQL Connectors accessible data. CVSS 3.0 Base Score 4.7 (Confidentiality and Integrity impacts). CVSS Vector: (CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:C/C:L/I:L/A:N).
> References: Mail Thread • Release Note • Advisory • Commit

Result 4 of 5 - Vulnerability

Critical • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: FP6xtV2+6LesXyCObm2W922vmtPLU+YKincZOqo8jM8= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: CVE-2015-2575
> Description: Improper Access Control vulnerability in the MySQL Connectors component in Oracle MySQL versions prior to 5.1.35 allows remote authenticated users to affect confidentiality and integrity via unknown vectors related to Connector/J.
> References: Commit • Advisory

Result 5 of 5 - Vulnerability

Low • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: VonDBCpyxrEzh8Mwt7jRQjRfR2tvjLex999W4SozI6c= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: CVE-2017-3589
> Description: Vulnerability in the MySQL Connectors component of Oracle MySQL (subcomponent: Connector/J). Supported versions that are affected are 5.1.41 and earlier. Easily "exploitable" vulnerability allows low privileged attacker with logon to the infrastructure where MySQL Connectors executes to compromise MySQL Connectors. Successful attacks of this vulnerability can result in unauthorized update, insert or delete access to some of MySQL Connectors accessible data. CVSS 3.0 Base Score 3.3 (Integrity impacts). CVSS Vector: (CVSS:3.0/AV:L/AC:L/PR:L/UI:N/S:U/C:N/I:L/A:N).
> References: Advisory • Release Note • Release Note • Commit • Issue

Package Name: mysql:mysql-connector-java

Version: 5.1.26

Total Results: 2

Category: CWE-400
Total Results: 2

Result 1 of 2 - Vulnerability
Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: KN4EgsD5DGry/YmsMEqdXJHCnwra8laEoqYYsarrK5U= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: CVE-2020-2934
> Description: Vulnerability in the MySQL Connectors product of Oracle MySQL (component: Connector/J). Supported versions that are affected are 8.0.19 and prior and 5.1.48 and prior. Difficult to exploit vulnerability allows unauthenticated attacker with network access via multiple protocols to compromise MySQL Connectors. Successful attacks require human interaction from a person other than the attacker. Successful attacks of this vulnerability can result in unauthorized update, insert or delete access to some of MySQL Connectors accessible data as well as unauthorized read access to a subset of MySQL Connectors accessible data and unauthorized ability to cause a partial denial of service (partial DOS) of MySQL Connectors. CVSS 3.0 Base Score 5.0 (Confidentiality, Integrity and Availability impacts). CVSS Vector: (CVSS:3.0/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:L).
> References: Release Note • Mail Thread • Advisory

Result 2 of 2 - Vulnerability
Low • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: g6Qx+6Lp+qxQY1ETDvufB5wUkNhyiKWA4ZmMQVyfwac= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: CVE-2020-2933
> Description: Vulnerability in the MySQL Connectors product of Oracle MySQL (component: Connector/J). Supported versions that are affected are 5.1.48 and prior. Difficult to exploit vulnerability allows high privileged attacker with network access via multiple protocols to compromise MySQL Connectors. Successful attacks of this vulnerability can result in unauthorized ability to cause a partial denial of service (partial DOS) of MySQL Connectors. CVSS 3.0 Base Score 2.2 (Availability impacts). CVSS Vector: (CVSS:3.0/AV:N/AC:H/PR:H/UI:N/S:U/C:N/I:N/A:L).
> References: Issue • Advisory • Release Note

Package Name: mysql:mysql-connector-java

Version: 5.1.26

Total Results: 1

Category: CWE-611
Total Results: 1

Result 1 of 1 - Vulnerability
Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: Ca/AEfCjdZlatedVQL4LtACiwEd1mdHnhR39XF41YPE= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: CVE-2021-2471
> Description: Vulnerability in the MySQL Connectors product of Oracle MySQL (component: Connector/J). This vulnerability affects versions through 8.0.26. Difficult to exploit vulnerability allows high privileged attacker with network access via multiple protocols to compromise MySQL Connectors. Successful attacks of this vulnerability can result in unauthorized access to critical data or complete access to all MySQL Connectors accessible data and unauthorized ability to cause a hang or frequently repeatable crash (complete DOS) of MySQL Connectors.
> References: Disclosure • Commit • Release Note • Advisory • Advisory

Maven-commons-collections:commons-collections-3.2.1 (5 Results)

Package Name: commons-collections:commons-collections

Version: 3.2.1

Total Results: 1

Category: CWE-674
Total Results: 1

Result 1 of 1 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 02 Mar, 2026 •
Result ID: Hit5mbleoDda66qVwR9mUDtCKAYrBMHGmLOdoKegUkc= •
First Scan ID: c37d1d68-0b6c-45fe-a6ed-9c3ac07bdc71

> CVE: Cx78f40514-81ff
> Description: The framework Apache Commons Collections before 4.3 is vulnerable to Stack Overflow. The function `add()` in the file `SetUniqueList.java` throws a StackOverflowError when the `add()` method is called with its own list. Please note: the package name was changed from "commons-collections:commons-collections" to "org.apache.commons:commons-collections4" on version 4.0.
> References: Issue • Pull request • Commit

Package Name: commons-collections:commons-collections

Version: 3.2.1

Total Results: 4

Category: CWE-502
Total Results: 4

Result 1 of 4 - Vulnerability
Critical • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: 5KkOr4iOOURTg5MX9oUOjR6iX6uoOjM++tqQJCswJoA= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: CVE-2016-2170
> Description: Apache OFBiz 12.04.x before 12.04.06 and 13.07.x before 13.07.03 allow remote attackers to execute arbitrary commands via a crafted serialized Java object, related to the Apache Commons Collections library. The Java artifact causing the deserialization vulnerability is Apache Commons Collections in versions 3.0 through 3.2.1 and version 4.0.
> References: Advisory • Advisory • Issue • Commit • Commit • Commit

Result 2 of 4 - Vulnerability
Critical • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: h1fxKEEKaMnnop4ocz3q+UWeVjN4H9slDwsaSoHOWu8= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: CVE-2015-4852
> Description: The WLS Security component in Oracle WebLogic Server 10.3.6.0, 12.1.2.0, 12.1.3.0, and 12.2.1.0 allows remote attackers to execute arbitrary commands via a crafted serialized Java object in T3 protocol traffic to TCP port 7001, related to "oracle_common/modules/com.bea.core.apache.commons.collections.jar". The Java artifact causing the deserialization vulnerability is Apache Commons Collections in versions 3.0 through 3.2.1 and version 4.0. NOTE: the scope of this CVE is limited to the WebLogic Server product.
> References: Advisory • POC/Exploit • POC/Exploit • Commit • Issue • Commit • Commit • Advisory

Result 3 of 4 - Vulnerability

Critical • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: cooFNFdbWZcZKll77bZkwolfvZF38v3Qs5g2qauH1y0= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: CVE-2015-7501
> Description: Red Hat JBoss A-MQ 6.x; BPM Suite (BPMS) 6.x; BRMS 6.x and 5.x; Data Grid (JDG) 6.x; Data Virtualization (JDV) 6.x and 5.x; Enterprise Application Platform 6.x, 5.x, and 4.3.x; Fuse 6.x; Fuse Service Works (FSW) 6.x; Operations Network (JBoss ON) 3.x; Portal 6.x; SOA Platform (SOA-P) 5.x; Web Server (JWS) 3.x; Red Hat OpenShift/xPAAS 3.x; and Red Hat Subscription Asset Manager 1.3 all ow remote attackers to execute arbitrary commands via a crafted serialized Java object, related to th e Apache Commons Collections (ACC) library. The Java artifact causing the deserialization vulnerabili ty is Apache Commons Collections in versions 3.0 through 3.2.1 and version 4.0.
> References: Release Note • Issue • Issue • Commit • POC/Exploit • Commit • Commit • Advisory

Result 4 of 4 - Vulnerability

Critical • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: qrMzNUeehrKe36R3LcukjCAjOTVFK7+x8×8kjFKxjJo= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: CVE-2015-6420
> Description: Serialized-object interfaces in certain Cisco Collaboration and Social Media; Endpoint Cli ents and Client Software; Network Application, Service, and Acceleration; Network and Content Secur ity Devices; Network Management and Provisioning; Routing and Switching - Enterprise and Service P rovider; Unified Computing; Voice and Unified Communications Devices; Video, Streaming, TelePrese nce, and Transcoding Devices; Wireless; and Cisco Hosted Services products allow remote attackers to execute arbitrary commands via a crafted serialized Java object, related to the Apache Commons Collections (ACC) library. The Java artifact causing the deserialization vulnerability is Apache Commo ns Collections in versions 3.0 through 3.2.1 and version 4.0.
> References: Commit • Issue • Mail Thread • Commit • Commit • Advisory • Advisory

Maven-dom4j:dom4j-1.6.1 (2 Results)

Package Name: dom4j:dom4j

Version: 1.6.1

Total Results: 1

Category: CWE-91
Total Results: 1

Result 1 of 1 - Vulnerability

High • New • To Verify • Outdated: yes • Found First: 12 Jan, 2026 •
Result ID: EFFHqEpWA2GlhudCEm06xAW+9aExC55k16I5xEIdEBA= •
First Scan ID: 3a981ea7-b550-4e65-a574-b479f74b28f3

> CVE: CVE-2018-1000632
> Description: dom4j prior to 2.0.3 and 2.1.x prior to 2.1.1 contains a CWE-91: XML Injection vulnerability in Class: Element. Methods: addElement, addAttribute that can result in an attacker tampering with X ML documents through XML injection. This attack appear to be exploitable via an attacker specifying attributes or elements in the XML document. To resolve this issue - upgrade to version 2.0.3 or 2.1.1. P lease note: the package name was changed to org.dom4j:dom4j on version 2.0.0.
> References: Commit • Issue • Advisory • Disclosure

Package Name: dom4j:dom4j

Version: 1.6.1

Total Results: 1

Category: CWE-611
Total Results: 1

Result 1 of 1 - Vulnerability
Critical • New • To Verify • Outdated: yes • Found First: 05 Mar, 2026 •
Result ID: xtHgjho616k5yA9VXeSWiS9kL6nwigledDtRcPEVU40= •
First Scan ID: 59e67747-9715-4391-8d50-e143dccbff96

> CVE: CVE-2020-10683
> Description: dom4j before 2.1.3 allows external DTDs and External Entities by default, which might enable XXE attacks. However, there is popular external documentation from OWASP showing how to enable the safe, non-default behavior in any application that uses dom4j.
> References: Advisory • Mail Thread • Release Note • Advisory • Commit

Maven-org.hibernate:hibernate-core-4.0.1.Final (2 Results)

Package Name: org.hibernate:hibernate-core

Version: 4.0.1.Final

Total Results: 2

Category: CWE-89
Total Results: 2

Result 1 of 2 - Vulnerability
High • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: mXOkNaV2CrHZEuGlXzc1WXani1K64uvU2nxkAd4VIAo= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: CVE-2020-25638
> Description: A flaw was found in hibernate-core in versions prior to 5.3.20.Final and from 5.4.0.CR1 to 5.4.23.Final. A SQL injection in the implementation of the JPA Criteria API can permit unsanitized literals when a literal is used in the SQL comments of the query. This flaw could allow an attacker to access unauthorized information or possibly conduct further attacks. The highest threat from this vulnerability is to data confidentiality and integrity.
> References: Advisory • Advisory • Issue • Commit

Result 2 of 2 - Vulnerability
Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: wIM32wuXSQU+bP3TBFDYK0Z2edNeHjcMMx3YCjrMAmk= •
First Scan ID: 2717add6-fd55-4ed8-a6dd-f80c124f6da1

> CVE: CVE-2019-14900
> Description: A flaw was found in Hibernate ORM in versions before 5.3.18, 5.4.18 and 5.5.0.Beta1. A SQL injection in the implementation of the JPA Criteria API can permit unsanitized literals when a literal is used in the SELECT or GROUP BY parts of the query. This flaw could allow an attacker to access unauthorized information or possibly conduct further attacks.
> References: Advisory • Advisory • Issue • Pull request • Commit

Npm-jquery-1.6.4 (6 Results)

Package Name: jquery

Version: 1.6.4

Total Results: 5

Category: CWE-79
Total Results: 5

Result 1 of 5 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: 6SlGpkAhsqafAsKZX7xLs6r7R7lGV6EQKlsDjGWxcBQ= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: Cxf0b588a3-5c6f
> Description: The package `jQuery` before 1.12.0, between 1.12.2 and 2.1.4 and between 2.2.2 and 2.2.4 is vulnerable to `XSS`. The function `jQuery.parseHTML()` in the file `src/core/parseHTML.js` doesn't stop scripts or inline event handlers from being executed immediately, which could result in XSS as the attacker could embed malicious scripts in the HTML (img nodes with embedded src url's which are pre-loaded when the page is requested) which would get executed immediately in the victim's browser even without user's intervention.
> References: Issue • Pull request • Commit • Pull request • Commit

Result 2 of 5 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: uwVV5+v7e2ALskGRMYIQqGfiOUn480XI/TEXfM9o5IY= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2012-6708
> Description: jQuery before 1.9.0 is vulnerable to Cross-site Scripting (XSS) attacks. The jQuery(strInput) function does not differentiate selectors from HTML in a reliable fashion. In vulnerable versions, jQuery determined whether the input was HTML by looking for the '<' character anywhere in the string, giving attackers more flexibility when attempting to construct a malicious payload. In fixed versions, jQuery only deems the input to be HTML if it explicitly starts with the '<' character, limiting exploitability only to attackers who can control the beginning of a string, which is far less common.
> References: Advisory • Issue • Commit

Result 3 of 5 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: 4DZG6vDus8rTH7NLBtNVo59dkypTDeuRQhKW2c5wNqY= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2015-9251
> Description: jQuery before 3.0.0-beta1 is vulnerable to Cross-site Scripting (XSS) attacks when a cross-domain Ajax request is performed without the dataType option, causing text/javascript responses to be executed.
> References: Issue • Pull request • Commit

Result 4 of 5 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: WX5NCPWc024hfsjh0Ly7fI1rZPsiR0fGI1VlpgH9xvo= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2020-11023
> Description: In jQuery versions 1.0.3 through 3.4.1, passing HTML containing <option> elements from untrusted sources - even after sanitizing it - to one of jQuery's DOM manipulation methods (i.e. .html(), .append(), and others) may execute untrusted code. This vulnerability also affects jquery-rails versions through 4.3.5.
> References: Advisory • Release Note • Pull request • Commit • Commit •
> Pull request • Release Note • Commit • Issue

Result 5 of 5 - Vulnerability

Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: 6OcxG8xCCf9y70u+Dis4NQ7kfM73xAjYjU1zDvKgesU= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2020-7656
> Description: jquery prior to 1.9.0 allows Cross-site Scripting attacks via the load method. The load method fails to recognize and remove "<script>" HTML tags that contain a whitespace character, i.e: "</ script >", which results in the enclosed script logic to be executed.
> References: Commit • Advisory • Advisory

Package Name: jquery

Version: 1.6.4

Total Results: 1

Category: CWE-1321
Total Results: 1

Result 1 of 1 - Vulnerability
Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: mgN2oFXc2Swi/4A9Pgl4va6/IF5WGzPNEMxEEIAx5rs= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2019-11358
> Description: jQuery before 3.4.0, as used in Drupal, Backdrop CMS, and other products, mishandles jQuery.extend(true, {}, ...) because of Object.prototype pollution. If an unsanitized source object contained an enumerable __proto__ property, it could extend the native Object.prototype.
> References: Advisory • Release Note • Pull request • Commit • Patch • Disclosure • Advisory • Advisory

Maven-org.apache.tomcat:tomcat-util-9.0.22 (1 Result)

Package Name: org.apache.tomcat:tomcat-util

Version: 9.0.22

Total Results: 1

Category: CWE-459
Total Results: 1

Result 1 of 1 - Vulnerability
Medium • New • To Verify • Outdated: yes • Found First: 27 Mar, 2026 •
Result ID: loCnJ/1JkQ2Iu+MGuEMYjcmtOqCZKOiiJrp6e/0Bdh4= •
First Scan ID: c831a188-5240-4cc7-be33-44a44d88e3a8

> CVE: CVE-2023-42795
> Description: Incomplete Cleanup vulnerability in Apache Tomcat. When recycling various internal objects in Apache Tomcat in versions prior to 8.5.94, 9.0.x prior to 9.0.81, 10.0.x prior to 10.1.14, 11.0.x prior to 11.0.0-M12 an error could cause Tomcat to skip some parts of the recycling process leading to information leaking from the current request/response to the next.
> References: Advisory • Advisory • Commit

Container Security Vulnerabilities

By Severity

5	24	14	6	0	49

Container Security Scan Results (49)

Dockerfile (1 Image)

node (3 Layers)

Base Images:

Remediation Available: Yes

Runtime: false

Total Vulnerabilities: 49

/bin/sh -c #(nop) ADD file:5d673d25da3a14ce1f6cf66e4c7fd4f4b85a3759a9d93efb3fd9f ... (11 Packages)
• Link • 5 Bytes

Package Name: openssl

Severity: H High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2023-03-22 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.1.1n-r0

Outdated: This data is currently not transmitted to the report.

CWE: CWE-295

CVE: CVE-2023-0464

Package Name: openssl

Severity: H High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2023-02-08 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.1.1n-r0

Outdated: This data is currently not transmitted to the report.

CWE: CWE-843

CVE: CVE-2023-0286

Package Name: openssl

Severity: H High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2023-02-08 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.1.1n-r0

Outdated: This data is currently not transmitted to the report.

CWE: CWE-416

CVE: CVE-2023-0215

Package Name: openssl

Severity: High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2023-02-08 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.1.1n-r0

Outdated: This data is currently not transmitted to the report.

CWE: CWE-415

CVE: CVE-2022-4450

Package Name: openssl

Severity: Medium

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2023-07-31 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.1.1n-r0

Outdated: This data is currently not transmitted to the report.

CWE: CWE-834

CVE: CVE-2023-3817

Package Name: openssl

Severity: Medium

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2023-07-19 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.1.1n-r0

Outdated: This data is currently not transmitted to the report.

CWE: CWE-1333

CVE: CVE-2023-3446

Package Name: openssl

Severity: Medium

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2023-05-30 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.1.1n-r0

Outdated: This data is currently not transmitted to the report.

CWE: CWE-770

CVE: CVE-2023-2650

Package Name: openssl

Severity: Medium

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2023-03-28 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.1.1n-r0

Outdated: This data is currently not transmitted to the report.

CWE: CWE-295

CVE: CVE-2023-0465

Package Name: openssl

Severity: Medium

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2023-02-08 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.1.1n-r0

Outdated: This data is currently not transmitted to the report.

CWE: CWE-203

CVE: CVE-2022-4304

Package Name: openssl

Severity: Medium

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2022-07-05 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.1.1n-r0

Outdated: This data is currently not transmitted to the report.

CWE: CWE-327

CVE: CVE-2022-2097

Package Name: openssl

Severity: Medium

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2023-11-06 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.1.1n-r0

Outdated: This data is currently not transmitted to the report.

CWE: CWE-754

CVE: CVE-2023-5678

Package Name: zlib

Severity: Critical

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2022-08-05 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.2.12-r0

Outdated: This data is currently not transmitted to the report.

CWE: CWE-787

CVE: CVE-2022-37434

/bin/sh -c addgroup -g 1000 node && adduser -u 1000 -G node -s /bin/sh -D no ... (404 Packages)

Link • 74 Bytes

Package Name: ajv

Severity: Low

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2026-02-11 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 6.12.6

Outdated: This data is currently not transmitted to the report.

CWE: CWE-1333

CVE: CVE-2025-69873

Package Name: ansi-regex

Severity: High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2021-09-17 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 2.1.1

Outdated: This data is currently not transmitted to the report.

CWE: CWE-1333

CVE: CVE-2021-3807

Package Name: ansi-regex

Severity: High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2021-09-17 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 3.0.0

Outdated: This data is currently not transmitted to the report.

CWE: CWE-1333

CVE: CVE-2021-3807

Package Name: ansi-regex

Severity: High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2021-09-17 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 4.1.0

Outdated: This data is currently not transmitted to the report.

CWE: CWE-1333

CVE: CVE-2021-3807

Package Name: bluebird

Severity: Low

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2016-04-24 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 3.5.5

Outdated: This data is currently not transmitted to the report.

CWE: CWE-401

CVE: Cxda14f253-4e52

Package Name: brace-expansion

Severity: Low

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2025-06-09 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.1.11

Outdated: This data is currently not transmitted to the report.

CWE: CWE-1333

CVE: CVE-2025-5889

Package Name: cross-spawn

Severity: High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2024-11-08 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 5.1.0

Outdated: This data is currently not transmitted to the report.

CWE: CWE-1333

CVE: CVE-2024-21538

Package Name: debug

Severity: Low

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2020-12-10 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 3.1.0

Outdated: This data is currently not transmitted to the report.

CWE: CWE-1333

CVE: Cx8bc4df28-fcf5

Package Name: decode-uri-component

Severity: High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2022-11-28 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 0.2.0

Outdated: This data is currently not transmitted to the report.

CWE: CWE-20

CVE: CVE-2022-38900

Package Name: form-data

Severity: Critical

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2025-07-18 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 2.3.2

Outdated: This data is currently not transmitted to the report.

CWE: CWE-330

CVE: CVE-2025-7783

Package Name: got

Severity: Medium

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2022-06-18 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 6.7.1

Outdated: This data is currently not transmitted to the report.

CWE: CWE-601

CVE: CVE-2022-33987

Package Name: http-cache-semantics

Severity: High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2023-01-31 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 3.8.1

Outdated: This data is currently not transmitted to the report.

CWE: CWE-1333

CVE: CVE-2022-25881

Package Name: inflight

Severity: High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2020-12-07 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.0.6

Outdated: This data is currently not transmitted to the report.

CWE: CWE-772

CVE: Cxdca8e59f-8bfe

Package Name: ip

Severity: Critical

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2024-02-08 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.1.5

Outdated: This data is currently not transmitted to the report.

CWE: CWE-918

CVE: CVE-2023-42282

Package Name: ip

Severity: High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2024-05-27 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.1.5

Outdated: This data is currently not transmitted to the report.

CWE: CWE-918

CVE: CVE-2024-29415

Package Name: ip

Severity: Low

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2025-09-16 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.1.5

Outdated: This data is currently not transmitted to the report.

CWE: CWE-918

CVE: CVE-2025-59437

Package Name: ip

Severity: Low

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2025-09-16 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.1.5

Outdated: This data is currently not transmitted to the report.

CWE: CWE-918

CVE: CVE-2025-59436

Package Name: minimatch

Severity: High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2026-02-26 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 3.0.4

Outdated: This data is currently not transmitted to the report.

CWE: CWE-1333

CVE: CVE-2026-27904

Package Name: minimatch

Severity: High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2026-02-20 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 3.0.4

Outdated: This data is currently not transmitted to the report.

CWE: CWE-1333

CVE: CVE-2026-26996

Package Name: minimatch

Severity: High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2022-10-17 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 3.0.4

Outdated: This data is currently not transmitted to the report.

CWE: CWE-400

CVE: CVE-2022-3517

Package Name: minimatch

Severity: High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2026-02-26 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 3.0.4

Outdated: This data is currently not transmitted to the report.

CWE: CWE-407

CVE: CVE-2026-27903

Package Name: minimist

Severity: Critical

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2022-03-17 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.2.5

Outdated: This data is currently not transmitted to the report.

CWE: CWE-1321

CVE: CVE-2021-44906

Package Name: npm

Severity: High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2026-01-23 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 6.14.16

Outdated: This data is currently not transmitted to the report.

CWE: CWE-732

CVE: CVE-2026-0775

Package Name: qs

Severity: High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2022-11-26 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 6.5.2

Outdated: This data is currently not transmitted to the report.

CWE: CWE-1321

CVE: CVE-2022-24999

Package Name: qs

Severity: Medium

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2025-12-29 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 6.5.2

Outdated: This data is currently not transmitted to the report.

CWE: CWE-20

CVE: CVE-2025-15284

Package Name: request

Severity: Medium

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2023-03-16 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 2.88.0

Outdated: This data is currently not transmitted to the report.

CWE: CWE-918

CVE: CVE-2023-28155

Package Name: semver

Severity: High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2023-06-21 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 5.7.1

Outdated: This data is currently not transmitted to the report.

CWE: CWE-1333

CVE: CVE-2022-25883

Package Name: tar

Severity: H High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2026-02-20 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 4.4.19

Outdated: This data is currently not transmitted to the report.

CWE: CWE-22

CVE: CVE-2026-26960

Package Name: tar

Severity: H High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2026-01-16 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 4.4.19

Outdated: This data is currently not transmitted to the report.

CWE: CWE-22

CVE: CVE-2026-23745

Package Name: tar

Severity: H High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2026-01-28 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 4.4.19

Outdated: This data is currently not transmitted to the report.

CWE: CWE-22

CVE: CVE-2026-24842

Package Name: tar

Severity: H High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2026-03-07 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 4.4.19

Outdated: This data is currently not transmitted to the report.

CWE: CWE-22

CVE: CVE-2026-29786

Package Name: tar

Severity: High

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2026-03-10 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 4.4.19

Outdated: This data is currently not transmitted to the report.

CWE: CWE-22

CVE: CVE-2026-31802

Package Name: tar

Severity: Medium

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2024-03-21 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 4.4.19

Outdated: This data is currently not transmitted to the report.

CWE: CWE-400

CVE: CVE-2024-28863

Package Name: tar

Severity: Medium

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2026-01-20 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 4.4.19

Outdated: This data is currently not transmitted to the report.

CWE: CWE-176

CVE: CVE-2026-23950

Package Name: tough-cookie

Severity: Critical

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2023-07-01 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 2.4.3

Outdated: This data is currently not transmitted to the report.

CWE: CWE-1321

CVE: CVE-2023-26136

/bin/sh -c apk add --no-cache --virtual .build-deps-yarn curl gnupg tar && for ... (1 Package)

Link • 7 Bytes

Package Name: yarn

Severity: Medium

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2025-07-28 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.22.18

Outdated: This data is currently not transmitted to the report.

CWE: CWE-1333

CVE: CVE-2025-8262

Package Name: yarn

Severity: Medium

State: To Verify

Status: NEW

Description: This data is currently not transmitted to the report.

First Scan ID: 7a0c2bd5-b974-40a6-927a-88b54c562444

First Found Date: 2025-08-21 05:30:00

Found Date: 2026-04-01 16:27:14

Version: 1.22.18

Outdated: This data is currently not transmitted to the report.

CWE: CWE-1333

CVE: CVE-2025-9308

SAST Resolved Vulnerabilities

No data to show

Categories

ASA Mobile Premium

Category	C	H	M	L	I
ASA Mobile Premium	37	0	5	0	0

ASA Premium

Category	C	H	M	L	I
ASA Premium	93	31	138	10	0

ASD STIG 6.1

Category	C	H	M	L	I
APSC-DV-002540 - CAT I The application must not be vulnerable to SQL Injection.	45	0	0	0	0
APSC-DV-002010 - CAT II The application must implement NSA-approved cryptography to protect classified information in accordance with applicable federal laws, Executive Orders, directives, policies, regulations, and standards.	0	0	1	0	0
APSC-DV-002330 - CAT II The application must protect the confidentiality and integrity of stored information when required by DoD policy or the information owner.	0	0	6	8	0
APSC-DV-002490 - CAT I The application must protect from Cross-Site Scripting (XSS) vulnerabilities.	48	14	0	0	0
APSC-DV-002500 - CAT II The application must protect from Cross-Site and Server-Side Request Forgery (CSRF|SSRF) vulnerabilities.	0	3	110	0	0
APSC-DV-002550 - CAT I The application must not be vulnerable to XML-oriented attacks.	0	1	0	0	0
APSC-DV-002560 - CAT I The application must not be subject to input handling vulnerabilities.	0	4	15	0	0
APSC-DV-001740 - CAT I The application must only store cryptographic representations of passwords.	0	0	5	0	0
APSC-DV-002360 - CAT II The application must isolate security functions from non-security functions.	0	0	0	2	0

Base Preset

Category	C	H	M	L	I
Base Preset	93	5	8	0	0

CWE top 25

Category	C	H	M	L	I
CWE top 25	93	26	114	0	0

FISMA 2014

Category	C	H	M	L	I
System And Information Integrity	93	21	7	0	0
Identification And Authentication	0	0	11	0	0
Configuration Management	0	0	1	0	0

MOIS(KISA) Secure Coding 2021

Category	C	H	M	L	I
MOIS(KISA) Verification and representation of input data	93	30	117	0	0
MOIS(KISA) Security Functions	0	0	18	0	0

NIST SP 800-53

Category	C	H	M	L	I
SC-4 Information in Shared Resources (P1)	0	0	6	0	0
SI-10 Information Input Validation (P1)	45	7	7	0	0
SI-15 Information Output Filtering (P0)	48	14	0	0	0

SC-28 Protection of Information at Rest (P1)	0	0	5	0	0
SC-13 Cryptographic Protection (P1)	0	0	1	0	0
SC-23 Session Authenticity (P1)	0	0	110	0	0

OWASP ASVS

Category	C	H	M	L	I
V01 Architecture, Design and Threat Modeling	0	3	7	0	0
V02 Authentication	0	0	5	0	0
V13 API and Web Service	0	0	110	0	0
V08 Data Protection	0	0	0	8	0
V12 Files and Resources	0	9	0	0	0
V06 Stored Cryptography	0	0	1	0	0
V10 Malicious Code	0	0	6	0	0
V14 Configuration	0	0	1	0	0
V05 Validation, Sanitization and Encoding	93	18	7	0	0

OWASP Mobile Top 10 2016

Category	C	H	M	L	I
M7-Client Code Quality	37	0	0	0	0
M9-Reverse Engineering	0	0	4	0	0

OWASP Mobile Top 10 2024

Category	C	H	M	L	I
M1: Improper Credential Usage	0	0	1	0	0
M4: Insufficient Input/Output Validation	93	26	2	0	0
M6: Inadequate Privacy Controls	0	0	6	0	0

OWASP Top 10 2013

Category	C	H	M	L	I
A4-Insecure Direct Object References	0	8	0	0	0
A6-Sensitive Data Exposure	0	0	8	8	0
A8-Cross-Site Request Forgery (CSRF)	0	0	110	0	0
A1-Injection	45	3	2	0	0
A3-Cross-Site Scripting (XSS)	48	14	0	0	0

OWASP Top 10 2017

Category	C	H	M	L	I
A7-Cross-Site Scripting (XSS)	48	14	0	0	0
A5-Broken Access Control	0	12	7	0	0
A4-XML External Entities (XXE)	0	1	0	0	0
A3-Sensitive Data Exposure	0	0	8	0	0
A10-Unvalidated Redirects and Forwards	0	0	5	0	0

OWASP Top 10 2021

Category	C	H	M	L	I
A4-Insecure Design	0	0	9	2	0
A3-Injection	93	19	3	0	0
A10-Server-Side Request Forgery	0	3	0	0	0
A1-Broken Access Control	0	9	121	0	0
A5-Security Misconfiguration	0	1	0	0	0
A7-Identification and Authentication Failures	0	0	5	0	0
A2-Cryptographic Failures	0	0	1	8	0

OWASP Top 10 API

Category	C	H	M	L	I
API1-Broken Object Level Authorization	0	0	7	0	0
API8-Injection	45	0	2	0	0
API2-Broken Authentication	0	0	5	0	0
API2-Broken Authentication	0	0	1	0	0
API4-Lack of Resources and Rate Limiting	0	0	1	0	0

OWASP Top 10 API 2023

Category	C	H	M	L	I
API7-Server Side Request Forgery	0	3	0	0	0
API4-Unrestricted Resource Consumption	0	0	1	0	0

API10-Unsafe Consumption of APIs	0	0	5	0	0
API8-Security Misconfiguration	0	0	1	0	0

PCI DSS v3.2.1

Category	C	H	M	L	i
PCI DSS (3.2.1) - 6.5.9 - Cross-site request forgery	0	0	110	0	0
PCI DSS (3.2.1) - 6.5.1 - Injection flaws - particularly SQL injection	45	3	15	0	0
PCI DSS (3.2.1) - 6.5.7 - Cross-site scripting (XSS)	48	14	0	0	0
PCI DSS (3.2.1) - 6.5.8 - Improper access control	0	9	5	0	0
PCI DSS (3.2.1) - 6.5.10 - Broken authentication and session management	0	0	4	0	0
PCI DSS (3.2.1) - 6.5.4 - Insecure communications	0	0	1	0	0

PCI DSS v4.0

Category	C	H	M	L	i
PCI DSS (4.0) - 6.2.4 Vulnerabilities in software development	93	27	133	2	0
PCI DSS (4.0) - 8.6.2 Vulnerabilities related to passwords/passphrases usage	0	0	5	0	0

SANS top 25

Category	C	H	M	L	i
SANS top 25	93	24	120	0	0

Top Tier

Category	C	H	M	L	i

Top Tier	93	17	2	0	0

Vulnerability Details

SQL_Injection (CWE 89)

What Is The Risk

An attacker could directly access all of the system's data. The attacker would likely be able to steal any sensitive information stored by the system, including private user information, credit card details, proprietary business data, and any other secret data. Likewise, the attacker could possibly modify or erase existing data, or even add new bogus data. In some scenarios, it may even be possible to execute code on the database. In addition to disclosing or altering confidential information directly, this vulnerability might also be used to achieve secondary effects, such as bypassing authentication, subverting security checks, or forging a data trail. Further increasing the likelihood of exploit is the fact that this flaw is easy for attackers to find, and easy to exploit.

What Can Cause It

The application stores and manages data in a database, by submitting a textual SQL query to the database engine for processing. The application creates the query by simple string concatenation, embedding untrusted data. However, there is no separation between data and code; furthermore, the embedded data is neither checked for data type validity nor subsequently sanitized. Thus, the untrusted data could contain SQL commands, or modify the intended query. The database would interpret the altered query and commands as if they originated from the application, and execute them accordingly. Note that an attacker can exploit this vulnerability either by modifying the URL, or by submitting malicious data in the user input or other request fields.

General Recommendations

* Validate all untrusted data, regardless of source. Validation should be based on a whitelist: accept only data fitting a specified structure, rather than reject bad patterns.
    * In particular, check for:
        * Data type
        * Size
        * Range
        * Format
        * Expected values.
    * Restrict access to database objects and functionality, according to the Principle of Least Privilege.
    * Do not use dynamically concatenate strings to construct SQL queries.
    * Prefer using DB Stored Procedures for all data access, instead of ad-hoc dynamic queries.
    * Instead of unsafe string concatenation, use secure database components such as parameterized queries and object bindings (for example, commands and parameters).
    * Alternatively, an even better solution is to use an ORM library, in order to pre-define and encapsulate the allowed commands enabled for the application, instead of dynamically accessing the database directly. In this way the code plane and data plane should be isolated from each other.
    * Data validation can be performed effectively using a secure library, such as OWASP's Encoder or ESAPI libraries.
    * Prefer using `PreparedStatement` for parameterizing the queries, or even better `CallableStatement`. Add dynamic data via the `.set*()` methods, instead of string concatenation.
    * Consider using an ORM package, such as `Hibernate`, `myBatis`, or others.

Stored_XSS (CWE 79)

What Is The Risk

A successful XSS exploit would allow an attacker to rewrite web pages and insert malicious scripts which would alter the intended output. This could include HTML fragments, CSS styling rules, arbitrary JavaScript, or references to third party code. An attacker could use this to steal users' passwords, collect personal data such as credit card details, provide false information, or run malware. From the victim’s point of view, this is performed by the genuine website, and the victim would blame the site for incurred damage. An attacker could use legitimate access to the application to submit modified data to the application’s data-store. This would then be used to construct the returned web page, triggering the attack.

What Can Cause It

The application creates web pages that include untrusted data, whether from user input, the application’s database, or from other external sources. The untrusted data is embedded directly in the page's HTML, causing the browser to display it as part of the web page. If the input includes HTML fragments or JavaScript, these are displayed too, and the user cannot tell that this is not the intended page. The vulnerability is the result of directly embedding arbitrary data without first encoding it in a format that would prevent the browser from treating it like HTML or code instead of plain text. In order to exploit this vulnerability, an attacker would load the malicious payload into the data-store, typically via regular forms on other web pages. Afterwards, the application reads this data from the data-store, and embeds it within the web page as displayed for another user.

General Recommendations

* Fully encode all dynamic data, regardless of source, before embedding it in output.
    * Encoding should be context-sensitive. For example:
        * HTML encoding for HTML content
        * HTML Attribute encoding for data output to attribute values
        * JavaScript encoding for server-generated JavaScript
    * It is recommended to use the platform-provided encoding functionality, or known security libraries for encoding output.
    * Implement a Content Security Policy (CSP) with explicit whitelists for the application's resources only.
    * As an extra layer of protection, validate all untrusted data, regardless of source (note this is not a replacement for encoding). Validation should be based on a whitelist: accept only data fitting a specified structure, rather than reject bad patterns. Check for:
        * Data type
        * Size
        * Range
        * Format
        * Expected values
    * In the `Content-Type` HTTP response header, explicitly define character encoding (charset) for the entire page.
    * Set the `HTTPOnly` flag on the session cookie for "Defense in Depth", to prevent any successful XSS exploits from stealing the cookie.

Second_Order_SQL_Injection (CWE 89)

What Is The Risk

An attacker could directly access all of the system's data. The attacker would likely be able to steal any sensitive information stored by the system, including private user information, credit card details, proprietary business data, and any other secret data. Likewise, the attacker could possibly modify or erase existing data, or even add new bogus data. In some scenarios, it may even be possible to execute code on the database. In addition to disclosing or altering confidential information directly, this vulnerability might also be used to achieve secondary effects, such as bypassing authentication, subverting security checks, or forging a data trail. Further increasing the likelihood of exploit is the fact that this flaw is easy for attackers to find, and easy to exploit.

What Can Cause It

The application stores and manages data in a database, by submitting a textual SQL query to the database engine for processing. The application creates the query by simple string concatenation, embedding untrusted data. However, there is no separation between data and code; furthermore, the embedded data is neither checked for data type validity nor subsequently sanitized. Thus, the untrusted data could contain SQL commands, or modify the intended query. The database would interpret the altered query and commands as if they originated from the application, and execute them accordingly. In order to exploit this vulnerability, an attacker would load the malicious payload into the database, typically via forms on other web pages. Afterwards, the application reads this data from the database, and embeds it within the SQL query, as SQL commands.

General Recommendations

* Validate all untrusted data, regardless of source. Validation should be based on a whitelist: accept only data fitting a specified structure, rather than reject bad patterns.
    * In particular, check for:
        * Data type
        * Size
        * Range
        * Format
        * Expected values.
    * Restrict access to database objects and functionality, according to the Principle of Least Privilege.
    * Do not use dynamically concatenate strings to construct SQL queries.
    * Prefer using DB Stored Procedures for all data access, instead of ad-hoc dynamic queries.
    * Instead of unsafe string concatenation, use secure database components such as parameterized queries and object bindings (for example, commands and parameters).
    * Alternatively, an even better solution is to use an ORM library, in order to pre-define and encapsulate the allowed commands enabled for the application, instead of dynamically accessing the database directly. In this way the code plane and data plane should be isolated from each other.
    * Data validation can be performed effectively using a secure library, such as OWASP's Encoder or ESAPI libraries.
    * Prefer using `PreparedStatement` for parameterizing the queries, or even better `CallableStatement`. Add dynamic data via the `.set*()` methods, instead of string concatenation.
    * Consider using an ORM package, such as `Hibernate`, `myBatis`, or others.

Unsafe_Reflection (CWE 470)

What Is The Risk

Reflections directly affected by user input may, at best, result in unexpected or unstable behavior. At worst, it may allow attackers to inject and execute malicious code, invoke unexpected methods or classes from within the code to bypass logic flow or manipulate data and more.

What Can Cause It

Reflections are a method of coding wherein classes, methods or built-in functions are programmatically invoked by their name. If this name is dynamically determined from user inputs, then these inputs may change the flow of code, invoke unexpected or unintended code and, at times, allow injection of new, malicious code.

General Recommendations

Avoid using any form of dynamic code evaluation, and specifically, avoid using reflections unless absolutely required.
- If dynamic evaluation is not required, use logic flow to determine which functions to run
- If dynamic evaluation is required, enforce a white-list of allowed code segments to ensure arbitrary code cannot be executed

SSRF (CWE 918)

What Is The Risk

An attacker can abuse this flaw to make arbitrary requests, originating from the application server. This can be exploited to scan internal services; proxy attacks into a protected network; bypass network controls; download unauthorized files; access internal services and management interfaces; and possibly control the contents of requests and even steal server credentials.

What Can Cause It

The application accepts a URL (or other data) from the user, and uses this to make a request to another remote server. However, the attacker can inject an arbitrary URL into the request, causing the application to connect to any server the attacker wants. Thus, the attacker can abuse the application to gain access to services that would not otherwise be accessable, and cause the request to ostensibly originate from the application server.

General Recommendations

* Do not connect to arbitrary services based on user input.
* If possible, the application should have the user's browser retrieve the desired information directly.
* If it is necessary for the application to proxy the request on the server, explicitly whitelist the allowed target URLs, and do not include any sensitive server information.

Relative_Path_Traversal (CWE 23)

What Is The Risk

An attacker could define arbitrary file path for the application to use, potentially leading to: * Stealing sensitive files, such as configuration or system files * Overwriting files such as program binaries, configuration files, or system files * Deleting critical files, causing denial of service (DoS).

What Can Cause It

The application uses user input in the file path for accessing files on the application server’s local disk.

General Recommendations

1. Ideally, avoid depending on dynamic data for file selection.
2. Validate all input, regardless of source. Validation should be based on a whitelist: accept only data fitting a specified structure, rather than reject bad patterns. Check for:
   * Data type
   * Size
   * Range
   * Format
   * Expected values
4. Accept dynamic data only for the filename, not for the path and folders.
5. Ensure that file path is fully canonicalized.
6. Explicitly limit the application to use a designated folder that is separate from the applications binary folder.
7. Restrict the privileges of the application’s OS user to necessary files and folders. The application should not be able to write to the application binary folder, and should not read anything outside of the application folder and data folder.

Reflected_XSS (CWE 79)

What Is The Risk

A successful XSS exploit would allow an attacker to rewrite web pages and insert malicious scripts which would alter the intended output. This could include HTML fragments, CSS styling rules, arbitrary JavaScript, or references to third party code. An attacker could use this to steal users' passwords, collect personal data such as credit card details, provide false information, or run malware. From the victim's point of view, this is performed by the genuine website, and the victim would blame the site for incurred damage. The attacker could use social engineering to cause the user to send the website modified input, which will be returned in the requested web page.

What Can Cause It

The application creates web pages that include untrusted data, whether from user input, the application's database, or from other external sources. The untrusted data is embedded directly in the page's HTML, causing the browser to display it as part of the web page. If the input includes HTML fragments or JavaScript, these are displayed too, and the user cannot tell that this is not the intended page. The vulnerability is the result of directly embedding arbitrary data without first encoding it in a format that would prevent the browser from treating it like HTML or code instead of plain text. Note that an attacker can exploit this vulnerability either by modifying the URL, or by submitting malicious data in the user input or other request fields.

General Recommendations

* Fully encode all dynamic data, regardless of source, before embedding it in output.
    * Encoding should be context-sensitive. For example:
        * HTML encoding for HTML content
        * HTML Attribute encoding for data output to attribute values
        * JavaScript encoding for server-generated JavaScript
    * It is recommended to use the platform-provided encoding functionality, or known security libraries for encoding output.
    * Implement a Content Security Policy (CSP) with explicit whitelists for the application's resources only.
    * As an extra layer of protection, validate all untrusted data, regardless of source (note this is not a replacement for encoding). Validation should be based on a whitelist: accept only data fitting a specified structure, rather than reject bad patterns. Check for:
        * Data type
        * Size
        * Range
        * Format
        * Expected values
    * In the `Content-Type` HTTP response header, explicitly define character encoding (charset) for the entire page.
    * Set the `HTTPOnly` flag on the session cookie for "Defense in Depth", to prevent any successful XSS exploits from stealing the cookie.

Improper_Restriction_of_XXE_Ref (CWE 611)

What Is The Risk

An application that will parse and replace DTD entity references, in an XML document that the user controls, can allow an attacker to craft an XML document to read arbitrary server files. This XML document could contain an XML entity reference, which refers to an embedded DTD entity definition that points to any local file. This would enable the attacker to retrieve any arbitrary system file on the server.

What Can Cause It

An attacker could upload an XML document that contains a DTD declaration, in particular an entity defintion that refers to a local file on the server's disk, e.g. `<!ENTITY xxe SYSTEM "file:///c:/boot.ini">`. The attacker would then include an XML entity reference that refers back to that entity definition, e.g. `<div>&xxe;</div>` . If the parsed XML document is then returned to the user, the result will include the contents of the sensitive system file. This is caused by the XML parser, which is configured to automatically parse DTD declarations and resolve entity references, instead of disabling both DTD and external references altogether.

General Recommendations

Generic Guidance:
    * Avoid processing user input directly, where possible.
    * If necessary to receive XML from the user, ensure the XML parser is restricted and constrained.
    * In particular, disable DTD parsing and resolving of entities. Apply a strict XML schema on the server, and validate the input XML accordingly.

    Specific Recommendations:
    * Use safe XML parsers, and disable DTD parsing and entity resolving.
    * Do not enable DTD parsing or entity resolving.

Connection_String_Injection (CWE 99)

What Is The Risk

If an attacker could manipulate the application's connection string to the database server, they might be able do any of the following: * Damage application performance (by increasing the MIN POOL SIZE) * Tamper with the network connection (for example, via TRUSTED CONNECTION) * Direct the application to the attacker's bogus database * Discover the password to the system account on the database (by a brute-force attack).

What Can Cause It

In order to communicate with the database, or with another external server (for example, Active Directory), the application dynamically constructs a connection string. This connection string includes untrusted data, which may be controlled by a malicious user. Since it is not constrained or properly sanitized, the untrusted data could be used to maliciously manipulate the connection string.

General Recommendations

* Validate all input, regardless of source. Validation should be based on a whitelist: accept only data fitting a specified structure, rather than reject bad patterns. Check for:
  * Data type
  * Size
  * Range
  * Format
  * Expected values
* Do not allow users to control the database connection string. Avoid dynamically building connection strings based on untrusted data, especially user input.
* Store all connection strings in appropriate configuration mechanisms. If it is necessary to dynamically construct a connection string at runtime, do not include untrusted data directly in the connection string; instead, allow users to select from pre-defined connection strings.

Use_Of_Hardcoded_Password (CWE 259)

What Is The Risk

Hardcoded passwords expose the application to password leakage. If an attacker gains access to the source code, she will be able to steal the embedded passwords, and use them to impersonate a valid user. This could include impersonating end users to the application, or impersonating the application to a remote system, such as a database or a remote web service. Once the attacker succeeds in impersonating the user or application, she will have full access to the system, and be able to do anything the impersonated identity could do.

What Can Cause It

The application codebase has string literal passwords embedded in the source code. This hardcoded value is used either to compare to user-provided credentials, or to authenticate downstream to a remote system (such as a database or a remote web service). An attacker only needs to gain access to the source code to reveal the hardcoded password. Likewise, the attacker can reverse engineer the compiled application binaries, and easily retrieve the embedded password. Once found, the attacker can easily use the password in impersonation attacks, either directly on the application or to the remote system. Furthermore, once stolen, this password cannot be easily changed to prevent further misuse, unless a new version of the application is compiled. Moreover, if this application is distributed to numerous systems, stealing the password from one system automatically allows a class break in to all the deployed systems.

General Recommendations

* Do not hardcode any secret data in source code, especially not passwords.
* In particular, user passwords should be stored in a database or directory service, and protected with a strong password hash (e.g. bcrypt, scrypt, PBKDF2, or Argon2). Do not compare user passwords with a hardcoded value.
* Sytem passwords should be stored in a configuration file or the database, and protected with strong encryption (e.g. AES-256). Encryption keys should be securely managed, and not hardcoded.

XPath_Injection (CWE 643)

What Is The Risk

An attacker that can modify the XPath query with an arbitrary expression will be able to control which nodes in the XML document will be selected, and thus what data the application will process. This can have various effects depending on the type of XML document and its usage, including retrieval of secret information, control of application flow, modification of sensitive data, reading arbitrary files, or even authentication bypass, impersonation, and privilege escalation.

What Can Cause It

The application queries an XML document by using a textual XPath query. The application creates the query by simply concatenating strings, including untrusted data potentially under an attacker's control. Since the external data is neither checked for data type validity nor subsequently sanitized, the data could be maliciously crafted to cause the application to select the wrong information from the XML document.

General Recommendations

* Validate all external data, regardless of source. Validation should be based on a whitelist: accept only data fitting a specified structure, rather than reject bad patterns. Check for:
    * Data type
    * Size
    * Range
    * Format
    * Expected values
* Avoid making the XPath query dependent on external data.
* If it is absolutely necessary to include untrusted data in the query, the data must at least be first properly validated or sanitized.
* If possible, it is preferable to map XPath queries to external parameters, maintaining separation between data and code.
* Input sanitization, while not preferred, can be done safely when required with OWASP's `ESAPI` library, using `Encoder.encodeForXPath()`. Additional libraries may also provide similar functionality.
* Prefer parameterized XPath queries over data sanitization, to fully separate the input from the expression. Precompile the XPath query using `XPath.compile()`, after defining the variable resolution mechanism using `XPath.setXPathVariableResolver()` and a custom `XPathVariableResolver` class. Afterwards the variables can be provided to the `XPathVariableResolver`, and evaluated using the resulting `XPathExpression.evaluate()`.

Use_of_Broken_or_Risky_Cryptographic_Algorithm (CWE 327)

What Is The Risk

Using a weak or broken algorithm ruins the protection granted by using cryptographic mechanisms in the first place, harming the confidentiality or integrity of sensitive user data. This could allow an attacker to steal secret information, alter sensitive data, or forge the source of modified messages.

What Can Cause It

The application code specifies the name of the selected cryptographic algorithm, either via a String argument, a factory method, or a specific implementation class. These algorithms have fatal cryptographic weaknesses, that make it trivial to break in a reasonable timeframe. Strong algorithms should withstand attacks far beyond the realm of possible.

General Recommendations

* Only use strong, approved cryptographic algorithms, including AES, RSA, ECC, and SHA-256 respectively, amongst others.
* Do not use weak algorithms that are considered completely broken, such as DES, RC4, and MD5, amongst others.
* Avoid, where possible, using legacy algorithms that are not considered "future-proof" with sufficient safety margins, even though they are considered "safe enough" for today. This includes algorithms that are weaker than they should be, and have stronger replacements, even if they are not yet fatally broken - such as SHA-1, 3DES,
* Consider using a relevant official set of classifications, such as NIST or ENISA. If possible, use only FIPS 140-2 certified algorithm implementations.

Unchecked_Input_for_Loop_Condition (CWE 606)

What Is The Risk

An attacker could input a very high value, keeping application logic busy on very long loops and potentially causing a denial of service (DoS).

What Can Cause It

The application performs some repetitive task in a loop, and defines the number of times to perform the loop according to user input. A very high value could cause the application to get stuck in the loop and to be unable to continue to other operations.

General Recommendations

- Ideally, don’t base a loop on user-provided data.
- If it is necessary to have dynamic values in iterations - any user input must first be validated, and its range should be limited.

Parameter_Tampering (CWE 472)

What Is The Risk

A malicious user could access other users' information. By requesting information directly, such as by an account number, authorization may be bypassed and the attacker could steal confidential or restricted information (for example, a bank account balance), using a direct object reference.

What Can Cause It

The application provides user information without filtering by user ID. For example, it may provide information solely by a submitted account ID. The application concatenates the user input directly into the SQL query string, without any additional filtering. The application also does not perform any validation on the input, nor constrain it to a pre-computed list of acceptable values.

General Recommendations

Generic Guidance:

* Enforce authorization checks before providing any access to sensitive data, including the specific object reference.
* Explicitly block access to any unauthorized data, especially to other users' data.
* If possible, avoid allowing the user to request arbitrary data by simply sending a record ID. For example, instead of having the user send an account ID, the application should look up the account ID for the current authenticated user session.

Specific Mitigation:

* Do not concatenate user input directly into SQL queries.
* Include a user-specific identifier as a filter in the WHERE clause of the SQL query.
* Map the user input to an indirect reference, e.g. via a prepared list of allowable values.

CSRF (CWE 352)

What Is The Risk

An attacker could cause the victim to perform any action for which the victim is authorized, such as transferring funds from the victim's account to the attacker's. The action will be logged as being performed by the victim, in the context of their account, and potentially without their knowledge that this action has occurred.

What Can Cause It

The application performs some action that modifies database contents, based purely on HTTP request content, and does not require per-request renewed authentication (such as transaction authentication or a synchronizer token), instead relying solely on session authentication. This means that an attacker could use social engineering to cause a victim to browse to a link which contains a transaction request to the vulnerable application, submitting that request from the user's browser. Once the application receives the request, it would trust the victim's session, and would perform the action. This type of attack is known as Cross-Site Request Forgery (CSRF). A Cross-Site Request Forgery attack relies on the trust between a server and an authenticated client. By only validating the session, the server ensures that a request has emerged from a client's web-browser. However, any website may submit GET and POST requests to other websites, to which the browser will automatically add the session token if it is in a cookie. This cross-site request can then be trusted as arriving from the user's browser, but does not validate that it was their intent was to make this request.

General Recommendations

Mitigating CSRF requires an additional layer of authentication that is built into the request validation mechanism. This mechanism would attach an additional token that only applies to the given user; this token would be available within the user's web-page, but will not be attached automatically to a request from a different website (e.g. not stored in a cookie). Since the token is not automatically attached to the request, and is not available to the attacker, and is required by the server to process the request, it would be completely impossible for the attacker to fill in a valid cross-site form that contains this token.

Many platforms offer built-in CSRF mitigation functionality which should be used, and perform this type of token management under the hood. Alternatively, use a known or trusted library which adds this functionality.

If implementing CSRF protection is required, this protection should adhere to the following rules:

* Any state altering form (Create, Update, Delete operations) should enforce CSRF protection, by adding an CSRF token to every state altering form submission on the client.
* An CSRF token should be generated, and be unique per-user per-session (and, preferably, per request).
* The CSRF token should be inserted into the client side form, and be submitted to the server as part of the form request. For example, it could be a hidden field in an HTML form, or a custom header added by a Javascript request.
* The CSRF token in the request body or custom header must then be verified as belonging to the current user by the server, before a request is authorized and processed as valid.

Privacy_Violation (CWE 359)

What Is The Risk

A user's personal information could be stolen by a malicious programmer, or an attacker that intercepts the data.

What Can Cause It

The application sends user information, such as passwords, account information, or credit card numbers, outside the application, such as writing it to a local text or log file or sending it to an external web service.

General Recommendations

1. Personal data should be removed before writing to logs or other files.
2. Review the need and justification of sending personal data to remote web services.

Plaintext_Storage_of_a_Password (CWE 256)

What Is The Risk

Passwords that are stored in plaintext outside of a secure container would be trivial to read, if retrieved by an attacker. Leaked passwords could then be used to authenticate to other sensitive resources, to perform actions and retrieve additional information.

What Can Cause It

A password was stored in plaintext, outside of a secure container such as a password hashing algorithm or data encryption.

General Recommendations

Generic Guidance:
- Always use strong, modern algorithms for encryption, hashing, and so on.
- Do not use weak, outdated, or obsolete algorithms.
- Ensure you select the correct cryptographic mechanism according to the specific requirements.
- Passwords should be protected with a dedicated password protection scheme, such as bcrypt, scrypt, PBKDF2, or Argon2.

Specific Recommendations:
- Do not use SHA-1, MD5, or any other weak hash algorithm to protect passwords or personal data. Instead, use a stronger hash such as SHA-256 when a secure hash is required.
- Do not use DES, 3DES, RC2, or any other weak encryption algorithm to protect passwords or personal data. Instead, use a stronger encryption algorithm such as AES to protect personal data.
- Do not use weak encryption modes such as ECB, or rely on insecure defaults. Explicitly specify a stronger encryption mode, such as GCM.
- For symmetric encryption, use a key length of at least 256 bits.

Open_Redirect (CWE 601)

What Is The Risk

An attacker could use social engineering to get a victim to click a link to the application, so that the user will be immediately redirected to another site of the attacker's choice. An attacker can then craft a destination website to fool the victim; for example - they may craft a phishing website with an identical looking UI as the previous website's login page, and with a similar looking URL, convincing the user to submit their access credentials in the attacker's website. Another example would be a phishing website with an identical UI as that of a popular payment service, convincing the user to submit their payment information.

What Can Cause It

The application redirects the user's browser to a URL provided by a tainted input, without first ensuring that URL leads to a trusted destination, and without warning users that they are being redirected outside of the current site. An attacker could use social engineering to get a victim to click a link to the application with a parameter defining another site to which the application will redirect the user's browser. Since the user may not be aware of the redirection, they may be under the misconception that the website they are currently browsing can be trusted.

General Recommendations

1. Ideally, do not allow arbitrary URLs for redirection. Instead, create a mapping from user-provided parameter values to legitimate URLs.
2. If it is necessary to allow arbitrary URLs:
    * For URLs inside the application site, first filter and encode the user-provided parameter, and then either:
        * Create a white-list of allowed URLs inside the application
        * Use variables as a relative URL as an absolute one, by prefixing it with the application site domain - this will ensure all redirection will occur inside the domain
    * For URLs outside the application (if necessary), either:
        * White-list redirection to allowed external domains by first filtering URLs with trusted prefixes. Prefixes must be tested up to the third slash \[/\] - `scheme://my.trusted.domain.com/,` to prevent evasion. For example, if the third slash \[/\] is not validated and scheme://my.trusted.domain.com is trusted, the URL scheme://my.trusted.domain.com.evildomain.com would be valid under this filter, but the domain actually being browsed is evildomain.com, not domain.com.
        * For fully dynamic open redirection, use an intermediate disclaimer page to provide users with a clear warning that they are leaving the site.

Missing_HSTS_Header (CWE 346)

What Is The Risk

Failure to set an HSTS header and provide it with a reasonable "max-age" value of at least one year may leave users vulnerable to Man-in-the-Middle attacks.

What Can Cause It

Many users browse to websites by simply typing the domain name into the address bar, without the protocol prefix. The browser will automatically assume that the user's intended protocol is HTTP, instead of the encrypted HTTPS protocol. When this initial request is made, an attacker can perform a Man-in-the-Middle attack and manipulate it to redirect users to a malicious web-site of the attacker's choosing. To protect the user from such an occurence, the HTTP Strict Transport Security (HSTS) header instructs the user's browser to disallow use of an unsecure HTTP connection to the the domain associated with the HSTS header. Once a browser that supports the HSTS feature has visited a web-site and the header was set, it will no longer allow communicating with the domain over an HTTP connection. Once an HSTS header was issued for a specific website, the browser is also instructed to prevent users from manually overriding and accepting an untrusted SSL certificate for as long as the "max-age" value still applies. The recommended "max-age" value is for at least one year in seconds, or 31536000.

General Recommendations

* Before setting the HSTS header - consider the implications it may have:
    * Forcing HTTPS will prevent any future use of HTTP, which could hinder some testing
    * Disabling HSTS is not trivial, as once it is disabled on the site, it must also be disabled on the browser
* Set the HSTS header either explicitly within application code, or using web-server configurations.
* Ensure the "max-age" value for HSTS headers is set to 31536000 to ensure HSTS is strictly enforced for at least one year.
* Include the "includeSubDomains" to maximize HSTS coverage, and ensure HSTS is enforced on all sub-domains under the current domain
    * Note that this may prevent secure browser access to any sub-domains that utilize HTTP; however, use of HTTP is very severe and highly discouraged, even for websites that do not contain any sensitive information, as their contents can still be tampered via Man-in-the-Middle attacks to phish users under the HTTP domain.
* Once HSTS has been enforced, submit the web-application's address to an HSTS preload list - this will ensure that, even if a client is accessing the web-application for the first time (implying HSTS has not yet been set by the web-application), a browser that respects the HSTS preload list would still treat the web-application as if it had already issued an HSTS header. Note that this requires the server to have a trusted SSL certificate, and issue an HSTS header with a maxAge of 1 year (31536000)
* Note that this query is designed to return one result per application. This means that if more than one vulnerable response without an HSTS header is identified, only the first identified instance of this issue will be highlighted as a result. If a misconfigured instance of HSTS is identified (has a short lifespan, or is missing the "includeSubDomains" flag), that result will be flagged. Since HSTS is required to be enforced across the entire application to be considered a secure deployment of HSTS functionality, fixing this issue only where the query highlights this result is likely to produce subsequent results in other sections of the application; therefore, when adding this header via code, ensure it is uniformly deployed across the entire application. If this header is added via configuration, ensure that this configuration applies to the entire application.
* Note that misconfigured HSTS headers that do not contain the recommended max-age value of at least one year or the "includeSubDomains" flag will still return a result for a missing HSTS header.

Trust_Boundary_Violation_in_Session_Variables (CWE 501)

What Is The Risk

Code that reads from Session variables may trust them as server-side variables, but they may have been tainted by user inputs. This can lead to tampering with parameters used to authenticate or authorize users. Further, tainted Session variables offer an additional attack surface against the application - if untrusted data taints a Session variable, and that Session variable is then used elsewhere without sanitization as if it were trusted, it could lead to further attacks such as Cross-Site Scripting, SQL Injection and more.

What Can Cause It

Server-side Session variables, or objects, are values assigned to a specific session, which is associated with a specific user. Often, they hold data relevant to that user's session, such as specific identifiers, user-type, authorization, authentication information and more. As such, the paradigm often associated to the Session object is that its contents can be trusted, as users cannot generally set these values themselves. The application places user input, which is untrusted data, in the server-side Session object, which is considered a trusted location. This could lead developers to treat untrusted data as trusted.

General Recommendations

1. Validate and sanitize all input, regardless of source. Validation should be based on a whitelist: accept only data fitting a specified structure, rather than reject bad patterns. Check for:
    * Data type
    * Size
    * Range
    * Format
    * Expected values
3. Don’t mix untrusted user input with trusted data.

Heap_Inspection (CWE 244)

What Is The Risk

All variables stored by the application in unencrypted memory can potentially be retrieved by an unauthorized user, with privileged access to the machine. For example, a privileged attacker could attach a debugger to the running process, or retrieve the process's memory from the swapfile or crash dump file. Once the attacker finds the user passwords in memory, these can be reused to easily impersonate the user to the system.

What Can Cause It

String variables are immutable - in other words, once a string variable is assigned, its value cannot be changed or removed. Thus, these strings may remain around in memory, possibly in multiple locations, for an indefinite period of time until the garbage collector happens to remove it. Sensitive data, such as passwords, will remain exposed in memory as plaintext with no control over their lifetime. While it may still be possible to retrieve data from memory, even if it uses a mutable container that is cleared, or retrieve a decryption key and decrypt sensitive data from memory - layering sensitive data with these types of protection would significantly increase the required effort to do so. By setting a high bar for retrieving sensitive data from memory, and reducing the amount and exposure of sensitive data in memory, an adversary is significantly less likely to succeed in obtaining valuable data.

General Recommendations

When it comes to avoiding Heap Inspection, it is important to note that, given any read access to memory or a memory dump of an application, it is always likely to disclose some sensitive data to an adversary - these suggestions are part of defense-in-depth principles for protection of sensitive data in cases where such memory read access is successfully obtained. These recommendations will enable significant reduction in the lifespan and exposure of sensitive data in memory; however - given enough time, effort and unlimited access to memory, they will only go so far in protecting sensitive data being used by the application. The only way to handle Heap Inspection issues is to minimize and reduce data exposure, and obscure it in memory wherever possible.

* Do not store sensitive data, such as passwords or encryption keys, in memory in plain-text, even for a short period of time.
* Prefer to use specialized classes that store encrypted data in memory to ensure it cannot be trivially retrieved from memory.
* When required to use sensitive data in its raw form, temporarily store it in mutable data types, such as byte arrays, to reduce readability from memory, and then promptly zeroize the memory locations, to reduce exposure duration of this data while in memory.
* Ensure that memory dumps are not exchanged with untrusted parties, as even by ensuring all of the above - it may still be possible to reverse-engineer encrypted containers, or retrieve bytes of sensitive data from memory and rebuild it.
* In Java, do not store passwords in immutable strings - prefer using an encrypted memory object, such as SealedObject.

Supply Chain Security Vulnerabilities

Secret Detection Severities